



N° d'ordre :/...



Université Cadi Ayyad
École Nationale des Sciences Appliquées de Safi
Département Informatique, Réseaux et Télécommunications (IRT)

MÉMOIRE DE PROJET DE FIN D'ÉTUDES

Pour l'obtention du diplôme:

INGÉNIEUR D'ÉTAT

En Génie Réseaux et Télécommunications

**Mise en œuvre d'une architecture Zero Trust
dans un environnement cloud Azure selon le
standard NIST 800-207**

Réalisé Par

Nadine Salma

Effectué à

DATAPROTECT
DATAPROTECT
Security is our **commitment**

Encadré à l'ENSAS par :

Mme. SOUNNI Hind

Encadré à Dataprotect par :

M. REDDAD Saad

Soutenu le 02/07/2025 devant le jury composé de :

M. BARAKA Kamal

M. DALLI Anouar

Mme. SOUNNI Hind

Professeur à l'ENSA de Safi

Professeur à l'ENSA de Safi

Professeur à l'ENSA de Safi

Année Universitaire : 2024/2025

Dédicaces

Je dédie ce travail :

À mes chers parents,

Pour votre amour inconditionnel, vos sacrifices silencieux, et vos prières qui m'ont toujours protégé. Vous êtes les racines profondes de ma force et de ma persévérance.

À mon frère et sœur,

Merci pour votre soutien constant, vos mots d'encouragement, et votre présence fidèle dans les moments d'incertitude. Les frères et sœurs sont comme des étoiles. On ne les voit pas toujours, mais on sait qu'ils sont là. On rit, on se chamaille, mais on s'aime plus que tout.

À ma chère famille,

Pour son affection chaleureuse, sa patience infinie, et l'espoir qu'elle ne cesse de semer dans ma vie.

À mes meilleur(e)s ami(e)s,

Pour les fous rires, les longues conversations, les silences partagés, et surtout... pour avoir cru en moi quand moi-même j'hésitais.

À mon frère,

*"So, I'll stay whenever the sun's bright you'll find me
See when the flowers bloom, you can just presume that I'll always be there
Stay here I'm happy whenever you're around me
Where you go, I'll follow, like there's no tomorrow ooh just stay"*

À celles et ceux que le cœur reconnaît,

À ceux qui ont tendu la main, même quand tout semblait loin,

À ceux qui savent rester...

Et à ceux que je n'oublierai jamais.

NADINE Salma

Remerciements

Je tiens à exprimer ma sincère gratitude à Madame Hind Sounni, mon encadrante d'école, pour son accompagnement précieux tout au long de cette aventure. Votre bienveillance, vos conseils avisés et votre soutien m'ont permis d'avancer avec confiance et sérénité. Grâce à vous, j'ai pu surmonter les défis rencontrés et enrichir mon parcours académique avec rigueur et détermination.

À Monsieur Saad Reddad, mon encadrant de stage, je témoigne toute ma reconnaissance pour votre encadrement, vos orientations pertinentes et votre disponibilité. Votre expertise et vos conseils ont été une source précieuse d'apprentissage, me permettant de mieux appréhender les réalités du monde professionnel.

Je tiens également à remercier tous les membres du jury de ma soutenance, qui ont pris le temps d'examiner mon travail avec attention et d'enrichir sa qualité par leurs remarques constructives. Votre analyse et vos suggestions sont une source d'amélioration et une précieuse contribution à mon développement.

À mes chers collègues, compagnons de route dans cette aventure, merci pour votre soutien, votre entraide et ces précieux moments de partage. Nos échanges ont été une véritable richesse, rendant ce parcours plus agréable et motivant.

Enfin, à ma famille, mon refuge et ma plus grande force, je vous dédie toute ma reconnaissance pour votre amour inconditionnel, votre patience et vos encouragements. Vos prières, votre confiance et votre présence ont été le socle sur lequel j'ai bâti mes ambitions. Que ces mots traduisent tout le respect et la gratitude que je vous porte.

Résumé

Ce rapport présente les travaux effectués dans le cadre de mon Projet de Fin d'Études au sein de l'entreprise DATAPROTECT, en vue de l'obtention du diplôme d'ingénieur d'État en Génie Télécommunications et Réseaux de l'École Nationale des Sciences Appliquées de Safi.

Dans un contexte marqué par l'évolution constante des menaces informatiques, ce projet s'inscrit dans une démarche de renforcement de la sécurité des systèmes d'information à travers l'application concrète du modèle Zero Trust, tel que défini par la norme NIST SP 800-207. Mon objectif principal a été de concevoir et de mettre en œuvre une infrastructure cloud sécurisée, fondée sur les modèles de déploiement EIG, SASE et SDP, en s'appuyant sur Microsoft Azure et Prisma Access.

L'environnement réalisé intègre plusieurs machines virtuelles exposées à des attaques internes et externes, permettant de simuler des scénarios réalistes. Les services Microsoft Sentinel et Defender for Cloud ont été utilisés pour la détection et la gestion des incidents de sécurité, avec visualisation des attaques via des workbooks personnalisés enrichis de données Geoip. L'automatisation de certaines tâches SOC a été assurée à l'aide de Logic Apps et l'intégration d'OpenAI pour la génération de résumés lisibles des incidents.

Par ailleurs, le projet a mis en œuvre la gestion des identités avec Entra ID, l'authentification unique (SSO), la segmentation réseau (NSG, Peering), et la visualisation des données FinOps et SOC à l'aide de Power BI. L'infrastructure a été entièrement déployée via Terraform, garantissant reproductibilité et cohérence.

Ce projet démontre la faisabilité d'une architecture Zero Trust dans un environnement cloud et constitue une base concrète pour la mise en place d'un Security Operations Center (SOC) moderne, automatisé et intelligent.

Mots clés : Zero Trust, NIST 800-207, Microsoft Azure, Prisma Access, Sentinel, Defender for Cloud, Logic Apps, OpenAI, Power BI, Entra ID, Terraform, Sécurité Cloud, SASE, EIG, SDP.

Abstract

This report presents the work carried out as part of my End-of-Studies Project within the company DATAPROTECT, for the completion of the state engineering degree in Telecommunications and Network Engineering at the National School of Applied Sciences of Safi.

In the face of increasingly sophisticated cyber threats, the objective of this project was to design and implement a secure cloud-based architecture aligned with the Zero Trust principles defined in NIST SP 800-207. The solution is based on deployment models such as EIG, SASE, and SDP, and leverages both Microsoft Azure and Prisma Access to simulate, detect, and respond to real-world attacks.

The implemented environment includes several virtual machines, exposed to brute-force and SQL attacks. Microsoft Sentinel and Defender for Cloud were used for centralized threat detection and compliance management, enriched with custom Geoip data visualizations through Sentinel Workbooks. Automation was introduced using Azure Logic Apps combined with OpenAI to generate human-readable incident tasks.

Identity management, SSO, and RBAC were integrated through Microsoft Entra ID, while security visualization and cost management dashboards were built using Power BI. The entire infrastructure was provisioned using Terraform, ensuring consistency and repeatability across deployments.

This project demonstrates the feasibility and effectiveness of implementing a Zero Trust Architecture within the cloud, serving as a foundation for building an intelligent and automated Security Operations Center (SOC).

Keywords: Zero Trust, NIST 800-207, Microsoft Azure, Prisma Access, Sentinel, Defender for Cloud, Logic Apps, OpenAI, Power BI, Entra ID, Terraform, Cloud Security, SASE, EIG, SDP.

ملخص

يقدم هذا التقرير ملخصاً للعمل المنجز في إطار مشروع نهاية الدراسة داخل شركة DATAPROTECT، لنيل دبلوم مهندس دولة في الهندسة الشبكية والاتصالات من المدرسة الوطنية للعلوم التطبيقية بأسفي.

أمام التهديدات السيبرانية المتزايدة تطوراً وتعقيداً، تمحور الهدف من هذا المشروع حول تصميم وتنفيذ بنية سحابية آمنة، مستندة إلى مبادئ Zero Trust كما حددها معيار NIST SP 800-207. وقد اعتمد الحل المقترح على نماذج نشر متقدمة مثل EIG، وSASE، وSDP، مع توظيف منصتي Microsoft Azure وPrisma Access لمحاكاة الهجمات الحقيقية، رصدها، والاستجابة لها.

يتضمن البيئة المنشأة عدة آلات افتراضية تم تعريضها لهجمات من نوع Brute-force، حيث تم اعتماد Microsoft Sentinel وDefender for Cloud للكشف المركزي عن التهديدات وضمان التوافق الأمني. كما تم إثراء لوحات المراقبة عبر Sentinel ببيانات Geoip مخصصة لتصور مواقع الهجمات بشكل تفاعلي.

ولتعزيز الأتمتة، تم استخدام Azure Logic Apps بالتكامل مع OpenAI لإنتاج ملخصات للحوادث الأمنية بلغة بشرية بسيطة. أما إدارة الهوية، وتسجيل الدخول الموحد، والتحكم في الوصول، فقد تم تنفيذها من خلال Microsoft Entra ID. كما تم إنشاء لوحات معلومات تفاعلية للأمان وتكلفة الموارد باستخدام Power BI.

وقد تم اعتماد Terraform كأداة لتوفير البنية التحتية تلقائياً، بما يضمن إعادة نشرها بطريقة متسقة وفعالة. يثبت هذا المشروع جدوى وكفاءة تنفيذ بنية Zero Trust في البيئة السحابية، ويمهد الطريق نحو بناء مركز عمليات أمنية ذكي ومؤتمت (SOC).

الكلمات المفتاح:

Defender for Cloud، Sentinel، Prisma Access، Microsoft Azure، NIST 800-207، Zero Trust، SDP، EIG، SASE، أمن السحابة، Terraform، Entra ID، Power BI، OpenAI، Logic Apps

Liste des abréviations

Abréviation	Désignation
ACM	Azure Cost Management
ARM	Azure Resource Manager
DLP	Data Loss Prevention
DNS	Domain Name System
EIG	Enterprise Identity Governance
Entra ID	Microsoft Entra ID (formerly Azure Active Directory)
FinOps	Cloud Financial Operations
IaC	Infrastructure as Code
IP	Internet Protocol
KQL	Kusto Query Language
NSG	Network Security Group
PA	Policy Administrator
PE	Policy Engine
PEP	Policy Enforcement Point
RBAC	Role-Based Access Control
SaaS	Software as a Service
SAML	Security Assertion Markup Language
SASE	Secure Access Service Edge
SDP	Software Defined Perimeter
SIEM	Security Information and Event Management
SOC	Security Operations Center
SSO	Single Sign-On
TF	Terraform
VM	Virtual Machine
VNet	Virtual Network

ZTNA

Zero Trust Network Access

Liste des figures

Figure 1: Historique de l'entreprise Dataprotect.....	2
Figure 2: Dataprotect: des projets dans une quarantaine de pays.....	3
Figure 3: Organisation interne de Dataprotect	4
Figure 4: Activité de Dataprotect UNE VISION 360° DE LA CYBERSÉCURITÉ	5
Figure 5: Diagramme de Gantt.....	10
Figure 6: Analyse SWOT	24
Figure 7: Architecture de la solution	25
Figure 8: Architecture du projet Terraform	28
Figure 9: Terraform init.....	29
Figure 10: Terraform plan	30
Figure 11: Terraform apply.....	30
Figure 12: L'infrastructure déployée via Terraform	31
Figure 13: Configuration Microsoft Defender	32
Figure 14: Configuration des paramètres de sécurité dans Microsoft Defender.....	33
Figure 15: Recommandation de Microsoft Defender pour Key Vault	34
Figure 16: Regulatory Compliance	35
Figure 17: Création d'un DCR.....	36
Figure 18: Test de récupération des logs de Windows	37
Figure 19: Définition des règles de détection dans Microsoft Sentinel	38
Figure 20: Analyse des incidents détectés dans Microsoft Sentinel.....	39
Figure 21: Investigation des incidents détectés dans Microsoft Sentinel.....	39
Figure 22: Clôture des incidents une fois l'analyse terminé vis status	40
Figure 23: Tableau de bord Sentinel.....	41
Figure 24: Interrogation de la Watchlist geoip dans logs	42
Figure 25: Création des Workbooks dans Sentinel.....	42
Figure 26: Workbook des authentifications échouées dans linux	43
Figure 27: Workbook des authentifications échouées dans le serveur MySQL.....	43
Figure 28: Workbook when NSG Allowed	44
Figure 29: Logic Apps designer 1	45
Figure 30: Création d'une règle d'automatisation	46
Figure 31: Exécution de notre règle d'automatisation	47
Figure 32: Mise en place de RBAC dans Entra ID	48
Figure 33: Configuration du SAML pour l'application Internal-ZT-App.....	49
Figure 34: Affichage des actions effectuées sur les ressources Azure via les AuditLogs	49
Figure 35: Création d'un groupe de connecteurs dans Prisma Access.....	50
Figure 36: Vérification que le connecteur ZTNA est actif.....	51
Figure 37: Configuration d'une politique de prévention des pertes de données (DLP).....	52
Figure 38: Test du profil DLP sur un fichier suspect	52
Figure 39: Exportation des données liées aux aspects FinOps.....	53

Figure 40: Surveillance SOC via Power BI	54
Figure 41: Attack Map.....	55
Figure 42: Suivi Financier (FinOps)	56
Figure 43 : Coût par service	57
Figure 44: Coût par resource group.....	58
Figure 45: Coût par resource location	59
Figure 46: Forecast cost	59

Liste des tableaux

Tableau 1: Tableau comparatif entre la sécurité traditionnelle périmétrique et l'approche moderne Zero Trust	9
Tableau 2: Tableau comparatif entre différents Cloud Providers	17
Tableau 3: Tableau comparatif entre Terraform et Bicep	18
Tableau 4: Tableau comparatif SIEM / SOAR	19
Tableau 5: Outils SASE	20
Tableau 6: Outils EIG	21
Tableau 7: Outils PA (Policy Administrator)	22
Tableau 8: Outils PEP	22
Tableau 9: Policy Engine (PDP)	23

Table des matières

Dédicaces	i
Remerciements	ii
Résumé	iii
Abstract	iv
ملخص	v
Liste des abréviations	vi
Liste des figures	viii
Liste des tableaux	x
Table des matières	xi
Introduction générale	1
Chapitre I : Contexte général du projet	2
1. Introduction	2
2. Présentation de l'organisme d'accueil	2
2.1. Présentation du groupe Dataprotect	2
2.2. Historique du groupe Dataprotect	2
2.3. Organigramme de Dataprotect	3
2.4. La BU Cloud Security	4
2.5. Activité de l'entreprise	4
2.6. Les clients du groupe	5
3. Contexte du projet	5
3.1. Contexte général	5
3.2. Problématique	6
3.3. Objectif du projet	7
3.4. État de l'art des menaces et de la sécurité cloud	8
3.5. Enjeux de l'approche Zero Trust dans un contexte cloud	9
3.6. Diagramme de GANTT	10
Chapitre II : Etude et analyse du projet	12
1. Introduction	12
2. Analyse et critique de l'existant	12
3. Spécification des besoins	13
3.1. Notions clés	13
3.2. Besoins fonctionnels	14

3.3.	Besoins non fonctionnels	15
4.	Étude des choix techniques	16
4.1.	Choix du Cloud Provider	16
4.2.	Choix d'outil d'automatisation	18
4.3.	Choix du SIEM	19
4.4.	Outils SASE	20
4.5.	Outils EIG	21
4.6.	Outils PA	22
4.7.	Outils PEP	22
4.8.	Policy Engine PDP	23
5.	Analyse SWOT des outils du projet Zero Trust	24
6.	Architecture de la solution	25
6.1.	Infrastructure Cloud et Réseau	25
6.2.	Outils et Services Utilisés	26
7.	Conclusion	26
Chapitre III : Infrastructure et Sécurité de Base		27
1.	Introduction	27
1.1.	Configuration du projet Terraform	27
1.2.	Architecture du projet Terraform	27
1.3.	La répartition des fichiers	28
1.4.	Déploiement du script	29
2.	Sécurité et Conformité des Charges de Travail	31
2.1.	Surveillance avec Microsoft Defender for Cloud	31
2.2.	Recommandations et Conformité réglementaire	33
3.	SIEM et Investigation avec Microsoft Sentinel	35
3.1.	Configuration d'agents pour la collecte des logs	35
3.2.	Règles Analytiques et Détection d'Incidents	37
3.3.	Workbooks et Visualisation	41
3.3.1.	Configuration du fichier Geoip dans Sentinel Watchlist	41
3.3.2.	Création des Workbooks	42
4.	Conclusion	44
Chapitre IV : Supervision et Automatisation		45
1.	Introduction :	45
2.	Automatisation avec Logic Apps et OpenAI	45
3.	Contrôle des Identités et de l'Accès Zero Trust	47

3.1. Intégration Entra ID	47
3.2. Prisma Access et ZTNA	50
4. Tableau de Bord SOC et Analyse FinOps	52
4.1. Surveillance SOC via Power BI	53
4.2. Suivi Financier (FinOps)	55
5. Conclusion	59
Conclusion et perspectives.....	60
Bibliographie.....	61

Introduction générale

Dans un contexte où les entreprises accélèrent leur transformation numérique, la question de la sécurité des systèmes d'information s'impose plus que jamais comme une priorité stratégique. L'évolution des modes de travail, l'adoption massive du cloud et la multiplication des menaces informatiques obligent aujourd'hui les organisations à repenser leurs modèles de sécurité. Les approches classiques, centrées sur la protection du périmètre réseau, ne suffisent plus à faire face à des attaques de plus en plus ciblées, sophistiquées et persistantes.

Face à ces enjeux, le modèle Zero Trust, défini par la norme NIST 800-207, propose une nouvelle vision fondée sur un principe simple mais fondamental : ne jamais accorder de confiance par défaut, quel que soit l'emplacement de l'utilisateur ou de la ressource. Cette approche repose sur la vérification systématique des identités, le contrôle d'accès contextuel, la micro-segmentation du réseau et une surveillance continue des activités.

C'est dans cette optique que s'inscrit ce Projet de Fin d'Études, qui a pour objectif de concevoir et de déployer une architecture cloud inspirée des modèles de sécurité Zero Trust, en s'appuyant notamment sur les solutions proposées par Microsoft Azure et Prisma Access. Le projet met en œuvre plusieurs technologies complémentaires : gestion des identités avec Entra ID, supervision centralisée avec Microsoft Sentinel, protection des charges de travail via Defender for Cloud, automatisation avec Logic Apps, visualisation avec Power BI, et enrichissement analytique grâce à l'intelligence artificielle d'OpenAI.

L'environnement mis en place permet de simuler des attaques réelles, de capturer les journaux d'événements, de déclencher des alertes de sécurité, et d'analyser les comportements suspects. Il s'appuie sur une infrastructure entièrement automatisée avec Terraform, intégrant des machines cibles (Windows et Linux), des attaques internes et externes, et des connexions réseau sécurisées par des règles NSG et du peering transitif. Le tout est complété par l'intégration d'une logique Zero Trust adaptée aux modèles EIG, SASE et SDP, démontrant ainsi la faisabilité et la pertinence d'une telle approche dans un environnement cloud.

Ce rapport est structuré en trois chapitres. Le premier chapitre présente le contexte général, les problématiques rencontrées ainsi que les objectifs visés. Le deuxième chapitre est consacré à l'étude des besoins, à l'analyse du projet, au choix des outils et aux fondements techniques retenus. Enfin, le troisième chapitre expose en détail la réalisation pratique du projet, de la conception de l'infrastructure jusqu'à la mise en œuvre des composants de sécurité et l'exploitation des résultats.

Chapitre I : Contexte général du projet

1. Introduction

Dans ce chapitre, on va situer notre travail dans son contexte général en commençant par présenter l'entreprise Dataprotect, où s'est déroulé notre stage. Ensuite, on procédera à définir le cadre du travail, mettant en lumière les objectifs du projet et la méthodologie que nous avons choisie pour sa réalisation.

2. Présentation de l'organisme d'accueil

2.1. Présentation du groupe Dataprotect

Dataprotect est une entreprise marocaine fondée en 2009 et spécialisée dans la cybersécurité. Elle est rapidement devenue un acteur majeur du secteur, en combinant expertise technique, innovation et une forte présence internationale. Aujourd'hui, Dataprotect compte plus de 220 collaborateurs, dont une majorité de consultants hautement qualifiés dédiés à la sécurité informatique.

Présente à Casablanca, Paris, Abidjan et Dubaï, l'entreprise opère sur plus de 40 pays à travers l'Afrique, l'Europe, le Moyen-Orient et l'Asie Pacifique. Forte de plus de 1500 projets réalisés, Dataprotect accompagne des organisations de toute taille dans la protection de leurs systèmes d'information, en fournissant des services allant du conseil stratégique à l'implémentation technique, avec une approche 360° de la cybersécurité.

2.2. Historique du groupe Dataprotect

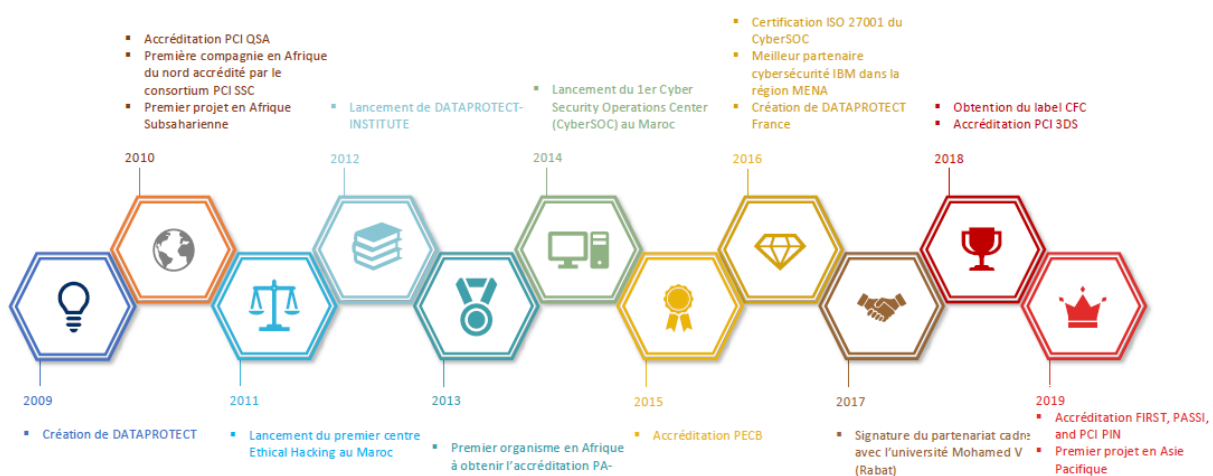


Figure 1: Historique de l'entreprise Dataprotect

Depuis sa création, Dataprotect a connu une croissance constante et marquante dans le paysage de la cybersécurité :

- 2009 : Fondation de l'entreprise et obtention de l'accréditation PCI QSA, une première en Afrique du Nord.
- 2011 : Lancement du premier centre d'« Ethical Hacking » au Maroc.
- 2012 : Mise en place du tout premier Cyber Security Operations Center (CyberSOC) au Maroc.
- 2015-2016 : Création de la filiale en France et ouverture de bureaux à Abidjan et Dubaï.
- 2017 à 2020 : Multiplication des accréditations internationales : PASSI, PCI 3DS, PCI PIN, FIRST, etc.
- Aujourd'hui : Dataprotect continue d'élargir son champ d'intervention en proposant des services de cybersécurité offensive, de gouvernance, de cyberdéfense, de sécurité cloud et d'intelligence de sécurité.

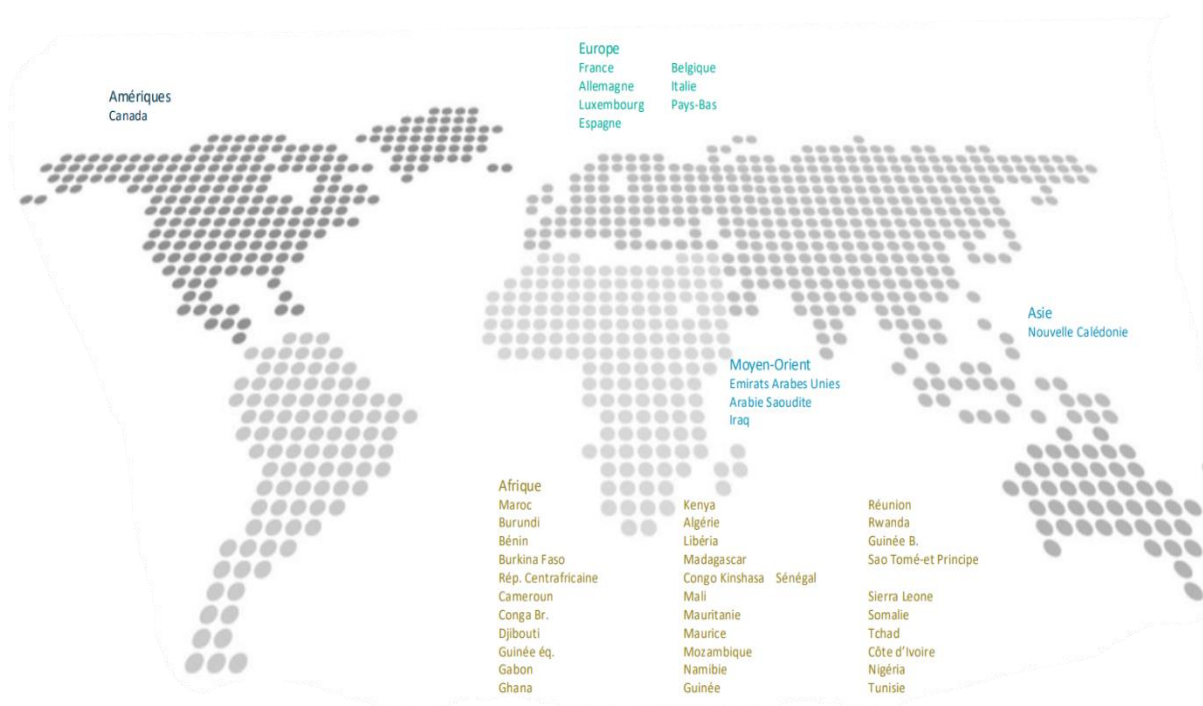


Figure 2: Dataprotect: des projets dans une quarantaine de pays

2.3. Organigramme de Dataprotect

L'organisation interne de DATAPROTECT est structurée en plusieurs unités fonctionnelles spécialisées qui se regroupent principalement en deux grands pôles : le support business (Finance, RH, Marketing, etc.) et l'expertise technique (Cyberdéfense, Offensive Security, Cloud Security, etc.), le tout supervisé directement par la Direction Générale.

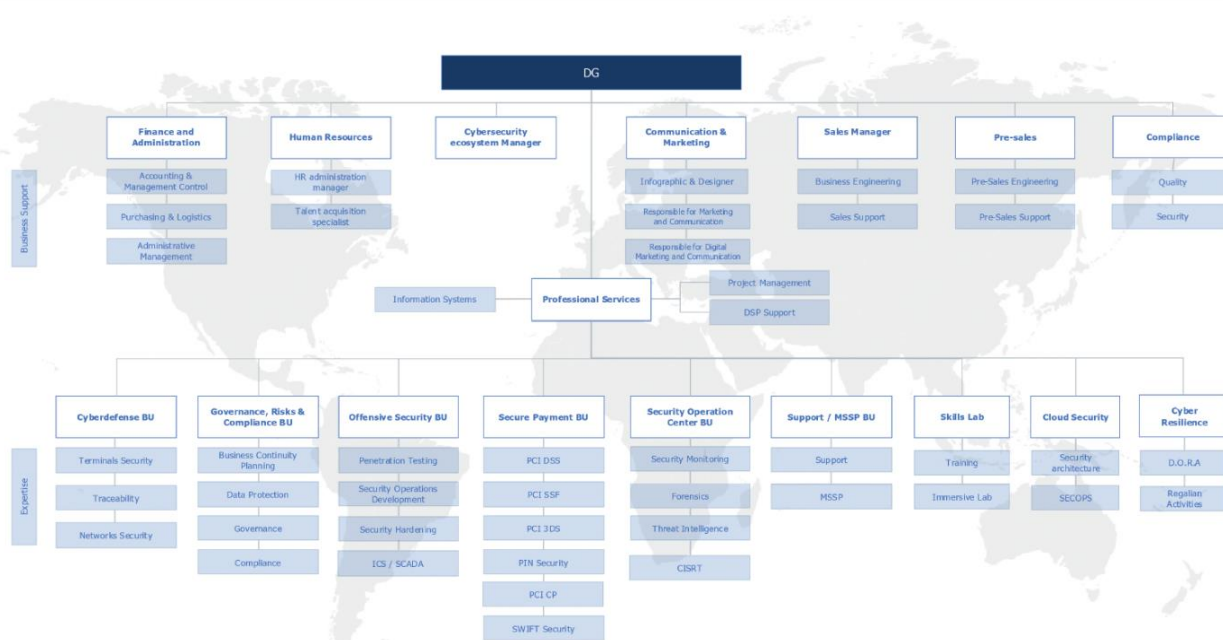


Figure 3: Organisation interne de Dataprotect

2.4. La BU Cloud Security

La BU Cloud Security de Dataprotect se concentre sur la protection des environnements cloud. Elle assure la sécurité des données hébergées, la protection des applications cloud, ainsi que la conformité aux exigences réglementaires propres à ces environnements.

Dans un contexte où les entreprises migrent massivement vers des solutions cloud soit public, privé ou hybride, cette BU joue un rôle crucial en proposant une approche sur mesure qui combine analyse des risques, sécurité des infrastructures cloud, et mise en conformité avec les normes internationales.

L'objectif de cette BU est clair : permettre aux clients de tirer pleinement parti du cloud sans compromettre la sécurité de leurs actifs numériques.

2.5. Activité de l'entreprise

L'Offre Cyberdéfense de Dataprotect se repose sur les activités suivantes : la sécurité des réseaux, assurée à travers des solutions robustes comme celles de Cisco, Palo Alto ou Fortinet. La continuité des services, soutenue par des partenaires tels qu'Acronis et Veeam. L'intelligence de sécurité, renforcée par des outils comme LogRhythm ou Nozomi pour une détection avancée des menaces. La sécurité des hôtes et des terminaux, déployée grâce à des solutions éprouvées telles que Kaspersky ou FireEye. La sécurité des applications, la sécurité des données, la traçabilité, et enfin la gestion des risques, chacune soutenue par un écosystème technologique pertinent. Cette approche modulaire permet à Dataprotect de répondre aux exigences actuelles

en matière de cybersécurité, tout en s'appuyant sur les meilleures pratiques et partenaires technologiques du marché.

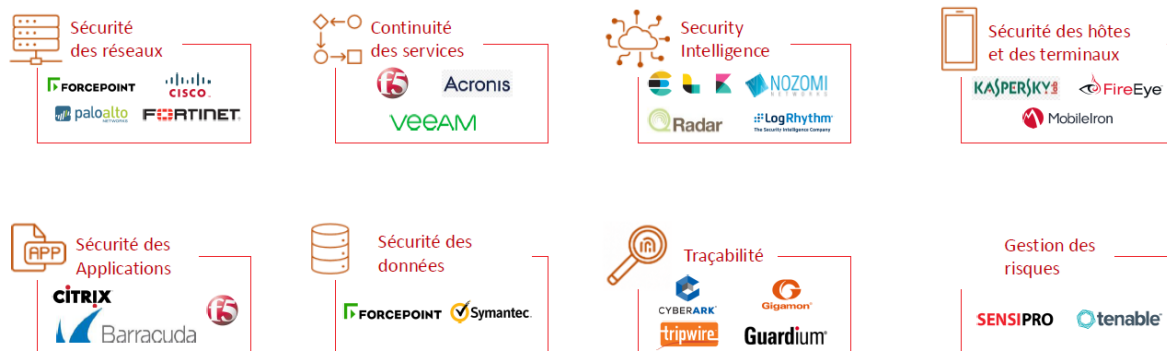


Figure 4: Activité de Dataprotect UNE VISION 360° DE LA CYBERSÉCURITÉ

2.6. Les clients du groupe

Dataprotect accompagne aujourd'hui plus de 450 clients actifs dans une diversité de secteurs, allant des **banques, assurances, télécommunications, à l'énergie, l'industrie, le transport, et la grande distribution.**

Ces clients sont répartis dans plus de 40 pays, ce qui confère à Dataprotect une solide expérience internationale. Parmi les références notables, on compte des grandes banques marocaines comme la BMCE, la Banque Populaire et Bank of Africa, ainsi que de nombreux acteurs du secteur public et des institutions gouvernementales.

Cette diversité de clients et de contextes témoigne de la capacité de Dataprotect à répondre à des besoins variés et complexes, avec un haut niveau de qualité et d'adaptabilité.

3. Contexte du projet

3.1. Contexte général

Dans un contexte mondial où la digitalisation s'accélère, les entreprises migrent progressivement vers des environnements cloud afin de bénéficier de l'élasticité, de la haute disponibilité, et de l'optimisation des coûts qu'offrent ces technologies. Cette transition s'inscrit également dans un changement de paradigme financier, passant d'un modèle CapEx (investissement en capital) à un modèle OpEx (dépenses opérationnelles), plus souple et prévisible.

Cependant, cette adoption massive du cloud expose les systèmes d'information à de nouvelles menaces. La surface d'attaque s'élargit, les environnements sont hybrides ou multi-cloud, les utilisateurs accèdent aux ressources depuis n'importe où, souvent via des appareils personnels.

Dans ce contexte, les mécanismes de sécurité traditionnels, basés sur la confiance implicite accordée au périmètre réseau, ne sont plus suffisants.

Le modèle Zero Trust, défini par la norme NIST SP 800-207, s'impose désormais comme la réponse incontournable à ces défis. Il repose sur trois principes clés : ne jamais faire confiance implicitement, toujours vérifier, et appliquer un contrôle d'accès granulaire et dynamique. C'est dans cette logique que s'inscrit ce projet de fin d'études, qui vise à concevoir et déployer une architecture de sécurité 100 % cloud, fondée sur les modèles de déploiement du Zero Trust tels que EIG, SASE et SDP.

Pour ce faire, le projet s'appuie sur Microsoft Azure, une plateforme cloud leader reconnue pour ses capacités en matière de sécurité, de conformité et d'automatisation. L'environnement mis en place intègre également Prisma Access de Palo Alto Networks, notamment pour la protection des accès distants et la prévention contre la perte de données (DLP).

Des outils clés comme Microsoft Sentinel, Defender for Cloud, Microsoft Entra ID, Azure Logic Apps, et Power BI ont été sélectionnés pour assurer respectivement la détection des menaces, la gestion des identités, l'automatisation des réponses aux incidents, et la visualisation des données de sécurité et de coûts.

Enfin, le déploiement de l'infrastructure a été entièrement automatisé via Terraform, garantissant une reproductibilité, une traçabilité, et une scalabilité conformes aux meilleures pratiques DevSecOps, tout en restant dans le périmètre gratuit (free tier).

3.2. Problématique

Nous avons choisi d'adopter l'approche Zero Trust, telle que définie par la norme NIST SP 800-207, afin de répondre à un ensemble de problématiques réelles liées à la sécurité des systèmes d'information modernes. Cette approche repose sur un principe fondamental : aucune entité ne doit être implicitement considérée comme digne de confiance, qu'elle soit interne ou externe au réseau. Chaque accès doit être validé, contrôlé et réévalué dynamiquement selon le contexte.

La problématique centrale réside dans la complexité croissante de sécuriser un environnement composé de multiples couches technologiques et de points d'accès distribués, notamment dans un contexte où l'on héberge à la fois des applications internes et des services exposés en ligne.

Dans ce cadre, plusieurs défis critiques émergent :

Absence de périmètre clair : Dans les architectures cloud, les utilisateurs, services et applications ne sont plus confinés à un réseau local. Cela rend les modèles de sécurité traditionnels (basés sur des firewalls statiques ou la segmentation réseau simple) obsolètes. La visibilité sur les flux devient difficile, et la notion de "confiance réseau" perd tout son sens.

Multiplicité des identités et des points d'entrée : Les ressources sont accessibles depuis différents terminaux, lieux, et identités, ce qui rend complexe l'application de politiques cohérentes. Sans gouvernance centralisée, il devient quasi impossible de maîtriser les droits, les autorisations temporaires, ou les comptes dormants à risque.

Manque de contrôle dynamique sur les accès : Dans une logique Zero Trust, chaque requête d'accès doit être évaluée en fonction de multiples critères (localisation, heure, niveau de risque, posture du terminal, rôle de l'utilisateur, sensibilité de la ressource...). Or, la plupart des entreprises ne disposent pas des mécanismes nécessaires pour faire ce type d'analyse contextuelle en temps réel.

Supervision fragmentée et détection tardive des attaques : Les journaux d'activité, s'ils ne sont pas collectés et corrélés dans un espace centralisé, deviennent inefficaces pour détecter les mouvements latéraux, les élévations de privilèges, ou les comportements anormaux. Sans plateforme de supervision intégrée, la réponse aux incidents reste manuelle, lente, et non scalable.

Silos technologiques : L'absence d'interopérabilité entre solutions de sécurité empêche d'automatiser la réponse ou de déclencher des actions en chaîne (ex : blocage automatique d'un compte après détection d'un comportement anormal). Les solutions existantes agissent souvent de façon isolée, sans logique d'orchestration.

Problèmes de conformité et de traçabilité : Pour respecter les exigences réglementaires (RGPD, ISO 27001, etc.), il est nécessaire de garantir une traçabilité complète des accès et des modifications. Cela suppose une centralisation des logs, une surveillance permanente, et une documentation claire des politiques appliquées.

Ce projet vise à démontrer comment une architecture Zero Trust basée exclusivement sur des services cloud peut répondre à ces enjeux en intégrant deux modèles clés du NIST :

- **EIG** pour assurer un contrôle strict et granulaire des identités et des droits d'accès, via l'intégration d'Entra ID et l'application de politiques conditionnelles ;
- **SASE** pour établir une sécurité centrée sur l'identité, la posture du périphérique, le contexte, et les politiques dynamiques d'accès, en intégrant notamment Prisma Access pour l'accès ZTNA aux ressources internes.

Grâce à des outils comme Microsoft Sentinel, Defender for Cloud, Entra ID, Power BI, Logic Apps et Terraform, ce projet propose une réponse technique et stratégique à une problématique de sécurité globale, en assurant :

- Une vérification systématique de chaque accès.
- Une supervision continue des événements.
- Une automatisation des réponses.
- Et une gouvernance centralisée de l'ensemble des accès, identités et ressources.

3.3. Objectif du projet

L'objectif principal du projet est de concevoir une infrastructure cloud de démonstration, alignée avec la norme Zero Trust du NIST 800-207, et déployée exclusivement à l'aide d'outils gratuits ou inclus dans les crédits d'essai d'Azure. L'architecture doit refléter les meilleures pratiques en matière de cybersécurité moderne, de supervision continue, et de gouvernance centralisée.

Plus spécifiquement, les objectifs du projet sont :

- Déployer une infrastructure complète sur Microsoft Azure, incluant des machines Windows et Linux, configurées pour simuler des scénarios d'attaque.
- Appliquer les modèles SASE et EIG, à travers l'utilisation d'Entra ID pour la gestion des identités, et Prisma Access pour le contrôle d'accès dynamique.
- Utiliser Microsoft Sentinel pour collecter, corrélérer, et visualiser les logs de sécurité en temps réel.
- Déclencher des automatisations intelligentes à l'aide d'Azure Logic Apps et d'OpenAI, pour générer des résumés lisibles d'incidents.
- Construire un tableau de bord Power BI à partir de fichiers CSV exportés manuellement (logs, coûts), pour illustrer la visibilité stratégique.
- Orchestrer l'ensemble du déploiement via Terraform, en garantissant la cohérence, la reproductibilité et l'efficacité.

Ce projet a donc une double vocation : technique, en mettant en œuvre des solutions opérationnelles et intégrées ; et pédagogique, en illustrant la faisabilité d'une architecture Zero Trust même en environnement académique ou à ressources limitées.

3.4.État de l'art des menaces et de la sécurité cloud

L'évolution rapide des technologies numériques, combinée à la migration massive vers le cloud, a profondément modifié le paysage des menaces en cybersécurité. Les infrastructures cloud, bien que robustes, introduisent de nouvelles vulnérabilités liées à la gestion des identités, à la configuration des services, et à la connectivité mondiale qu'elles offrent. Les attaquants exploitent désormais ces surfaces d'exposition étendues pour mener des campagnes sophistiquées de type ransomware, exfiltration de données ou compromission de comptes à privilèges.

Selon le Verizon Data Breach Investigations Report (DBIR) de 2024, plus de 70 % des violations de données analysées impliquent des environnements cloud. De plus, le volume des attaques par force brute ciblant les machines virtuelles dans le cloud a augmenté de 95 % en un an, notamment à cause de l'exposition publique des ports comme RDP ou SSH. D'après le rapport ENISA Threat Landscape 2024, les erreurs de configuration cloud sont parmi les 3 principales causes d'incidents majeurs.

Cette réalité démontre que l'adoption du cloud doit impérativement s'accompagner de mécanismes de sécurité renforcés, adaptés à ces nouveaux paradigmes. Il ne s'agit plus seulement de protéger un périmètre réseau fermé, mais d'assurer une sécurité dynamique, continue et contextuelle, capable de suivre l'utilisateur, le terminal et les ressources où qu'ils soient.

3.5. Enjeux de l'approche Zero Trust dans un contexte cloud

La sécurité traditionnelle, dite « périmétrique », repose sur une distinction claire entre l'intérieur (de confiance) et l'extérieur (non fiable) du réseau de l'entreprise. Une fois un utilisateur ou un appareil à l'intérieur du périmètre, il bénéficie souvent d'un accès étendu, ce qui ouvre la voie à des mouvements latéraux en cas de compromission.

Face à cela, l'approche **Zero Trust**, théorisée dans le standard **NIST SP 800-207**, bouleverse cette logique en partant du principe que rien ni personne ne doit être implicitement digne de confiance, même à l'intérieur du réseau. Chaque requête d'accès à une ressource est évaluée en temps réel, selon le contexte, l'identité, l'état du terminal, l'emplacement, et d'autres signaux.

Dans un environnement cloud, l'enjeu principal est la gouvernance identitaire, car l'identité devient le nouveau périmètre. Les outils tels que Microsoft Entra ID permettent de renforcer cette gouvernance via l'authentification unique (SSO), la segmentation des rôles (RBAC) et la surveillance des accès.

Un autre pilier essentiel est la visibilité en temps réel. Grâce à Microsoft Sentinel, couplé à Defender for Cloud, il est possible de centraliser, corréler et visualiser les journaux d'activités de toutes les ressources cloud et machines virtuelles. Cette surveillance permet non seulement la détection d'incidents, mais aussi leur automatisation via des outils comme Logic Apps, garantissant une réaction rapide et documentée.

En résumé, l'approche Zero Trust offre une sécurité continue, granulaire, et résiliente, une nécessité stratégique dans un monde numérique décentralisé et en perpétuel mouvement.

Tableau 1: Tableau comparatif entre la sécurité traditionnelle périmétrique et l'approche moderne Zero Trust

Aspect	Sécurité Périmétrique	Approche Zero Trust
Principe de base	Confiance implicite à l'intérieur du périmètre réseau	Aucune confiance par défaut, vérification systématique
Délimitation du périmètre	Physique ou réseau (pare-feux, VPN)	Identité et contexte deviennent le nouveau périmètre
Contrôle d'accès	Contrôle initial à l'entrée, peu granulaire en interne	Accès basé sur l'identité, le rôle (RBAC), l'état du terminal et l'emplacement, évalué à chaque requête
Gestion des identités	Peu centralisée, souvent cloisonnée	Centralisée avec Microsoft Entra ID (SSO, RBAC, MFA, surveillance)

Mouvements latéraux	Possibles si un acteur malveillant entre dans le réseau	Fortement limités grâce à la micro-segmentation et l'accès just-in-time
Surveillance	Ponctuelle, souvent réactive	Continue, en temps réel avec Microsoft Sentinel + Defender for Cloud
Réponse aux incidents	Réactive, manuelle	Automatisée via des outils comme Logic Apps et playbooks (SOAR)
Adaptabilité au cloud	Limitée, pensée pour un environnement on-prem	Native pour le cloud hybride et les environnements multicloud
Résilience & agilité	Peu flexible face aux menaces modernes	Adaptative, granulaire, conçue pour un monde numérique en constante évolution

3.6. Diagramme de GANTT

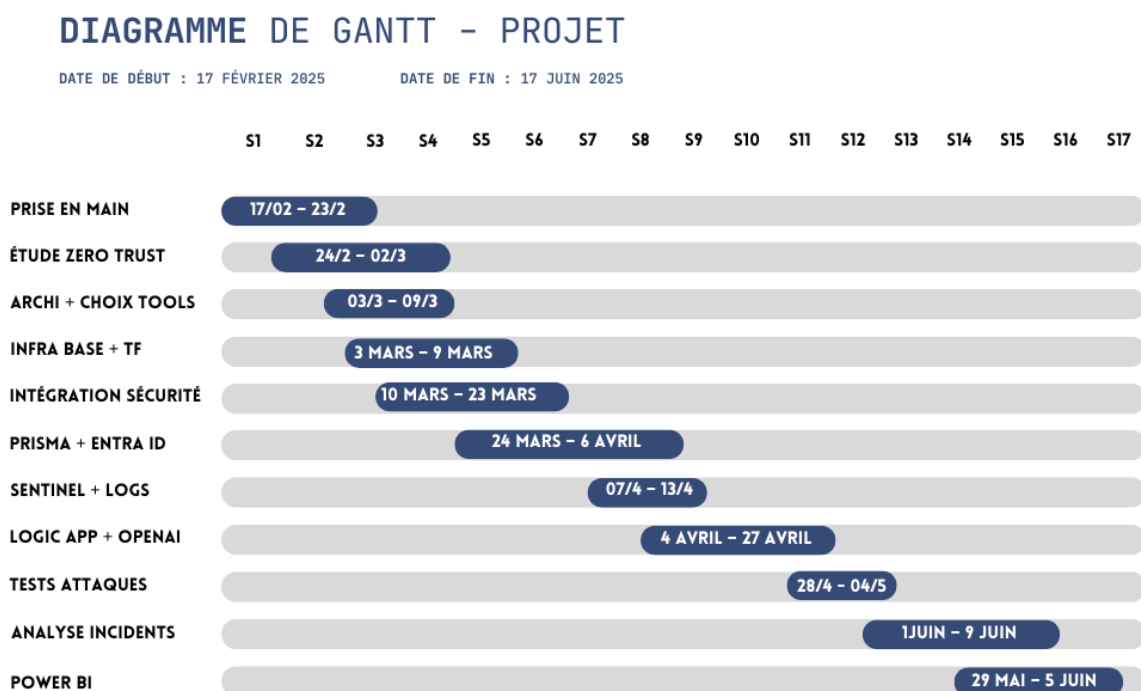


Figure 5: Diagramme de Gantt

Il est indéniable que la planification d'un projet est une étape cruciale pour une conception fluide. Grâce à elle on arrive à organiser, structurer les tâches et les accomplir d'une manière efficace afin d'atteindre les objectifs fixés. Cela implique un tas d'aspects essentiels comme définir clairement les différentes activités sans oublier l'estimation des ressources nécessaires en termes de compétences. Tout cela en établissant un calendrier qui sert à suivre l'avancement du projet, et anticiper les risques éventuels en élaborant des solutions pour les gérer.

C'est pour cela qu'on utilisera le diagramme de Gantt qui offre une vision claire des étapes à franchir pour mener à bien le projet. Il sert de repère pour suivre l'évolution des tâches et ajuster la planification en fonction des besoins.

4. Conclusion

Après avoir présenté l'organisme d'accueil en décrivant sa structure et ses différentes missions, on a présenté le cadrage du projet, puis on a relevé le besoin et explicité la problématique à laquelle on doit répondre et fixer nos objectifs. Dans le chapitre suivant, On passera à la définition des besoins spécifiques et fonctionnels et présentera l'étude de l'existant et l'étude de cas d'utilisation.

Chapitre II : Etude et analyse du projet

1. Introduction

Dans ce chapitre, nous allons examiner des notions importantes dans notre projet, telles que le modèle Zero Trust, la norme NIST 800-207 qui intègre les principes EIG et SASE. L'enjeu est de garantir une gouvernance fine des identités et un contrôle d'accès dynamique sur des ressources Microsoft Azure. Nous intégrerons également Prisma Access, qui applique les principes Zero Trust pour sécuriser les accès distants aux applications, tout en assurant une inspection continue du trafic et une gestion centralisée des politiques.

2. Analyse et critique de l'existant

Dans le contexte d'un système d'information traditionnel, l'approche de sécurité repose souvent sur une confiance implicite accordée à tout ce qui est situé à l'intérieur du périmètre réseau de l'entreprise. Ce modèle périmétrique, bien qu'efficace dans des infrastructures fermées, montre aujourd'hui ses limites face à la généralisation du travail à distance, à la montée des cyberattaques, et à la complexité croissante des environnements cloud.

Lors de l'analyse de l'environnement initial avant la mise en œuvre du projet, plusieurs limites ont été identifiées :

- **Absence de surveillance centralisée** : Aucun système de collecte unifiée des journaux n'était mis en place, rendant difficile la détection d'activités suspectes ou la corrélation des événements de sécurité.
- **Manque de visibilité sur les coûts** : L'exploitation du cloud, même dans des environnements de test, génère rapidement des coûts non maîtrisés. Sans outils de suivi ou d'alerte, ces dépenses peuvent devenir imprévisibles.
- **Accès réseau trop permissif** : Les connexions entre utilisateurs et ressources internes n'étaient pas filtrées de manière granulaire, exposant l'ensemble du réseau à des risques de latéralisation en cas de compromission.
- **Pas de gouvernance des identités** : Les utilisateurs pouvaient accéder aux ressources sans restrictions contextuelles ni journalisation claire de leurs activités.
- **Pas d'accès sécurisé aux applications internes** : L'accès aux applications hébergées sur des machines internes devait passer par un VPN traditionnel ou une ouverture directe de ports des solutions peu flexibles et potentiellement risquées.

Ces constats ont motivé la mise en place d'une nouvelle architecture centrée sur les principes de Zero Trust, intégrant des outils cloud modernes tels qu'Azure, Prisma Access et Terraform, tout en respectant les contraintes de gratuité ou de crédits limités.

3. Spécification des besoins

3.1. Notions clés

Avant de concevoir l'architecture et sécurisée de ce projet, il est essentiel de comprendre les grands concepts qui en constituent les fondations. Ces notions guident les choix techniques, les mécanismes de sécurité, ainsi que la logique d'optimisation des coûts.

Le **NIST SP 800-207** définit l'architecture Zero Trust comme un cadre de cybersécurité qui élimine la confiance implicite dans les systèmes et utilisateurs. Elle repose sur l'idée que la sécurité ne doit pas être basée sur des périmètres réseau classiques, mais sur une vérification continue de l'identité et des accès. Cette approche exige une authentification et une autorisation dynamiques avant d'accorder l'accès aux ressources numériques, réduisant ainsi le risque de compromission. [1]

Le **ZTNA** est un modèle de sécurité qui restreint l'accès aux applications et aux services en fonction du principe du moindre privilège. Contrairement aux VPN classiques qui donnent un accès global au réseau interne, le ZTNA agit comme une passerelle sécurisée, ne permettant aux utilisateurs d'interagir qu'avec les ressources spécifiques auxquelles ils sont autorisés. Cette solution repose sur une évaluation dynamique des risques et permet un meilleur contrôle de la surface d'attaque. [2]

Le **SASE** combine les fonctionnalités de sécurité réseau et d'accès cloud en une seule solution. Il intègre des technologies comme le ZTNA, les CASB (Cloud Access Security Brokers) et les SD-WAN, permettant une connectivité sécurisée et flexible. [3]

L'**EIG** est une approche de gestion des identités qui assure un contrôle strict des accès aux ressources numériques. Elle est essentielle pour la mise en œuvre d'une Zero Trust Architecture, garantissant que seuls les utilisateurs autorisés peuvent interagir avec les systèmes. [4]

Le **FinOps** est une méthodologie qui vise à optimiser la gestion financière des infrastructures cloud. Plutôt que de voir le cloud uniquement comme une dépense, il encourage les entreprises à aligner leur consommation avec leurs objectifs stratégiques. Grâce à des pratiques comme le monitoring des coûts en temps réel, la planification budgétaire et l'allocation des ressources sur demande, les équipes FinOps assurent une meilleure rentabilité tout en maintenant des performances élevées. [5]

La **microsegmentation** consiste à diviser finement l'environnement réseau en zones de sécurité distinctes. Chaque zone a ses propres règles d'accès. Ce découpage empêche qu'un acteur malveillant puisse se déplacer latéralement dans le système après une compromission. Le trafic entre les segments est contrôlé, surveillé et limité aux interactions strictement nécessaires.

Validation continue : Dans une architecture Zero Trust, chaque tentative d'accès est soumise à une vérification dynamique. Il ne s'agit pas seulement d'authentifier une fois le système analyse en continu les identifiants, l'état de l'appareil, l'heure, le lieu et même le comportement de l'utilisateur. Les décisions d'accès se basent sur des signaux contextuels et sont ajustées en temps réel pour assurer une sécurité maximale.

Le **principe du moindre privilège** impose que chaque utilisateur, service ou application ne possède que les droits nécessaires à l'exécution de ses tâches. Cette restriction réduit drastiquement les surfaces d'attaque. La gestion granulaire des rôles, l'assignation contrôlée des permissions et la supervision régulière des droits permettent de maintenir un environnement rigoureux et adaptable.

L'**SDP** remplace les mécanismes traditionnels comme les VPN. Il crée un périmètre dynamique et invisible qui ne révèle les ressources qu'aux entités autorisées. L'accès est conditionné à une identification préalable, souvent renforcée par des techniques comme l'authentification à double facteur ou l'évaluation du contexte. Cela empêche les scans de ports et les tentatives d'intrusion passives.

Terraform et Infrastructure as Code :

L'Infrastructure as Code, et plus particulièrement Terraform, joue un rôle fondamental dans la construction d'un environnement Zero Trust.

- Elle permet une automatisation complète du déploiement, de la configuration et de la sécurisation des ressources, ce qui garantit leur cohérence.
- L'infrastructure devient déclarative, ce qui facilite la compréhension du système cible et réduit les erreurs humaines.
- L'audit est simplifié : le code devient une source unique de vérité et les configurations peuvent être vérifiées, versionnées et restaurées en cas de besoin.
- Les stratégies de sécurité, comme l'application du moindre privilège, le chiffrement, ou la mise en place de règles de réseau, peuvent être codifiées et vérifiées automatiquement.
- Dans une optique FinOps, les ressources peuvent être balisées et optimisées dès leur création, ce qui réduit les coûts et évite le gaspillage.

3.2. Besoins fonctionnels

Les besoins fonctionnels définissent les fonctionnalités attendues du système à mettre en œuvre. Ils expriment ce que la solution doit réaliser du point de vue des utilisateurs, des administrateurs et des systèmes interconnectés. Dans le cadre de ce projet, les besoins fonctionnels sont directement liés aux exigences d'une architecture Zero Trust, d'une gouvernance centralisée des identités EIG, et d'un accès sécurisé aux ressources via des principes SASE/ZTNA.

• Gestion des identités et des accès

Utilisation d'Entra ID pour enregistrer les utilisateurs, gérer leurs rôles et contrôler leur accès aux ressources. Des politiques basiques d'accès ont été appliquées selon l'adresse IP ou la provenance des connexions.

• Segmentation du réseau et contrôle d'accès aux applications

Les ressources critiques ont été isolées via des NSG (Network Security Groups) et des règles de pare-feu Azure. L'accès aux applications internes a été restreint via Prisma Access et des règles contextuelles.

- **Supervision centralisée et détection des menaces**

Microsoft Sentinel a été configuré pour collecter les journaux depuis les machines virtuelles (Windows et Linux), détecter les anomalies et visualiser les attaques via des cartes géographiques enrichies par des watchlists.

- **Déploiement automatisé de l'infrastructure**

Terraform a été utilisé pour automatiser la création des machines virtuelles, des ressources réseau, et la configuration initiale, garantissant ainsi la reproductibilité et la rapidité de déploiement.

- **Reporting et traçabilité**

Les données collectées ont été exportées sous forme de fichiers CSV (logs, coûts) et analysées manuellement via Power BI pour générer des rapports personnalisés, incluant une cartographie des attaques et un suivi des coûts.

3.3. Besoins non fonctionnels

Les besoins non fonctionnels définissent les critères de performance, de sécurité, de conformité et d'exploitation qui doivent être respectés par la solution, indépendamment des fonctions métier spécifiques. Ils sont essentiels pour garantir la fiabilité, la scalabilité et la pérennité de l'architecture mise en œuvre.

- **Disponibilité**

Même sans Azure Stack HCI, l'architecture déployée dans le cloud Azure public a été pensée pour garantir un minimum de continuité de service en cas de redémarrage ou maintenance des VM.

- **Sécurité**

Le modèle Zero Trust est appliqué à travers la limitation des privilèges, la surveillance constante, la centralisation des logs et la configuration de règles NSG minimales.

- **Conformité**

Le projet prend en compte les recommandations du NIST SP 800-207 et les principes de la loi marocaine 09-08 sur la protection des données.

- **Interopérabilité**

Prisma Access a été intégré avec Azure et les machines virtuelles Linux/Windows pour illustrer la faisabilité d'un accès sécurisé à des applications internes sans VPN classique.

- **Résilience et sauvegarde**

Les configurations critiques sont stockées dans Terraform pour permettre un redéploiement rapide. Des scripts de sauvegarde manuelle sont également prévus.

- **Maîtrise des coûts « FinOps »**

L'usage exclusif d'outils gratuits ou de crédits limite les coûts. Le tableau de bord Power BI permet une surveillance manuelle et granulaire de l'évolution des dépenses.

- **Temps de réponse et performance**

L'architecture reste simple, mais les services essentiels (VM, Sentinel, Prisma Access) ont été testés pour garantir un temps de réponse acceptable dans un contexte de simulation d'attaques.

4. Étude des choix techniques

La mise en œuvre d'une architecture Zero Trust sur Microsoft Azure, combinée à des outils tels que Prisma Access et Microsoft Defender, repose sur des choix technologiques stratégiques, à la croisée des contraintes budgétaires et des objectifs de sécurité, d'automatisation et de gouvernance. Dans ce contexte, chaque outil intégré a été rigoureusement sélectionné selon des critères précis : compatibilité native avec l'écosystème Azure, simplicité de déploiement, capacité à répondre efficacement aux incidents, et richesse fonctionnelle en matière de visualisation, de corrélation et d'analyse des événements de sécurité.

Cette démarche vise à démontrer qu'il est possible, même dans un cadre académique ou à ressources limitées, de construire une architecture Zero Trust cohérente, modulaire et opérationnelle.

L'analyse suivante propose une comparaison structurée de plusieurs outils reconnus pour chaque domaine fonctionnel de l'architecture, avec une justification claire des choix retenus dans le cadre de ce projet étudiant.

4.1. Choix du Cloud Provider

Dans un contexte où la sécurité cloud est au cœur des préoccupations, Microsoft Azure se distingue par une approche intégrée, cohérente et profondément alignée avec les principes Zero Trust. Contrairement à AWS et GCP, Azure propose une suite complète de services de sécurité nativement connectés, ce qui facilite la mise en œuvre de stratégies robustes sans dépendre d'outils tiers.

Parmi ses atouts majeurs :

- **Microsoft Defender for Cloud** : protection unifiée contre les menaces sur les workloads, avec recommandations de durcissement.
- **Azure AD** : gestion des identités avancée, MFA, Conditional Access, intégration fluide avec les politiques Zero Trust.
- **Sentinel** : SIEM/SOAR cloud natif, automatisation des réponses, corrélation intelligente des alertes.
- **Key Vault** : gestion sécurisée des secrets, certificats et clés de chiffrement.

- **Compliance & certifications** : Azure couvre plus de 100 certifications internationales, dont ISO 27001, SOC, GDPR, HIPAA.

Tableau 2: Tableau comparatif entre différents Cloud Providers

Critère			 Google Cloud Platform
SIEM / SOAR natif	Sentinel intégré, Logic Apps, playbooks automatisés	AWS Security Hub + Lambda	Stackdriver + Chronicle (moins mature)
Gestion des identités	Azure AD, Conditional Access, MFA, RBAC avancé	IAM + Cognito, MFA disponible	IAM + Identity-Aware Proxy
Protection des workloads	Defender for Cloud, intégration avec Sentinel	GuardDuty, Inspector	Security Command Center
Gestion des secrets	Key Vault (certificats, clés, secrets)	Secrets Manager (secrets uniquement)	Secret Manager (similaire à AWS)
Zero Trust	Modèle complet intégré (microsegmentation, validation continue, moindre privilège)	Partiellement intégré, dépend de services séparés	Approche modulaire, moins centralisée
Conformité & certifications	+100 certifications, forte adoption entreprise	Large couverture, mais moins intégrée	Bonne conformité, mais moins répandue en entreprise
Intégration avec outils Microsoft	Native (Defender, Intune, M365, Purview)	Possible mais via connecteurs tiers	Faible, nécessite adaptation

Azure est le choix stratégique pour une architecture cloud sécurisée, surtout si l'on vise une mise en œuvre fluide du Zero Trust, une automatisation des réponses aux incidents, et une visibilité centralisée. Sa maturité en matière de sécurité, son intégration native avec les outils Microsoft, et ses capacités SOAR avancées en font une plateforme idéale pour les environnements exigeants.

4.2. Choix d'outil d'automatisation

Dans le cadre de notre projet, le choix de Terraform s'est imposé comme une solution stratégique pour le déploiement et la gestion de l'infrastructure cloud. Bien que Bicep soit un langage natif à Azure, conçu pour simplifier la création de ressources via des modèles ARM, Terraform offre une portabilité, une maturité et une flexibilité supérieures, particulièrement adaptées aux environnements complexes ou évolutifs.

L'un des critères majeurs ayant orienté notre décision est la compatibilité multi-cloud de Terraform. Contrairement à Bicep, qui est exclusivement lié à Azure, Terraform permet de gérer des ressources sur Azure, AWS, GCP, VMware, Kubernetes, et bien d'autres plateformes via un système de *providers*. Cette capacité est essentielle dans une optique d'interopérabilité et de réversibilité, notamment si l'organisation envisage une stratégie hybride ou multi-cloud à moyen terme.

De plus, Terraform bénéficie d'une communauté open source très active, d'une documentation exhaustive, et d'un écosystème riche en modules réutilisables. Sa gestion d'état (.tfstate) permet un suivi précis des ressources déployées, une planification des changements (terraform plan) et une traçabilité complète des opérations. Cette approche renforce la gouvernance, la sécurité et la conformité, tout en facilitant les audits et les contrôles internes.

Tableau 3: Tableau comparatif entre Terraform et Bicep

Critère		
Type d'outil	IaC multi-cloud, développé par HashiCorp	DSL Azure natif, développé par Microsoft
Langage utilisé	HCL (HashiCorp Configuration Language), déclaratif	Syntaxe déclarative simplifiée, transpile en ARM templates
Compatibilité cloud	Azure, AWS, GCP, VMware, etc.	Exclusivement Azure
Gestion d'état	Fichier .tfstate versionnable, traçabilité complète	Pas de fichier d'état, suivi géré par Azure Resource Manager
Modularité	Modules réutilisables, logique DRY	Modules intégrés, mais moins flexibles que Terraform
Sécurité	Intégration avec Key Vault, RBAC, gestion des variables sensibles	Intégration native avec Azure RBAC, Key Vault, et politiques Azure
Automatisation	Déploiement, mise à jour, suppression via commandes locales (apply, destroy)	Déploiement direct via Azure CLI ou PowerShell
Courbe d'apprentissage	Moyenne à élevée, nécessite compréhension du state et des providers	Faible à moyenne, syntaxe intuitive et intégrée à l'écosystème Azure

Communauté & support	Large communauté open source, nombreux modules et providers	Communauté croissante, support officiel Microsoft
Cas d'usage idéal	Environnements hybrides ou multi-cloud, gouvernance avancée	Déploiements Azure natifs, simplicité et rapidité de mise en œuvre

L'adoption de Terraform dans notre projet repose sur une vision à long terme de l'infrastructure cloud : flexible, sécurisée, automatisée et interopérable. Sa capacité à s'adapter à différents fournisseurs, à intégrer des politiques de sécurité dès le niveau du code, et à offrir une traçabilité complète des opérations en fait un outil central dans notre stratégie. En favorisant Terraform, nous nous assurons de disposer d'une solution scalable, standardisée, et alignée avec les exigences modernes de gouvernance et de cybersécurité, tout en gardant la porte ouverte à une évolution vers des environnements multi-cloud.

4.3. Choix du SIEM

Dans un environnement fortement ancré dans Azure, l'intégration naturelle entre les services cloud et les outils de sécurité devient un facteur clé de cohérence, d'efficacité et de rapidité d'action. Microsoft Sentinel s'impose comme une solution de choix grâce à sa capacité à corréler les données issues de Microsoft Defender, Azure AD, Prisma Access, et même Terraform. Il permet de combiner visibilité centralisée, automatisation des réponses, et conformité aux principes Zero Trust sans ajout complexe d'interfaces externes.

Tableau 4: Tableau comparatif SIEM / SOAR

Critère	 Microsoft Sentinel	 splunk	 wazuh.
Type	Cloud natif SIEM + SOAR	SIEM avec SOAR (via module dédié)	SIEM open source
Déploiement	100 % cloud (Azure)	Cloud, hybride ou on-prem	Principalement on-prem
SOAR intégré	Playbooks via Logic Apps	Workflows personnalisables mais complexes	Scripts manuels, peu d'orchestration native
Intégration Zero Trust	Native avec Azure AD, Defender, Terraform	Flexible mais nécessite configuration poussée	Faible, nécessite ajout de modules externes

Coût	Paiement à l'usage, optimisable	Licence élevée	Gratuit, maintenance technique requise
Usage idéal	Azure, automatisation, sécurité cloud	Personnalisation avancée, gros volumes	PME avec expertise technique

En s'appuyant sur Sentinel, nous obtenons une plateforme unifiée qui soutient nos objectifs de sécurité proactive : alertes enrichies par l'intelligence Microsoft, automatisation des traitements grâce aux Logic Apps, création de playbooks SOAR adaptés aux scénarios de Zero Trust. Cette orientation réduit la complexité opérationnelle, limite les coûts liés à la gestion multi-outils, et renforce notre capacité de réponse en cas d'incidents. C'est une architecture alignée avec notre vision stratégique de la sécurité cloud moderne.

4.4. Outils SASE

Dans le cadre de ce projet, il était essentiel de garantir un accès sécurisé aux ressources, y compris celles hébergées sur des VM exposées. Le modèle SASE a été implémenté à travers l'intégration de Prisma Access et Microsoft Defender for Cloud Apps, assurant un contrôle du trafic, une inspection des connexions et une protection contre les fuites de données.

Tableau 5: Outils SASE

Critère d'évaluation	 PRISMA	 Microsoft Defender for Cloud Apps
Intégration avec Microsoft Azure	Moyenne	Élevée
Détection du Shadow IT	Pris en charge	Pris en charge
Inspection du trafic (ZTNA/HTTP)	Oui	Partielle
Protection contre les menaces SaaS	Oui	Oui
Intégration avec Microsoft Sentinel	Partielle	Native

Prisma Access a été utilisé pour créer un tunnel ZTNA vers une application privée (DVWA), tandis que Defender for Cloud Apps a permis une surveillance des accès SaaS. Bien qu'ils ne soient pas 100 % intégrés entre eux, leur complémentarité a renforcé la posture de sécurité globale, notamment dans le cadre du contrôle des accès hors périmètre.

Le choix de Prisma Access s’est imposé naturellement dans notre stratégie de sécurité cloud, notamment pour sa capacité à offrir une protection étendue et cohérente aux utilisateurs distants, aux réseaux hybrides et aux applications sensibles. En tant que solution SASE (Secure Access Service Edge), Prisma Access combine des fonctions de pare-feu, de filtrage web, de ZTNA (Zero Trust Network Access) et d’inspection du trafic dans une plateforme cloud unifiée.

Un des éléments déterminants dans cette décision fut la disponibilité préalable de la licence Prisma Access au sein de l’entreprise. Cette licence permettait déjà d’accéder aux fonctionnalités clés du service, notamment :

- La gestion centralisée des politiques de sécurité.
- L’intégration avec les outils existants comme Azure AD et Defender for Cloud.
- La visibilité complète sur les menaces et les flux réseau via le Strata Logging Service.

Disposer de cette licence a permis de réduire les coûts d’implémentation, d’accélérer le déploiement et de rentabiliser les investissements déjà réalisés. Cela a également facilité l’adoption du modèle Zero Trust, en s’appuyant sur une solution déjà maîtrisée par les équipes internes.

4.5. Outils EIG

Une gouvernance efficace des identités est essentielle dans une démarche Zero Trust. Elle garantit que chaque utilisateur accède uniquement aux ressources dont il a réellement besoin, selon son rôle, son contexte, et son niveau de privilège. L’évaluation porte ici sur les solutions les plus couramment déployées pour gérer le cycle de vie des identités dans des environnements cloud.

Tableau 6: Outils EIG

Critère d’évaluation	Okta Governance	SailPoint IdentityIQ	Microsoft Entra ID	CyberArk Identity
Intégration avec Azure et Office 365	Moyenne	Faible	Native	Faible
Cycle de vie automatisé des identités	Limité	Partiel	Complet	Limité
Prise en charge des identités externes (B2B)	Restreinte	Modérée	Complète	Inexistante

Microsoft Entra ID – Identity Governance se distingue par son alignement natif avec Azure Active Directory, offrant une gouvernance fluide des identités internes et externes. Les fonctionnalités avancées de revue d’accès, de privilèges temporaires (PIM), et de certification

font de cette solution un pilier central dans l'implémentation d'une stratégie Zero Trust à l'échelle organisationnelle.

4.6. Outils PA

Le Policy Administrator (PA) est chargé de la configuration, de la gestion et de la distribution des règles de sécurité au sein de l'architecture Zero Trust. Il représente l'interface de gouvernance à travers laquelle les politiques sont définies, diffusées et ajustées en fonction du contexte opérationnel ou des signaux de sécurité. Dans le cadre de ce projet, les rôles de PA ont été incarnés par Azure Entra ID, Azure RBAC, et Prisma Access Console, permettant une définition centralisée des droits d'accès, des groupes, et des configurations ZTNA pour les applications privées.

Tableau 7: Outils PA (Policy Administrator)

Critère d'évaluation	Entra ID + RBAC + Prisma Console
Définition des politiques d'accès	Oui (Groupes, Rôles, RBAC)
Intégration avec les applications SaaS et SAML	Oui (via Entra ID Enterprise Apps)
Interface de gestion centralisée	Oui (Azure Portal + Prisma UI)
Création et gestion d'utilisateurs/tests	Oui
Attribution dynamique de permissions	Partiel (RBAC manuel)
Visibilité sur les affectations	Oui
Flexibilité et évolutivité	Haute (Cloud-native, extensible)

L'utilisation combinée d'Entra ID pour l'identité fédérée, de la console Prisma Access pour la configuration des accès privés et ZTNA, et du modèle RBAC pour une gouvernance fine des ressources Azure, a permis de matérialiser un Policy Administrator fonctionnel et opérationnel. Ce triptyque assure un contrôle unifié, cohérent et extensible des règles de sécurité, en phase avec les exigences du NIST 800-207 et les bonnes pratiques du Zero Trust.

4.7. Outils PEP

Les PEP appliquent les politiques de sécurité définies par le système. Dans le projet, ils ont été réalisés par une combinaison de NSG, Defender for Cloud, et Prisma ZTNA Connector, permettant un contrôle granulaire des flux réseau et des connexions entrantes vers les Vms.

Tableau 8: Outils PEP

Critère d'évaluation	NSG + Defender + Prisma ZTNA
----------------------	------------------------------

Blocage des ports non autorisés	Oui
Inspection du comportement et alertes	Oui (via Defender)
Accès sans exposition IP	Oui (Prisma ZTNA)
Envoi des logs vers SIEM	Oui (via Sentinel)
Contrôle basé sur contexte	Oui

La combinaison des NSG pour la segmentation réseau, de Microsoft Defender for Cloud pour la sécurisation des charges de travail, et de Prisma Access pour l'application du modèle ZTNA, a permis de concrétiser les Policy Enforcement Points PEP dans un environnement cloud. Cette approche intégrée renforce une posture de sécurité unifiée, adaptative et centralisée, assurant une inspection continue du trafic et une application cohérente des politiques, en ligne avec les principes Zero Trust et les exigences de gouvernance moderne.

4.8. Policy Engine PDP

Le moteur de décision centralisé est essentiel pour évaluer les signaux de sécurité, orchestrer les workflows, et déclencher les réponses. Dans ce projet, c'est Microsoft Sentinel qui a joué ce rôle, enrichi par Logic Apps et OpenAI pour générer des résumés automatiques des incidents.

Tableau 9: Policy Engine (PDP)

Critère d'évaluation	Microsoft Sentinel
Intégration native avec Azure Defender	Oui
Automatisation via Logic Apps	Oui (très avancée)
Support de l'analyse comportementale	Oui
Connecteurs prêts à l'emploi	Nombreux
Coût dans le cadre du projet	Crédit étudiant

L'intégration de Microsoft Sentinel avec Logic Apps et OpenAI a permis de centraliser la gestion des incidents et d'automatiser leur analyse de manière intelligente. Cette orchestration renforce la détection, la classification et l'interprétation des événements en temps réel, tout en s'inscrivant dans les principes Zero Trust grâce à une visibilité accrue, une réponse automatisée et une réduction de la charge des équipes SOC.

5. Analyse SWOT des outils du projet Zero Trust

Afin d'évaluer de manière globale les forces et les limites de notre architecture cloud orientée sécurité, nous avons établi une analyse SWOT.

Strengths • Intégration native entre les services Microsoft (Sentinel , Defender, Entra ID, Logic Apps) • Automatisation puissante avec Terraform et Logic Apps • Centralisation de la surveillance (SIEM + SOAR + FinOps) • Déploiement rapide et reproductible (Infrastructure as Code) • Prisma Access offre une vraie solution ZTNA + DLP cloud-ready		Weaknesses • Courbe d'apprentissage élevée pour Terraform, Sentinel KQL, et Prisma • Documentation parfois technique et morcelée • Certains services (Sentinel, Defender) payants au-delà des quotas gratuits • Limitations des offres gratuites (features restreintes ou expirables)
Opportunities • Renforcement des compétences Cloud & SecOps recherchées sur le marché • Possibilité d'extension vers une architecture hybride ou multicloud • Intégration d'IA (OpenAI) pour automatiser l'analyse des incidents • Créer une plateforme complète pour former ou sensibiliser à la sécurité Zero Trust	S W O T	Threats • Mauvaise configuration Terraform ou NSG → faille de sécurité ou coût élevé • Épuisement des crédits Azure avant fin du projet • Exposition réelle des VMs → risque de suspension du compte Azure • Dépendance à des outils propriétaires cloud (Azure lock-in)

Figure 6: Analyse SWOT

L'analyse SWOT réalisée met en lumière les leviers clés que le projet peut mobiliser pour renforcer sa posture sécuritaire tout en assurant une évolutivité maîtrisée. Les forces identifiées, telles que l'intégration native avec Azure et l'automatisation via Terraform et Sentinel, constituent une base solide pour la mise en œuvre du modèle Zero Trust. Toutefois, les faiblesses internes, notamment certaines limitations opérationnelles ou le besoin de montée en compétence sur des outils spécialisés, devront être anticipées afin de ne pas freiner la performance globale. Les opportunités externes, comme l'évolution du paysage réglementaire ou l'adoption croissante de modèles SASE et SOAR, offrent un contexte favorable à l'innovation et à la consolidation du système. Enfin, la présence de menaces liées à l'augmentation des attaques ciblées, ou à la dépendance technologique vis-à-vis d'éditeurs spécifiques, appelle à une veille continue et à une gouvernance renforcée. Cette lecture croisée permet non seulement d'orienter les choix techniques, mais aussi de consolider la maturité stratégique de l'architecture mise en place.

6. Architecture de la solution

Cette section présente une vue d'ensemble de l'infrastructure mise en place dans le cadre de la mise en œuvre d'une architecture Zero Trust selon les recommandations de la norme NIST 800-207. L'approche adoptée repose sur une combinaison d'outils cloud, de services de sécurité managés, et de composants de virtualisation, le tout orchestré par des technologies d'automatisation (IaC) et enrichi par des solutions d'analyse et d'intelligence artificielle.

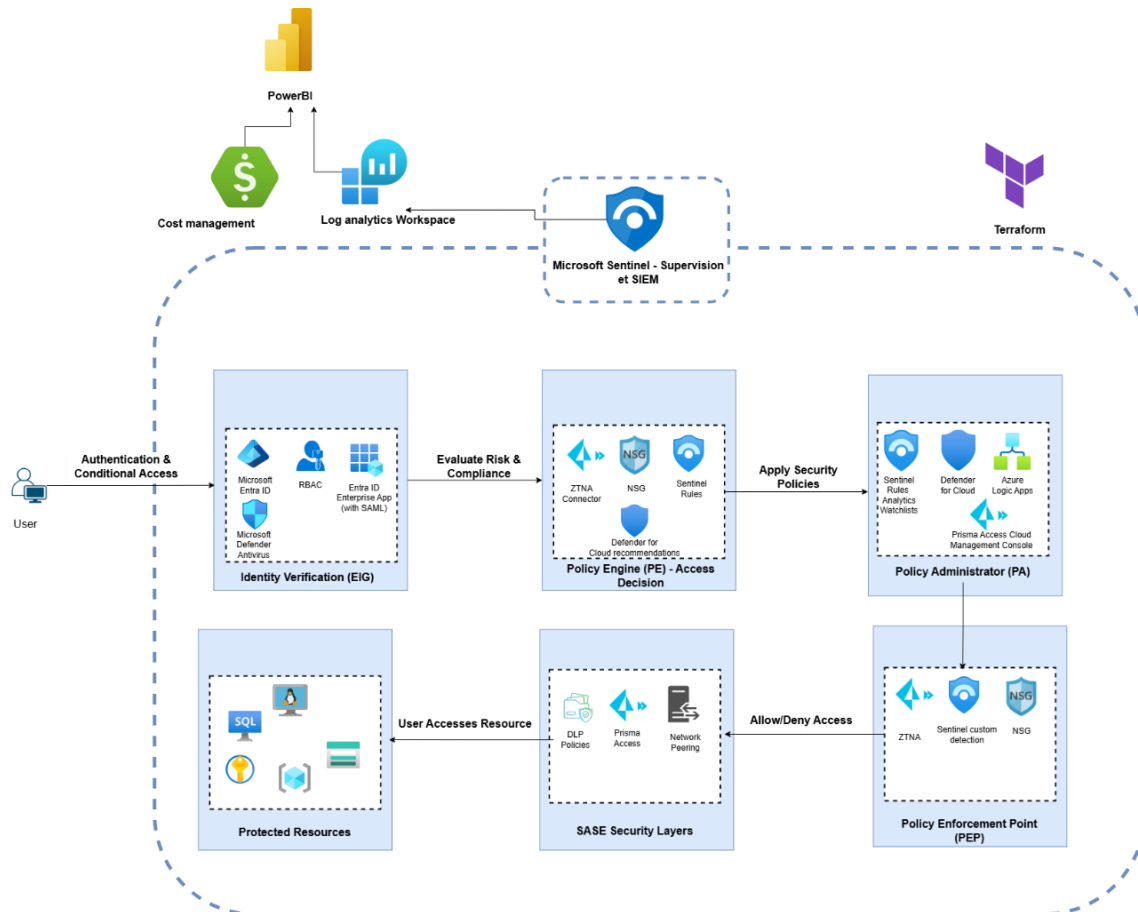


Figure 7: Architecture de la solution

6.1. Infrastructure Cloud et Réseau

L'infrastructure repose sur Microsoft Azure, avec le déploiement de plusieurs machines virtuelles (VM) organisées autour de cas d'usage spécifiques :

- Une machine Windows (ZTA-WinClient) équipée de SQL Server, utilisée comme cible d'attaque dans le cadre de tests de sécurité, mais également comme démonstration d'un service sensible nécessitant une protection avancée.
- Une machine Linux (ZTA-Linux) hébergeant une application vulnérable servant de simulateur d'attaques web pour analyser le comportement des outils de sécurité.
- Une machine Attacker, configurée avec des outils d'intrusion et de brute-force, permettant de simuler des scénarios offensifs internes et externes dans un cadre contrôlé.

L'ensemble des VMs est intégré à un réseau virtuel VNet, segmenté en sous-réseaux isolés selon les rôles de chaque machine (production, attaque, supervision). Des groupes de sécurité réseau NSG ont été définis pour restreindre le trafic entre sous-réseaux et contrôler finement les flux autorisés. Le peering entre VNet permet également d'assurer la connectivité entre des ressources réparties tout en maintenant la segmentation logique indispensable à une architecture Zero Trust.

6.2. Outils et Services Utilisés

Le système s'appuie sur un ensemble d'outils de sécurité et d'automatisation, à la fois côté Microsoft Azure et via des solutions tierces :

- **Azure Sentinel** : plateforme SIEM utilisée pour centraliser, corrélérer et visualiser les événements de sécurité générés par les machines virtuelles, Defender et autres sources.
- **Microsoft Defender for Cloud** : activé pour la surveillance continue des ressources (VM, SQL, Stockage) et la détection de menaces.
- **Microsoft Entra ID** : gère l'identité, le Single Sign-On et la RBAC, conforme au modèle ZTA.
- **Prisma Access** : apporte les dimensions ZTNA et DLP Ces outils sont utilisés pour tester le contrôle d'accès granulaire à une application interne, ainsi que la protection des données sensibles.

En complément, des solutions spécifiques ont été intégrées pour améliorer l'automatisation, la réponse aux incidents et la visualisation :

- **Terraform** pour l'automatisation du déploiement d'infrastructure (Infrastructure as Code).
- **Azure Logic Apps** pour orchestrer des flux de réponse aux incidents à l'aide d'OpenAI.
- **Power BI** pour visualiser des tableaux de bord regroupant des indicateurs de sécurité, de coût et de performances du système.

7. Conclusion

Les choix techniques opérés dans ce projet ont été guidés par une volonté de concilier efficacité, intégration native à l'écosystème Azure, et maîtrise des coûts. Chaque outil sélectionné répond à un besoin précis du modèle Zero Trust, qu'il s'agisse de la gestion des identités, de l'automatisation, de la surveillance des événements ou du contrôle des accès. L'ensemble forme une architecture cohérente, automatisée et évolutive, adaptée aux environnements cloud modernes et aux contraintes d'un projet étudiant sans budget étendu.

Chapitre III : Infrastructure et Sécurité de Base

1. Introduction

Ce chapitre décrit la phase initiale de mise en place de l'architecture cloud sécurisée. Il présente le déploiement automatisé de l'infrastructure sur Microsoft Azure à l'aide de Terraform, la configuration des ressources critiques comme les machines virtuelles et les réseaux, ainsi que l'intégration de Microsoft Defender for Cloud pour assurer une protection des charges de travail dès leur création. Cette étape pose les fondations de l'approche Zero Trust, en assurant cohérence, traçabilité et conformité dès le provisionnement des ressources. L'Automatisation de l'infrastructure Azure avec Terraform

1.1. Configuration du projet Terraform

On a choisi d'utiliser Terraform pour automatiser la mise en place de notre infrastructure dans Azure, conformément à une approche Infrastructure-as-Code. Cela nous a permis de déployer de manière cohérente et reproductible les machines virtuelles, réseaux, groupes de sécurité, comptes de stockage, et solutions de sécurité.

L'intégration avec Azure s'est faite via l'authentification CLI avec la commande `az login`. Pour des raisons de sécurité, les identifiants des machines virtuelles nom d'utilisateur et mot de passe n'ont pas été codés en dur dans les fichiers `.tf`, mais saisis dynamiquement dans le terminal en les passant via des variables d'environnement (`TF_VAR_windows_vm_password`), évitant ainsi toute fuite de données sensibles dans le code.

1.2. Architecture du projet Terraform

La structure adoptée vise à respecter les bonnes pratiques Terraform. Chaque ressource est déployée dans un fichier séparé selon sa nature :

- Infrastructure de calcul (Compute) : machines Windows, Linux, honeypot.
- Sécurité réseau (NSG) : règles d'accès et groupes de sécurité associés.
- Stockage et supervision : logs, workspace Sentinel, Defender.
- Surveillance et automatisation : intégration Sentinel, configuration Defender, Logic Apps.

Cela permet :

- De modulariser le projet pour faciliter le travail en équipe.
- D'éviter les conflits ou erreurs de déploiement.
- De réutiliser des blocs de code facilement dans d'autres projets.

La figure ci-dessous illustre les divers fichiers de notre projet Terraform.

monitoring.tf : Met en place la surveillance : Log Analytics Workspace, Microsoft Sentinel, connecteurs de données.

defender.tf : Configure Microsoft Defender for Cloud pour les VM, les serveurs SQL, et le stockage, en activant les plans gratuits.

compute_project_vms.tf : Définit les machines virtuelles principales du projet, leurs disques, IP publiques, et extensions.

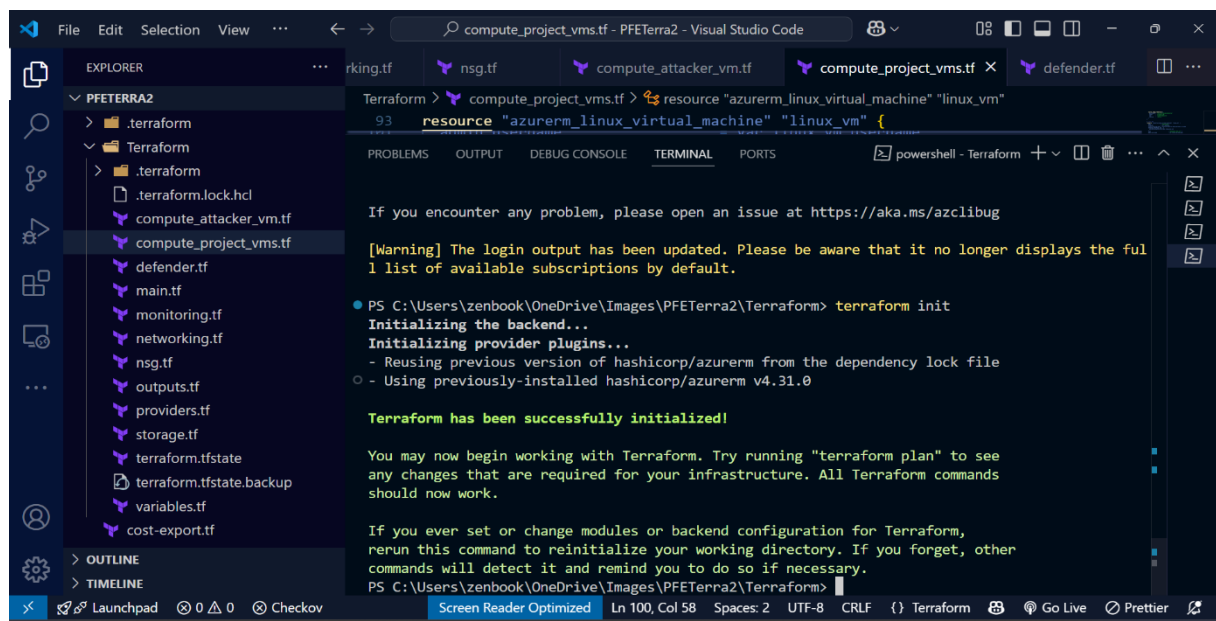
compute_attacker_vms.tf : Gère la machine d'attaque séparément pour isoler sa configuration du reste du projet.

1.4. Déploiement du script

Lors de chaque cycle de déploiement, nous avons utilisé les commandes :

- **terraform init** pour initialiser le projet et télécharger les providers nécessaires.

terraform init est la commande qui permet d'initialiser un projet Terraform. Elle sert à configurer l'environnement de travail en téléchargeant tous les providers (fournisseurs de services cloud.) spécifiés dans le fichier de configuration, ainsi que les modules nécessaires. Cette étape est indispensable avant de pouvoir exécuter d'autres commandes Terraform, car elle prépare le projet en vérifiant les dépendances, en configurant le backend pour le stockage de l'état, et en établissant la base du projet.



```
File Edit Selection View ... compute_project_vms.tf - PFETerra2 - Visual Studio Code
EXPLORER
PFETerra2
├── .terraform
├── Terraform
│   ├── .terraform.lock.hcl
│   ├── compute_attacker_vm.tf
│   ├── compute_project_vms.tf
│   ├── defender.tf
│   ├── main.tf
│   ├── monitoring.tf
│   ├── networking.tf
│   ├── nsg.tf
│   ├── outputs.tf
│   ├── providers.tf
│   ├── storage.tf
│   ├── terraform.tfstate
│   ├── terraform.tfstate.backup
│   ├── variables.tf
│   └── cost-export.tf
└── OUTLINE
    └── TIMELINE
Launchpad 0 0 0 Checkov Screen Reader Optimized Ln 100, Col 58 Spaces: 2 UTF-8 CRLF {} Terraform Go Live Prettier

Terraform > compute_project_vms.tf > resource "azurerm_linux_virtual_machine" "linux_vm"
93 resource "azurerm_linux_virtual_machine" "linux_vm" {
PROBLEMS OUTPUT DEBUG CONSOLE TERMINAL PORTS powershell - Terraform + - - - - -
If you encounter any problem, please open an issue at https://aka.ms/azclibug
[Warning] The login output has been updated. Please be aware that it no longer displays the full list of available subscriptions by default.
PS C:\Users\zenbook\OneDrive\Images\PFETerra2\Terraform> terraform init
Initializing the backend...
Initializing provider plugins...
- Reusing previous version of hashicorp/azurerm from the dependency lock file
- Using previously-installed hashicorp/azurerm v4.31.0
Terraform has been successfully initialized!
You may now begin working with Terraform. Try running "terraform plan" to see any changes that are required for your infrastructure. All Terraform commands should now work.
If you ever set or change modules or backend configuration for Terraform, rerun this command to reinitialize your working directory. If you forget, other commands will detect it and remind you to do so if necessary.
PS C:\Users\zenbook\OneDrive\Images\PFETerra2\Terraform>
```

Figure 9: Terraform init

- **terraform plan** pour prévisualiser les ressources à créer ou modifier.

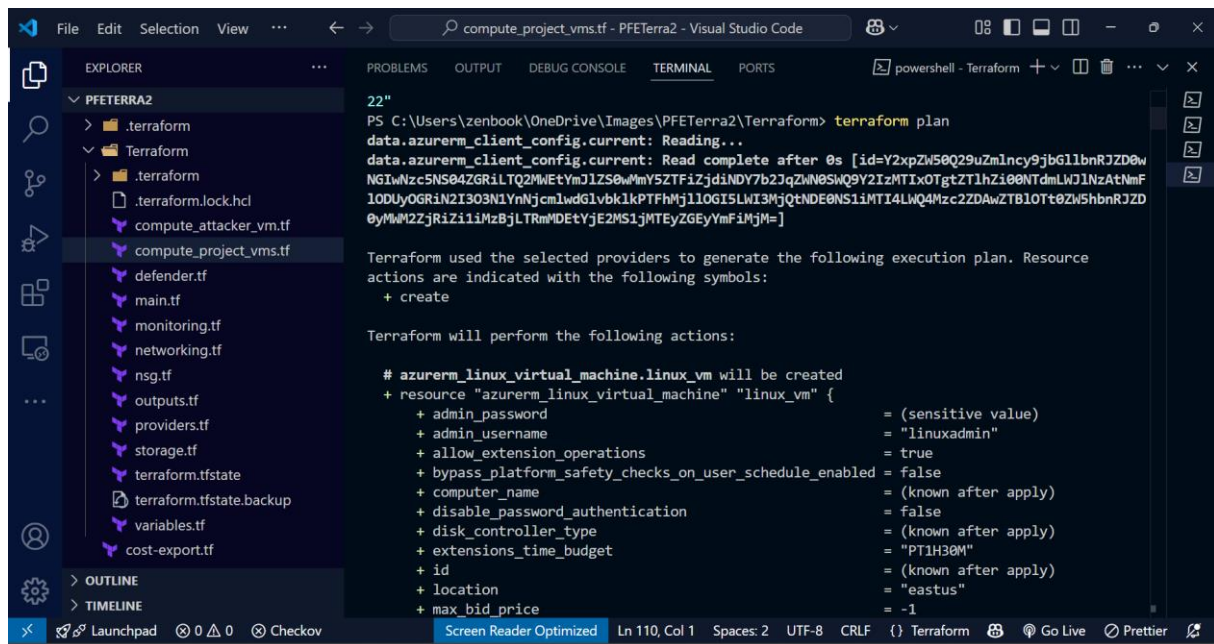


Figure 10: Terraform plan

- **terraform apply** pour appliquer effectivement les changements dans Azure.

terraform apply est la commande qui permet d'appliquer concrètement les modifications définies dans les fichiers de configuration Terraform. Après avoir validé le plan d'exécution (terraform plan), cette commande effectue les actions nécessaires pour créer, modifier ou supprimer les ressources dans l'environnement ciblé — par exemple dans Azure. Elle exécute donc les changements décrits, en interagissant directement avec l'API d'Azure pour provisionner l'infrastructure telle que décrite dans les fichiers .tf.

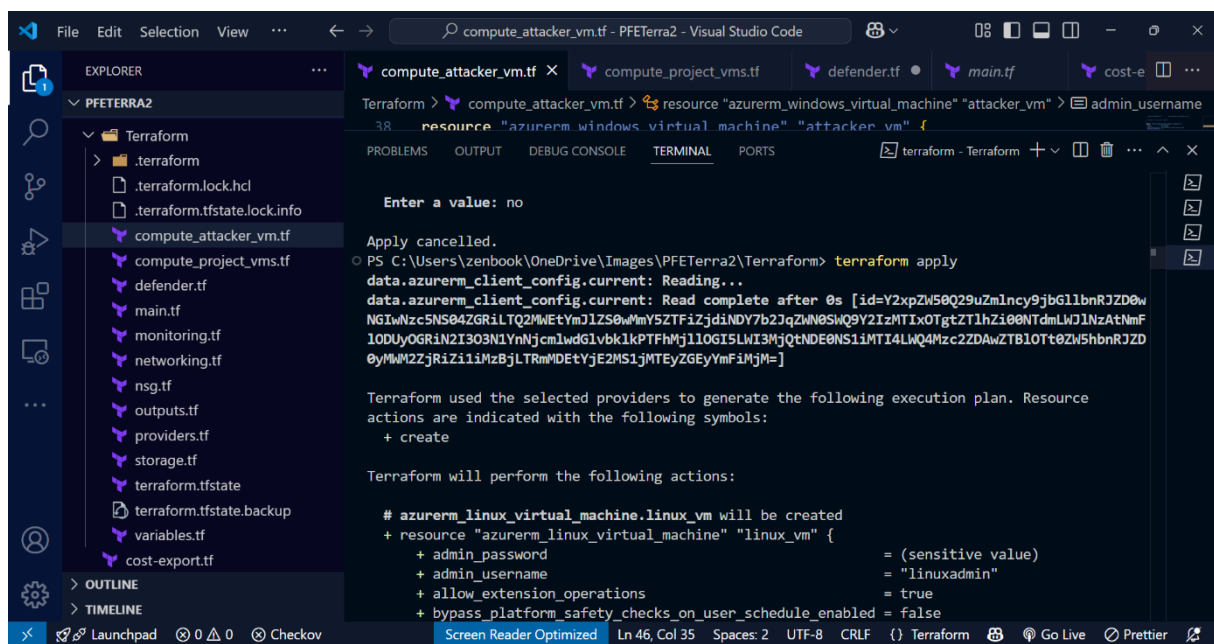


Figure 11: Terraform apply

Cette approche automatisée a grandement simplifié le déploiement de notre environnement complexe tout en assurant une traçabilité et une cohérence dans la configuration.

Après l'authentification sur Azure et l'initialisation du rôle via Terraform init, on a utilisé la commande Terraform apply pour déployer notre infrastructure. Terraform apply a pris en compte les configurations définies dans nos fichiers Terraform. Voilà notre infrastructure sur Azure.

On navigue vers notre interface azure, on vérifie l'infrastructure déployée via Terraform.

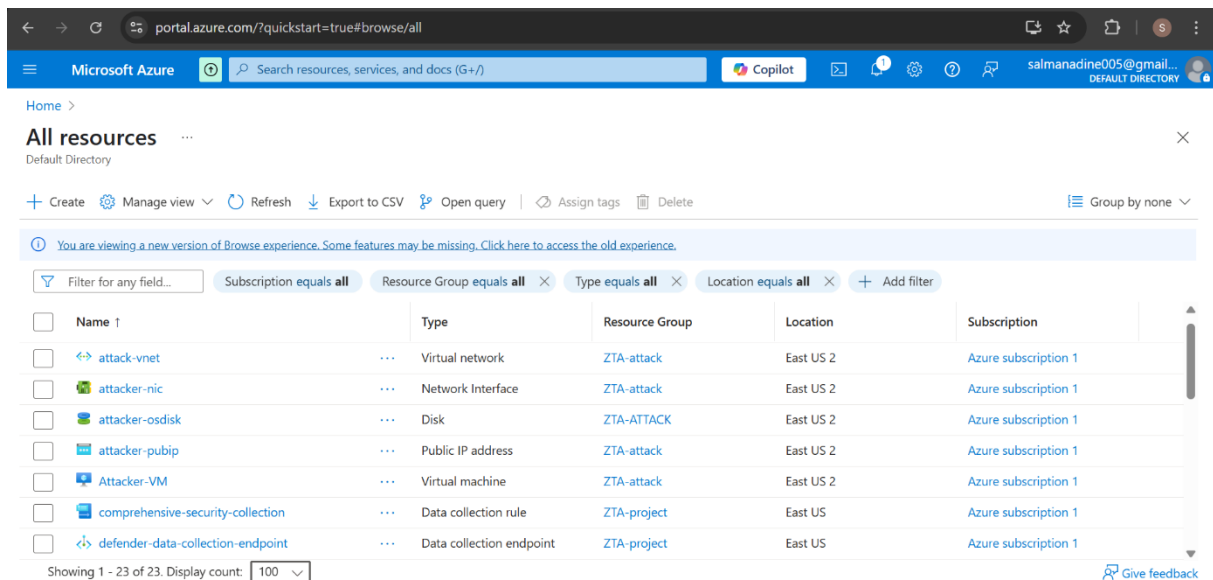


Figure 12: L'infrastructure déployée via Terraform

2. Sécurité et Conformité des Charges de Travail

2.1. Surveillance avec Microsoft Defender for Cloud

Dans le cadre de notre projet reposant sur les principes du modèle Zero Trust et les recommandations du NIST SP 800-207, nous avons mis en place un système de surveillance avancé à l'aide de Microsoft Defender for Cloud. Cette solution native d'Azure nous a permis d'évaluer et d'améliorer la posture de sécurité de notre environnement tout en assurant un niveau de protection cohérent avec les exigences modernes en matière de cybersécurité.

Nous avons sélectionné les plans Defender en fonction des ressources critiques présentes dans notre groupe de ressources. Deux d'entre eux ont été particulièrement importants :

- **Microsoft Defender pour les serveurs**, qui offre une protection étendue aux machines virtuelles. Il permet de détecter des menaces, des vulnérabilités connues et des comportements anormaux sur les charges de travail serveur.
- **Microsoft Defender pour les bases de données SQL**, utilisé pour surveiller et sécuriser nos serveurs SQL contre des attaques potentielles, notamment les attaques par injection, les configurations faibles ou les tentatives d'escalade de privilèges.

Ces plans s'intègrent naturellement dans une stratégie Zero Trust en renforçant les contrôles de sécurité au plus près des charges de travail et en multipliant les points de vérification.

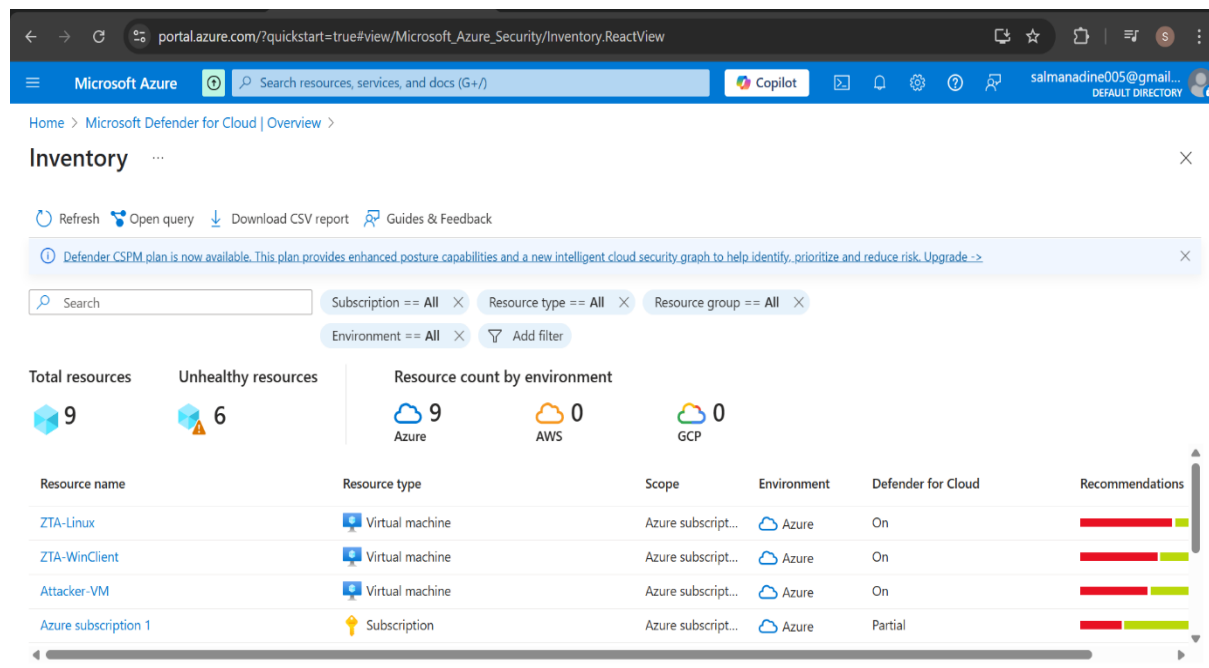


Figure 13: Configuration Microsoft Defender

Nous avons activé la collecte de données complète à travers Microsoft Defender for Cloud pour alimenter notre espace de travail Log Analytics. Cette configuration comprend :

- L'audit des événements liés aux ressources Azure, au réseau et à la sécurité.
- L'analyse de comportement pour identifier automatiquement les écarts par rapport aux schémas habituels.
- La surveillance continue, avec génération d'alertes sur les événements suspects et les tentatives d'exploitation.

Ce niveau de visibilité permet une détection précoce des menaces, en conformité avec le principe du NIST "Assume Breach" et l'exigence de vérification continue propre au Zero Trust.

Dans une logique de protection du périmètre étendu, nous avons activé la fonction de protection des points de terminaison sans agent. Cette capacité permet à Defender de scanner les machines à la recherche de logiciels malveillants ou de vulnérabilités sans nécessiter d'installation locale, ce qui facilite le déploiement et réduit les risques opérationnels.

Ce dispositif contribue à maintenir une hygiène de sécurité de base sur les machines, en particulier en ce qui concerne :

- La détection des ports ouverts exposés.
- Les processus suspects.

- Les connexions non approuvées.

Il s'agit d'un élément central dans le contrôle de l'état des appareils, dimension clé dans les architectures Zero Trust.

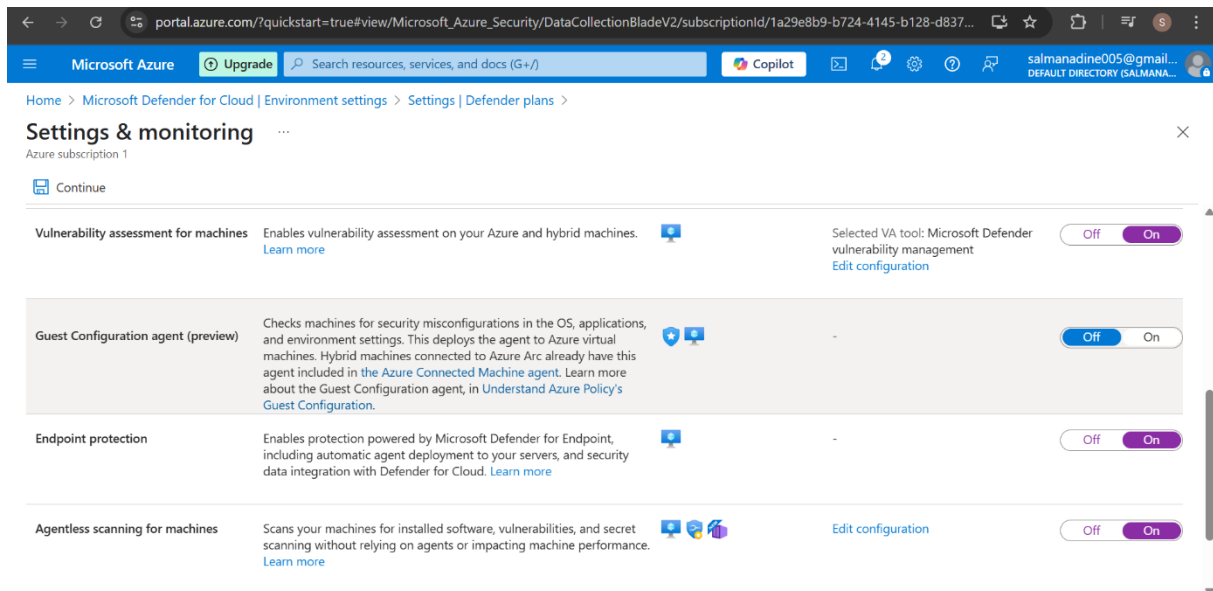


Figure 14: Configuration des paramètres de sécurité dans Microsoft Defender

Enfin, nous avons mis en œuvre une analyse régulière des vulnérabilités sur les machines virtuelles à l'aide de Defender for Cloud. Celle-ci nous a permis :

- D'identifier des vulnérabilités connues (CVE) sur les composants système et logiciels.
- De classer les menaces selon leur criticité.
- De recevoir des recommandations claires pour prioriser les actions correctives.

Ce processus de remédiation itératif renforce notre résilience face aux attaques tout en assurant l'alignement avec les exigences du NIST SP 800-207, notamment en matière de réduction de la surface d'attaque et de correction continue.

2.2. Recommandations et Conformité réglementaire

Dans la continuité de notre démarche proactive de sécurisation de l'environnement cloud, nous avons exploité les fonctionnalités avancées de Microsoft Defender for Cloud pour obtenir des recommandations de sécurité précises, ainsi qu'une évaluation de la conformité réglementaire vis-à-vis des standards internationaux de cybersécurité. Ces deux volets jouent un rôle fondamental dans la mise en œuvre opérationnelle d'une architecture Zero Trust robuste.

1. Recommandations de sécurité : priorisation et amélioration continue

Microsoft Defender for Cloud génère en permanence des recommandations contextualisées pour améliorer la posture de sécurité de nos ressources. Ces recommandations sont classées selon leur niveau de sévérité (haut, moyen, faible) et leur impact sur la surface d'attaque. Elles incluent notamment :

- Le renforcement des configurations réseau (désactivation de ports ouverts, mise en œuvre de NSG).
- L'activation du chiffrement des données au repos et en transit.
- La gestion des identités à privilèges (application du principe du moindre privilège).
- La correction des vulnérabilités logicielles ou de configuration détectées sur les machines.

Ces recommandations sont centralisées dans le tableau de bord Secure Score, qui fournit un indicateur clair et mesurable de notre niveau de sécurité global. Chaque amélioration appliquée permet d'augmenter ce score, ce qui en fait un outil dynamique d'auto-évaluation et de priorisation des efforts de durcissement.

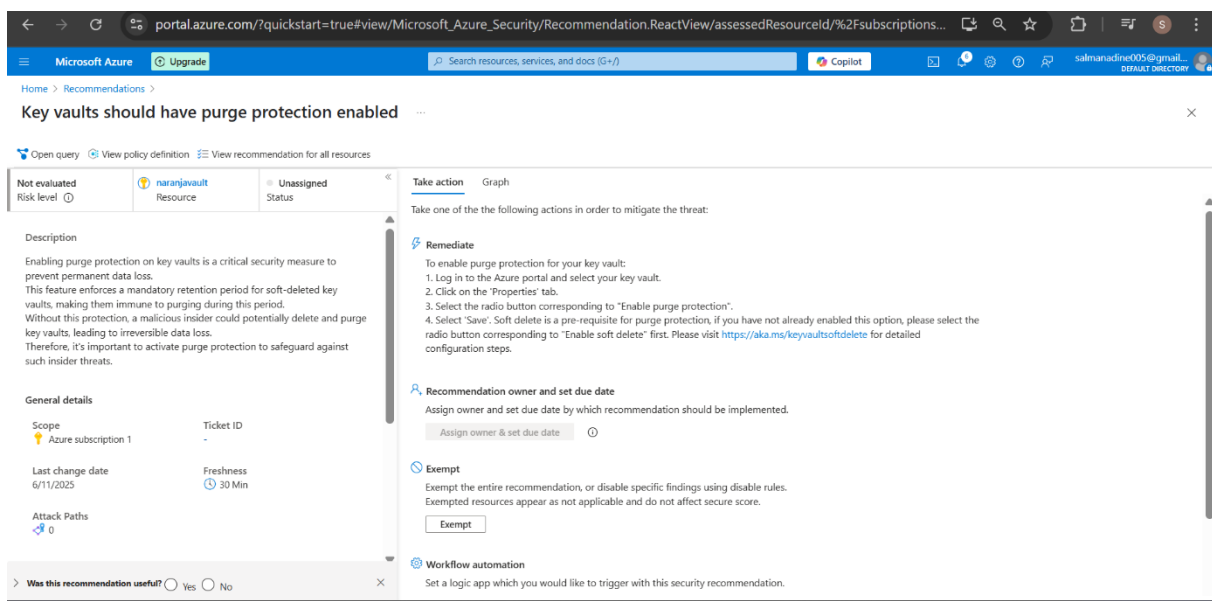


Figure 15: Recommendation de Microsoft Defender pour Key Vault

Microsoft Defender for Cloud offre également un module d'évaluation de la conformité réglementaire, basé sur des référentiels. À travers ce module, nous avons pu :

- Cartographier l'état de conformité de notre environnement Azure par rapport à ces standards.
- Identifier les écarts entre notre configuration actuelle et les exigences formelles des référentiels sélectionnés.
- Obtenir des recommandations précises pour réduire ces écarts, notamment en matière de gestion des accès, de journalisation, ou de segmentation réseau.

Dans le contexte de notre projet, nous nous sommes principalement référés à l'Azure Security Benchmark (ASB), qui est en étroite cohérence avec le modèle Zero Trust. Ce benchmark met l'accent sur la surveillance continue, la défense en profondeur, et l'automatisation des réponses aux menaces.

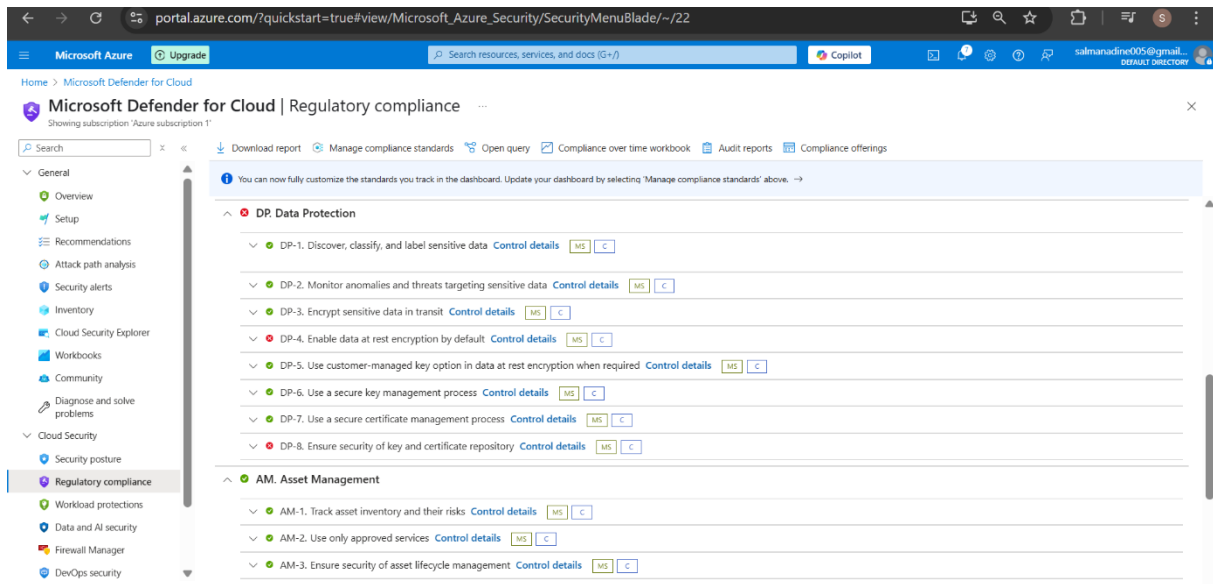


Figure 16: Regulatory Compliance

3. SIEM et Investigation avec Microsoft Sentinel

3.1. Configuration d'agents pour la collecte des logs

Dans le cadre de notre stratégie d'investigation et de détection des menaces, nous avons mis en place un système robuste de collecte centralisée des logs, basé sur l'écosystème Azure Monitor et Microsoft Sentinel. Cette configuration constitue le socle de notre solution SIEM, essentielle pour la surveillance active, l'analyse comportementale et la réponse aux incidents.

- Création de l'environnement de collecte

La première étape a consisté à créer un Log Analytics Workspace nommé MyMonitoringWorkspace. Cet espace de travail est utilisé comme destination centralisée pour l'ensemble des données collectées, assurant une corrélation efficace entre les différentes sources.

En parallèle, nous avons configuré un container de type blob dans notre compte de stockage Azure nommé sanikoyani1, destiné à héberger les journaux bruts. Cette séparation entre la collecte et le stockage répond aux principes de conservation sécurisée et de traçabilité des données, en accord avec les bonnes pratiques de gouvernance cloud.

- Surveillance du trafic réseau par les Flow Logs

Pour assurer une visibilité complète sur les flux réseau, nous avons activé les Network Security Group Flow Logs sur notre groupe de sécurité réseau. Ces journaux permettent de capturer l'intégralité du trafic entrant et sortant associé aux ressources, y compris les adresses IP source et destination, les ports utilisés, le protocole appliqué et le verdict (autorisé ou bloqué).

Les logs ainsi générés sont automatiquement stockés dans `sanikoyani1`, puis liés à `MyMonitoringWorkspace`, rendant possible leur exploitation via des requêtes KQL (Kusto Query Language), des tableaux de bord personnalisés et la création d'alertes dynamiques. Ce dispositif contribue à une détection fine des comportements anormaux et à la réduction du temps moyen de détection.

- Contrôle granulaire de la collecte avec un DCR

Dans une logique de collecte précise et maîtrisée, nous avons mis en place un Data Collection Rule (DCR). Ce composant nous a permis de définir les resource groups cibles de la collecte, de choisir les types de données sources (logs système, performance, diagnostics) et d'indiquer la destination vers `MyMonitoringWorkspace`.

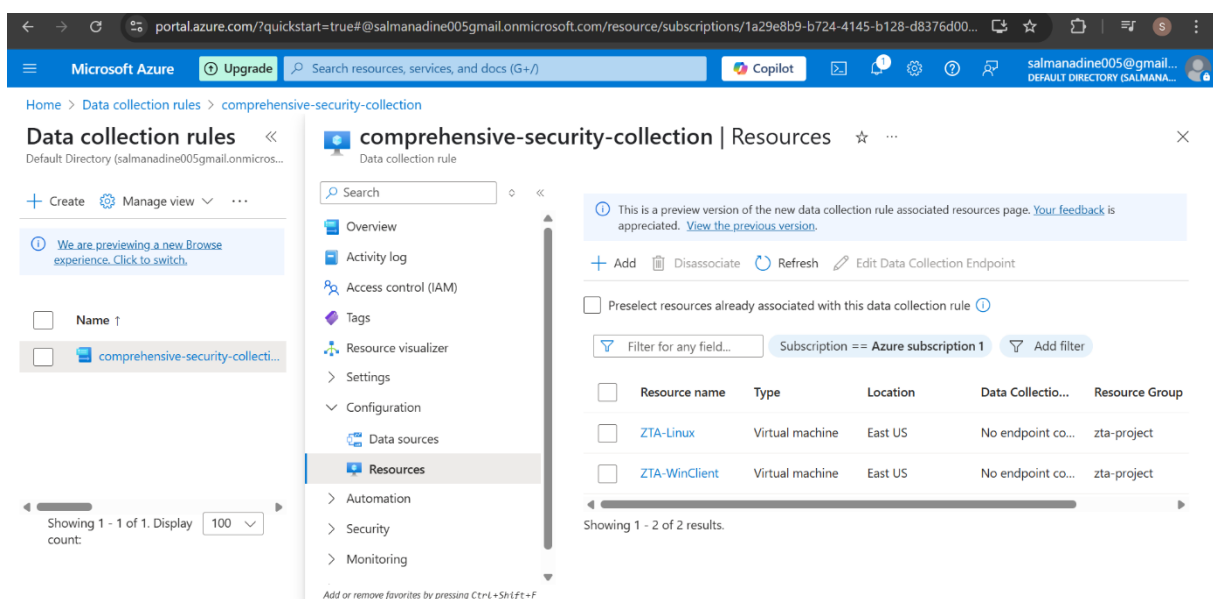


Figure 17: Création d'un DCR

Le DCR joue un rôle central dans l'optimisation des coûts et dans l'alignement avec les exigences du modèle Zero Trust, notamment en contrôlant quels types de données sont collectés, pour quelles ressources et dans quel but.

- Installation et validation de l'agent AMA

Pour rendre effective la collecte sur nos machines, nous avons installé l'agent Azure Monitor Agent sur une machine virtuelle Linux. L'installation réussie de cet agent garantit la capacité de capturer les logs système, les métriques de performance et les événements de sécurité, de

transmettre ces données de manière sécurisée et en temps quasi réel vers Azure Monitor, et d'assurer une observabilité complète des workloads déployés.

Ce déploiement constitue une étape clé dans l'activation de scénarios d'investigation avancée avec Microsoft Sentinel, notamment en permettant la corrélation multi-source et la détection d'activités suspectes par l'intelligence intégrée de Sentinel.

Après la configuration des agents et des règles de collecte, nous avons procédé à des tests pour vérifier que notre Log Analytics Workspace (MyMonitoringWorkspace) reçoit bien les journaux générés par nos machines, notamment une VM Windows.

Nous avons ciblé les sources SecurityEvent (journaux de sécurité Windows) ainsi que Syslog (pour les systèmes Linux), ce qui nous a permis de valider la collecte des événements critiques tels que les connexions, déconnexions, échecs d'authentification ou changements de privilèges.

The screenshot shows the Microsoft Sentinel 'Logs' view in a web browser. The left sidebar contains navigation options: General, Overview, Logs (selected), News & guides, Search, Threat management, Incidents, Workbooks, Hunting, Notebooks, Entity behavior, and Threat intelligence. The main area displays a KQL query: `SecurityEvent | where TimeGenerated > ago(7d) | where EventID == 4625 or EventID == 4624`. Below the query, the 'Results' tab is active, showing a table with columns: TimeGenerated [UTC], Account, AccountType, Computer, and EventSourceName. The table contains five rows of data, all from 'ZTA-WinClient' machines, showing security events with EventID 4625 or 4624.

TimeGenerated [UTC]	Account	AccountType	Computer	EventSourceName
6/15/2025, 12:53:38.964 AM	NT AUTHORITY\SYSTEM	Machine	ZTA-WinClient	Microsoft-Windows-Security-Audit
6/15/2025, 12:53:36.309 AM	NT AUTHORITY\SYSTEM	Machine	ZTA-WinClient	Microsoft-Windows-Security-Audit
6/15/2025, 12:53:36.153 AM	NT AUTHORITY\SYSTEM	Machine	ZTA-WinClient	Microsoft-Windows-Security-Audit
6/15/2025, 12:50:02.726 AM	NT AUTHORITY\SYSTEM	Machine	ZTA-WinClient	Microsoft-Windows-Security-Audit
6/15/2025, 12:48:34.039 AM	NT AUTHORITY\SYSTEM	Machine	ZTA-WinClient	Microsoft-Windows-Security-Audit

Figure 18: Test de récupération des logs de Windows

À l'aide de requêtes KQL, nous avons pu interroger les données depuis Microsoft Sentinel et visualiser en temps réel les journaux transmis. Ces tests ont confirmé la bonne transmission des données entre les ressources surveillées, Log Analytics et Sentinel, assurant ainsi une base fiable pour les analyses futures, la détection d'anomalies et la mise en place de règles de corrélation avancées.

3.2.Règles Analytiques et Détection d'Incidents

Pour permettre à Microsoft Sentinel d'agir efficacement lors de la détection d'incidents, nous avons commencé par lui accorder les autorisations nécessaires à l'exécution des playbooks. Ces droits ont été accordés de manière ciblée, en sélectionnant uniquement les groupes de ressources concernés, conformément au principe du moindre privilège. Cette granularité permet à Sentinel

de ne disposer que des accès strictement requis, tout en restant pleinement opérationnel sur les Logic Apps utilisées pour automatiser les actions de réponse.

Une fois cette étape réalisée, nous avons défini des règles analytiques au sein de Microsoft Sentinel, basées sur des queries spécifiques. Ces règles ont pour but d'identifier les activités potentiellement suspectes dans notre environnement, comme des tentatives d'accès anormal, des connexions inhabituelles ou des pics d'activité. Chaque règle correspond à un scénario défini selon les comportements à surveiller sur les machines de notre groupe de ressources.

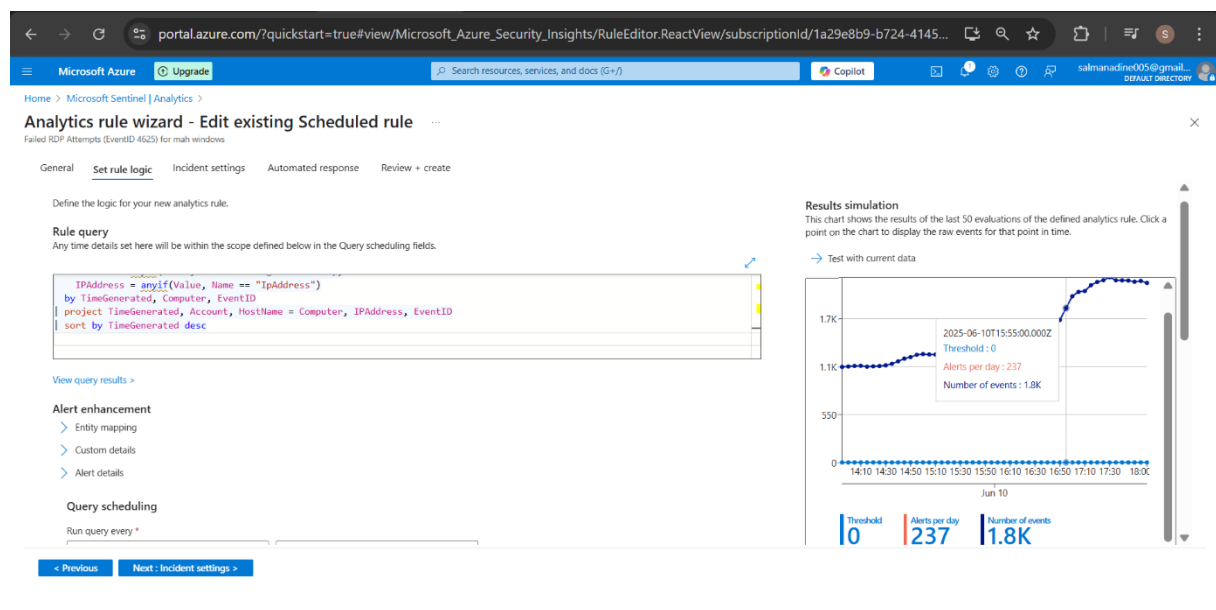


Figure 19: Définition des règles de détection dans Microsoft Sentinel

Les incidents détectés via ces règles apparaissent automatiquement dans l'interface centrale de Sentinel. Cette console d'analyse permet aux analystes de consulter tous les détails relatifs à l'alerte, y compris les ressources impactées, la chronologie des événements et les entités liées. Elle sert aussi de plateforme de coordination pour les étapes d'investigation, les prises de décision et la documentation des actions correctives.

Dans notre projet, un exemple marquant a été la détection d'une attaque de type brute force sur une machine Linux. Grâce aux outils d'analyse graphique intégrés, nous avons pu identifier les entités impliquées, les adresses IP suspectes, ainsi que les comptes ciblés. Cette visualisation a facilité la reconstitution du déroulement de l'attaque et permis d'évaluer son étendue. L'exploration des entités nous a également permis de déterminer s'il était nécessaire de déclencher des mesures urgentes telles que la mise en quarantaine, la désactivation de comptes ou la réinitialisation de mots de passe.

Ce processus d'investigation approfondie s'inscrit dans une approche continue d'amélioration de la sécurité, fondée sur la visibilité, la corrélation des données et la réactivité face aux menaces.

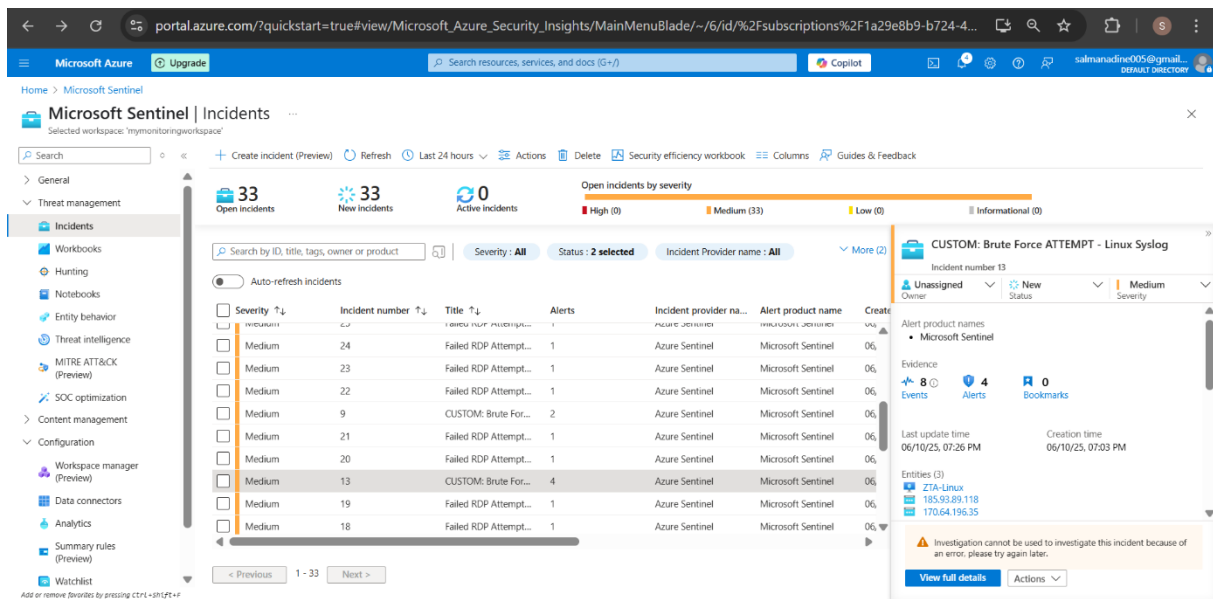


Figure 20: Analyse des incidents détectés dans Microsoft Sentinel

On explore les entités impliquées dans l'attaque brute force détectée sur un système Linux afin de comprendre l'origine de l'incident et évaluer son impact.

Ce type d'enquête permet d'identifier les comptes compromis, les adresses IP suspectes, ainsi que les ressources ciblées. Grâce à la visualisation graphique des entités, on peut reconstruire la chronologie des événements et détecter rapidement les mouvements latéraux potentiels dans l'environnement. On utilise aussi ces informations pour déterminer si des actions correctives immédiates sont nécessaires, comme la mise en quarantaine de ressources ou la réinitialisation de mots de passe.

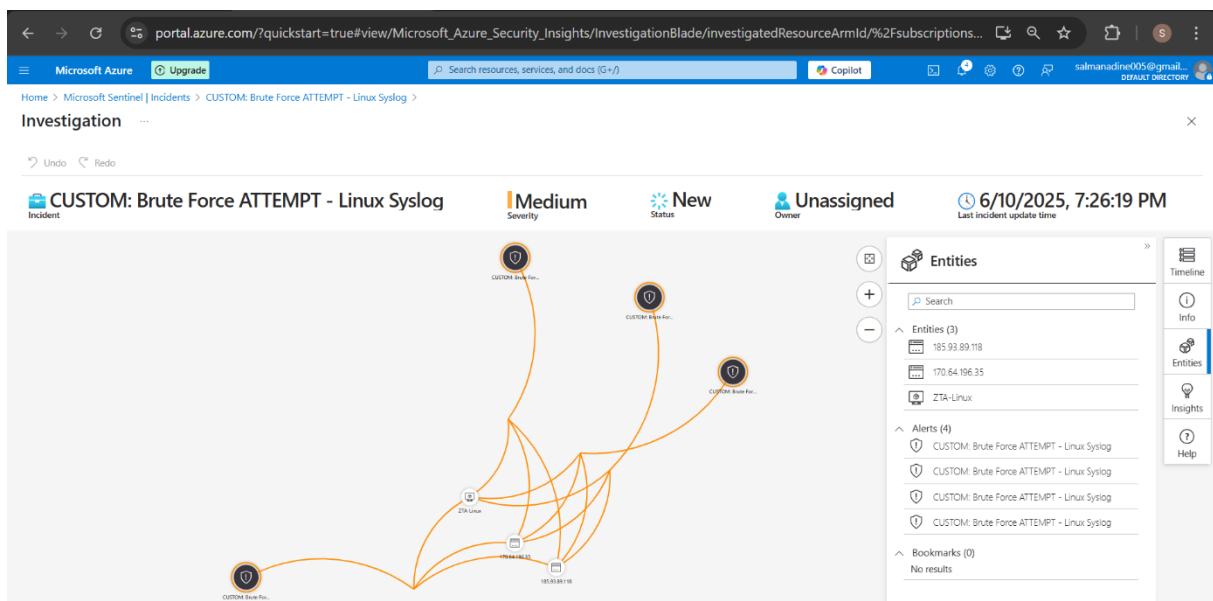


Figure 21: Investigation des incidents détectés dans Microsoft Sentinel

Afin de limiter le risque de récurrence, nous avons restreint la règle de sécurité existante dans le groupe de sécurité réseau, en autorisant uniquement notre propre adresse IP publique comme source d'accès. La règle a conservé son nom d'origine pour préserver la traçabilité, tout en appliquant une restriction efficace et ciblée. Cette mesure de durcissement répond au principe de limitation de la surface d'exposition.

Une fois l'analyse terminée, nous avons clôturé les incidents dans Sentinel en leur attribuant le statut Closed. Pour les incidents confirmés comme réels, le champ True Positive avec la mention Suspicious activity a été sélectionné. Ce processus assure une documentation claire des décisions et des classifications, tout en améliorant la cohérence des investigations futures. L'usage structuré de ces statuts permet aux équipes de filtrer les événements historiques, d'ajuster les règles de détection et de renforcer la posture globale.

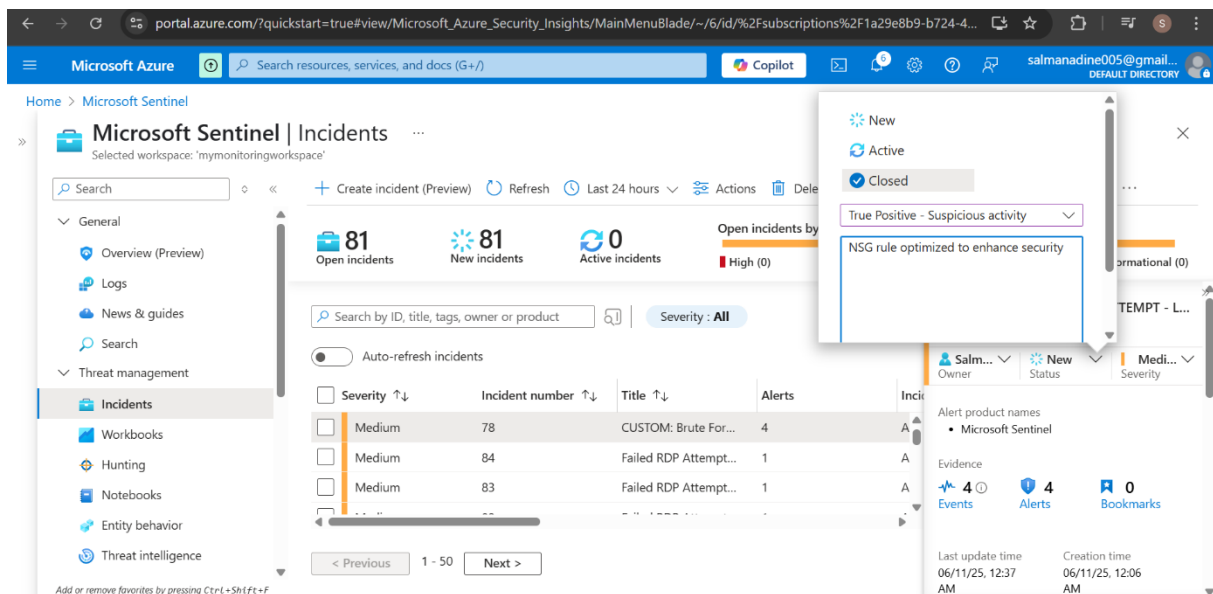


Figure 22: Clôture des incidents une fois l'analyse terminée vis status

Ce processus permet de documenter clairement les décisions prises, tout en facilitant le suivi historique et l'amélioration continue de la détection. L'usage cohérent de ces statuts renforce l'efficacité des équipes SOC, qui peuvent ensuite filtrer les incidents résolus ou validés pour alimenter des tableaux de bord, affiner les règles de détection et optimiser la réponse aux incidents futurs.

Enfin, nous avons utilisé le tableau de bord Overview de Microsoft Sentinel pour consulter les indicateurs essentiels liés aux incidents de sécurité. Ce tableau offre une vue consolidée sur la gravité des incidents, leur typologie ainsi que leur évolution dans le temps. Cette visualisation permet de détecter des pics d'activité inhabituels, comme ceux observés à 17h et 21h, facilitant ainsi l'ajustement des ressources SOC en fonction de la charge et de la menace.

En parallèle, l'analyse des tactiques fréquemment observées, notamment Credential Access et Initial Access, nous aide à identifier les approches les plus exploitées par les attaquants. En étudiant leur fréquence et leur distribution temporelle, nous évaluons l'évolution des techniques utilisées, et adaptons nos priorités de surveillance en conséquence. Cette capacité à lire les tendances d'attaque dans le temps renforce la stratégie proactive du SOC et contribue à optimiser les règles de détection.

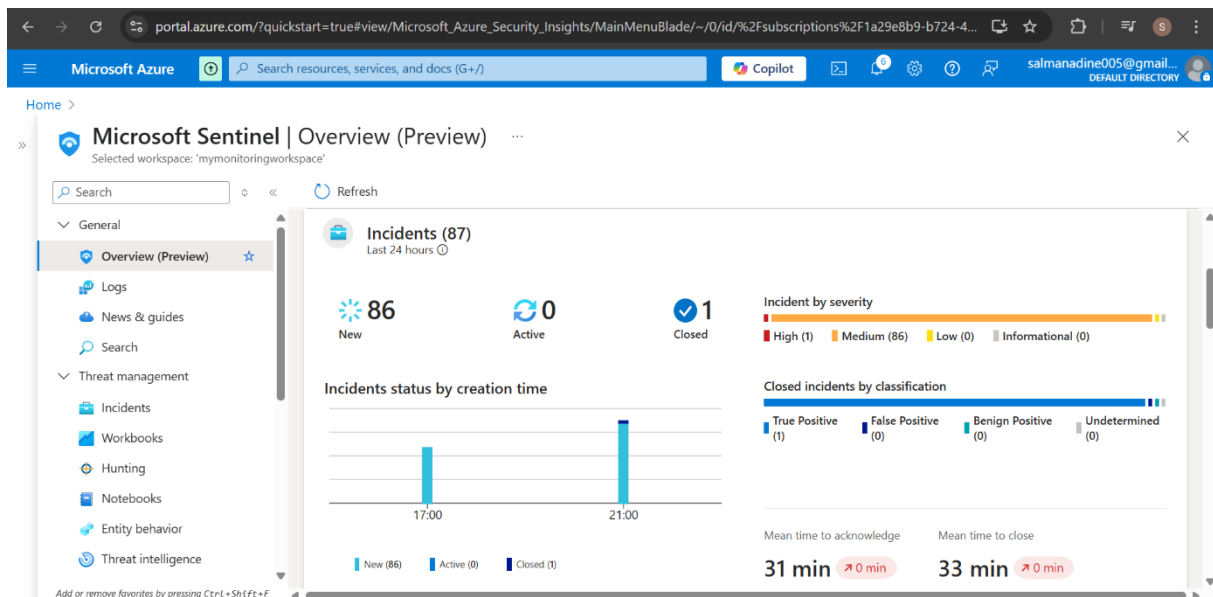


Figure 23: Tableau de bord Sentinel

3.3. Workbooks et Visualisation

3.3.1. Configuration du fichier Geoip dans Sentinel Watchlist

Dans le but d'enrichir nos visualisations avec des données de localisation, nous avons importé un fichier CSV local contenant des informations réseau et géographiques pour créer une watchlist nommée geoip dans Microsoft Sentinel. Le fichier respectait la structure requise, avec une ligne d'en-tête, et les paramètres ont été définis correctement via l'assistant d'importation.

Après l'import, nous avons vérifié et, si nécessaire, modifié les entrées pour nous assurer que chaque plage IP était bien associée à ses coordonnées géographiques, incluant latitude, longitude, ville et pays. Ces métadonnées sont essentielles pour permettre une corrélation visuelle entre les adresses IP observées dans les événements de sécurité et leur origine géographique.

Une fois la watchlist active, nous avons utilisé la commande `_GetWatchlist('Geoip')` pour interroger les données enregistrées. Cela nous a permis de visualiser en temps réel les villes et pays d'origine liés aux activités détectées au cours des dernières 24 heures. Nous avons également exécuté une requête pour compter le nombre total d'éléments présents dans la watchlist, ce qui confirme son bon chargement et sa disponibilité dans l'environnement Sentinel.

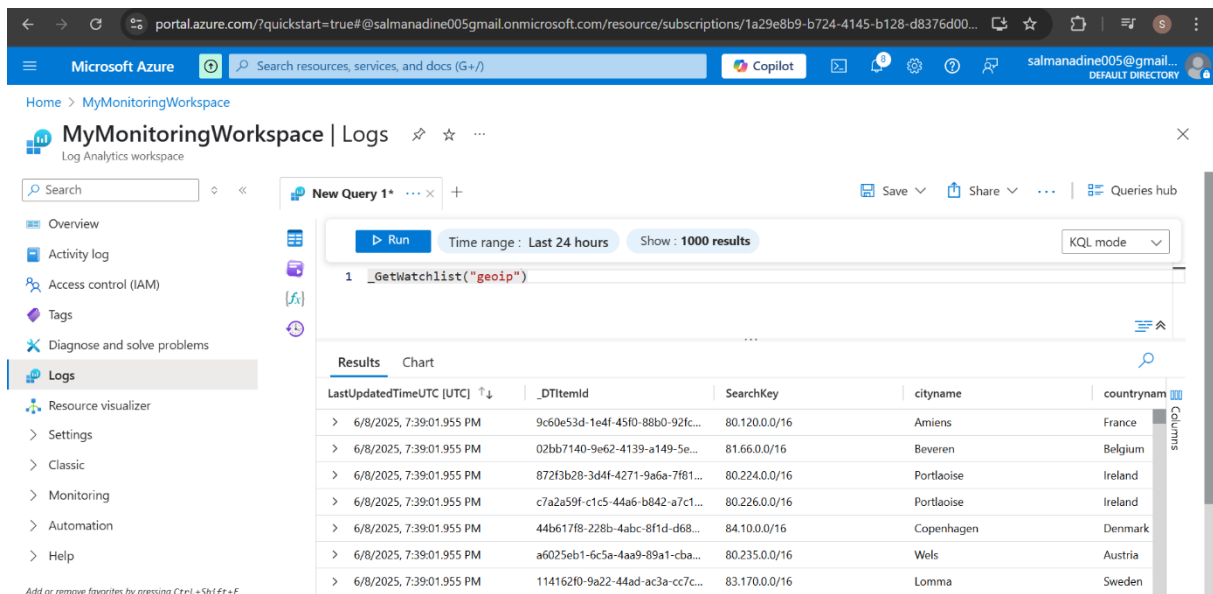


Figure 24: Interrogation de la Watchlist geoip dans logs

3.3.2. Création des Workbooks

Pour exploiter les données collectées et offrir une lecture visuelle claire aux analystes SOC, nous avons créé des workbooks personnalisés à l'aide de l'advanced editor dans Microsoft Sentinel. Ces workbooks permettent de représenter graphiquement la provenance géographique des événements de sécurité issus des données de la watchlist geoip.

Dans notre configuration, les visualisations mettent en évidence les villes et pays associés aux adresses IP détectées, ainsi que le volume d'événements provenant de chaque localisation. Cette approche facilite l'identification des régions à forte activité malveillante et appuie la prise de décision en matière de restriction d'accès.

Un exemple de workbook mis en œuvre affiche précisément les tentatives d'authentification échouées sur les machines Linux, en les classant par pays d'origine. Ces visualisations apportent un contexte géopolitique à la détection, tout en améliorant la réactivité face aux menaces.

```

2  "type": 3,
3  "content": {
4    "version": "KqlItem/1.0",
5    "query": "let GeoIPDB_FULL = _GetWatchlist(\"geoip\");\nlet WindowsEvents = SecurityEvent;\nWindowsEvents | where EventID == 4625\n| order by T",
6    "size": 3,
7    "timeContext": {
8      "durationMs": 2592000000
9    },
10   "queryType": 0,
11   "resourceType": "microsoft.operationalinsights/workspaces",
12   "visualization": "map",
13   "mapSettings": {
14     "locInfo": "LatLong",
15     "locInfoColumn": "countryname",
16     "latitude": "latitude",
17     "longitude": "longitude",
18     "sizeSettings": "EventID",
19     "sizeAggregation": "Count",
20   }
21 }

```

Figure 25: Création des Workbooks dans Sentinel

Les workbooks créés dans Microsoft Sentinel à l'aide des données enrichies par la watchlist geoip permettent une visualisation précise et contextualisée de l'origine géographique des événements de sécurité. Cette approche renforce la capacité d'analyse stratégique des analystes SOC, en mettant en évidence les zones d'activité malveillante et les schémas d'attaque récurrents.

Un premier workbook a été conçu pour afficher les tentatives d'authentification échouées sur les machines Linux. Les données collectées sont représentées sur une carte géographique, avec un regroupement des événements par pays et par ville. Cette représentation visuelle offre une lecture intuitive de l'origine des attaques, en mettant en avant les zones géographiques particulièrement actives ou inhabituelles. L'identification rapide de ces régions permet d'orienter les actions préventives telles que le blocage ciblé d'IP ou le durcissement des stratégies d'authentification



Figure 26: Workbook des authentifications échouées dans linux

Un second workbook porte sur les tentatives d'authentification échouées détectées sur un serveur MySQL sous Windows.

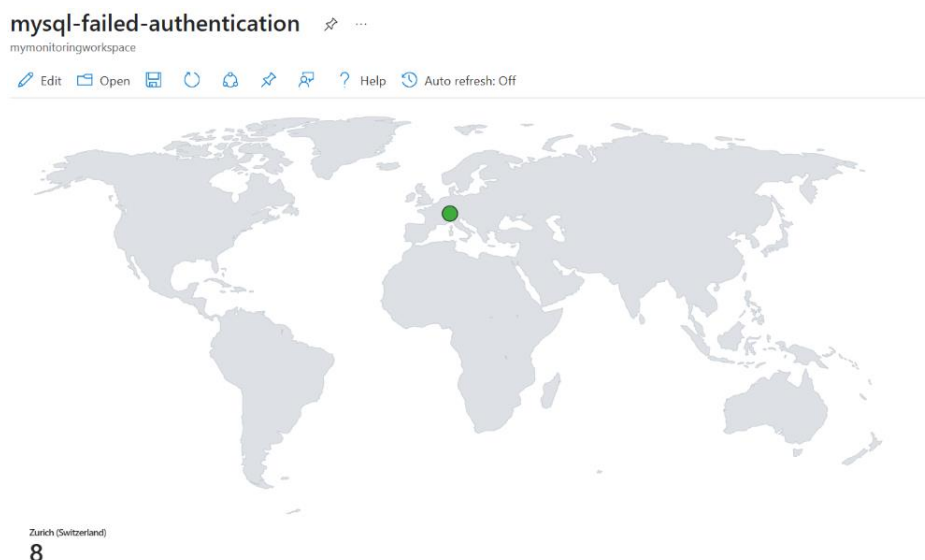


Figure 27: Workbook des authentifications échouées dans le serveur MySQL

Ce Workbook met en lumière l'origine géographique des connexions malveillantes autorisées par certaines règles des groupes de sécurité réseau NSG. En s'appuyant sur les journaux de flux NSG et l'enrichissement Geoip, il permet de cartographier les tentatives d'accès par ville et pays, et d'identifier les régions les plus actives en matière d'activités suspectes.

Cette visualisation facilite l'analyse des flux autorisés potentiellement risqués, et aide à ajuster les règles NSG pour renforcer la posture de sécurité tout en conservant la visibilité sur les comportements réseau.

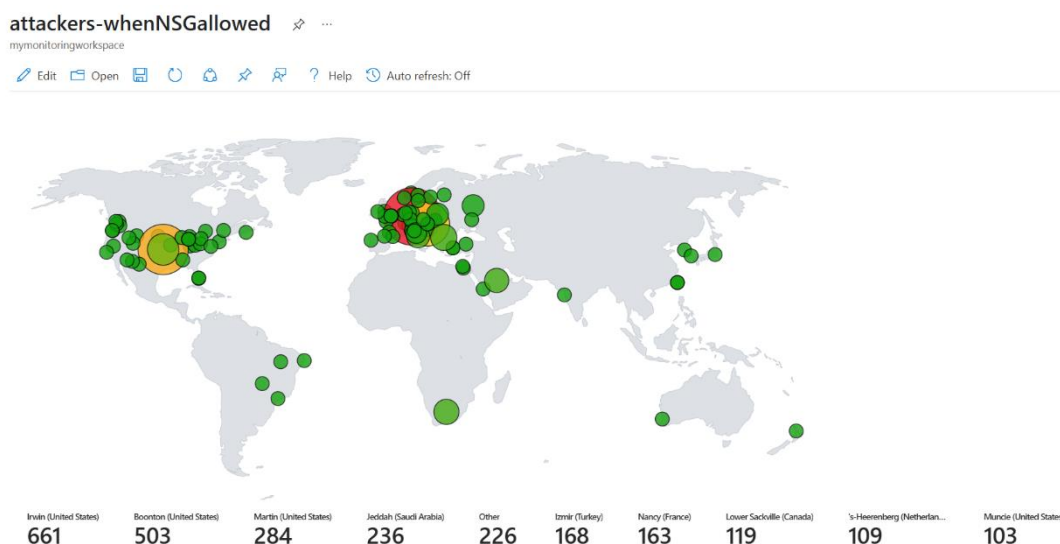


Figure 28: Workbook when NSG Allowed

4. Conclusion

Cette première étape a permis de construire un environnement cloud cohérent et sécurisé, aligné avec les principes de Zero Trust. Grâce à Terraform, l'infrastructure est reproductible et modulaire. L'intégration précoce de Defender for Cloud garantit une visibilité et une conformité continues. Cette base servira de socle à l'ajout progressif des couches de supervision, d'automatisation et de réponse aux incidents.

Chapitre IV : Supervision et Automatisation

1. Introduction :

Ce chapitre se concentre sur la supervision, la détection des menaces et l'automatisation des réponses dans l'environnement cloud sécurisé. Il présente l'intégration avancée de Microsoft Sentinel pour la collecte et l'analyse des logs, l'enrichissement avec des données géographiques personnalisées, ainsi que l'automatisation des tâches à l'aide d'Azure Logic Apps et d'OpenAI. Enfin, l'exploitation des données de sécurité et de coûts est centralisée via Power BI, et l'accès sécurisé est renforcé par l'utilisation de Prisma Access et Microsoft Entra ID.

2. Automatisation avec Logic Apps et OpenAI

Dans le cadre de notre stratégie d'automatisation de la réponse aux incidents, nous avons conçu un workflow intitulé chatGPT-automation-tasks à l'aide de Logic App. Ce flux permet d'interagir dynamiquement avec le service GPT afin de générer des compléments d'analyse, puis de créer un incident enrichi, documenté automatiquement.

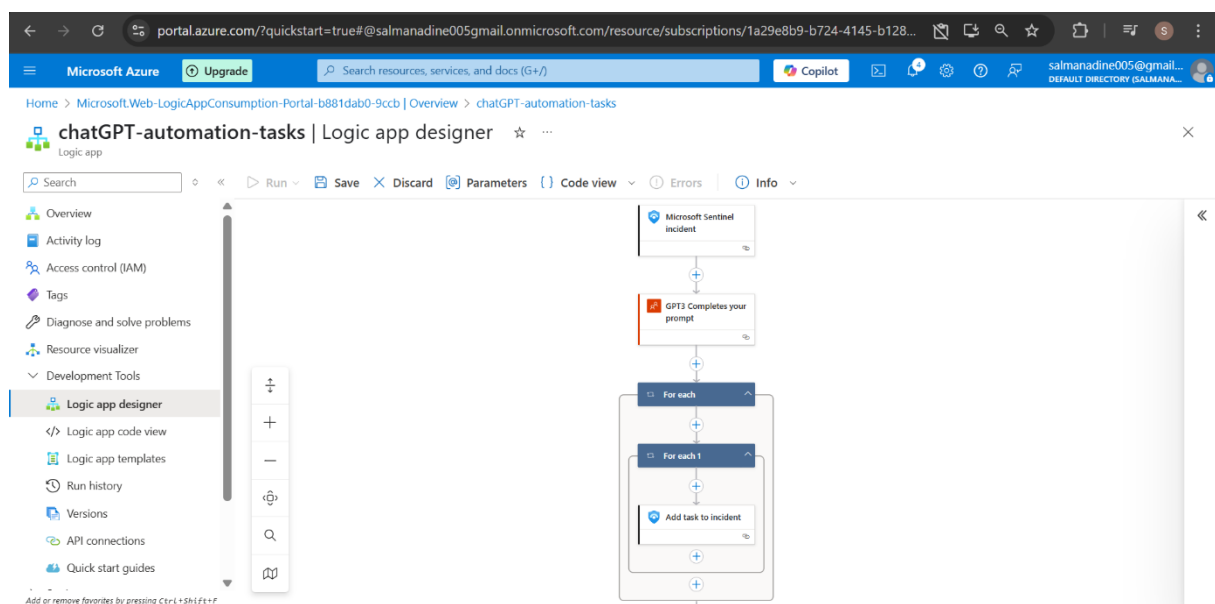


Figure 29: Logic Apps designer 1

Le cœur du processus repose sur quatre requêtes distinctes envoyées à GPT dans des blocs successifs. Chaque prompt est conçu pour produire un contenu spécifique : suggestion de mesure corrective, synthèse de l'incident, estimation de l'impact, et rédaction d'un message à destination des équipes SOC. Ces contenus sont ensuite intégrés de manière structurée dans l'incident nouvellement généré.

L'automatisation s'appuie également sur trois blocs For each, permettant d'itérer sur des ensembles d'entrées comme les entités concernées, les résultats de détection ou les lignes

extraites de journaux. À chaque itération, des notes contextualisées sont ajoutées à l'incident, ce qui assure une documentation riche et granulaire, sans intervention manuelle.

Ce type de workflow facilite l'intégration entre la détection effectuée dans Microsoft Sentinel et les tâches exécutées en réponse. Il garantit la traçabilité des décisions prises à travers des journaux complets, tout en apportant une couche d'intelligence supplémentaire grâce à GPT. L'enchaînement logique des nœuds, visible dans Logic Apps Designer, permet une lecture claire du processus et une maintenance aisée du flux.

Ce scénario d'automatisation reflète pleinement les principes de Zero Trust appliqués à la réponse aux incidents : action rapide, contextualisation des événements, contrôle basé sur les métadonnées, et documentation systématique.

On configure une nouvelle règle d'automatisation intitulée Incident response plan, qui se déclenche lorsqu'un incident est créé et exécute automatiquement notre logic app playbook.

Dans cette configuration, on définit des conditions qui rend la règle large et applicable à un ensemble d'incidents. L'objectif ici est de standardiser les réponses aux incidents dès leur création, en déclenchant des actions automatiques via des playbooks, ce qui permet de gagner en réactivité et cohérence.

Ce type d'automatisation est essentiel pour accélérer la réponse aux menaces, en standardisant des tâches comme l'enrichissement automatique des données, la notification des équipes, ou l'initiation de mesures correctives. C'est une brique clé de l'approche SOAR.

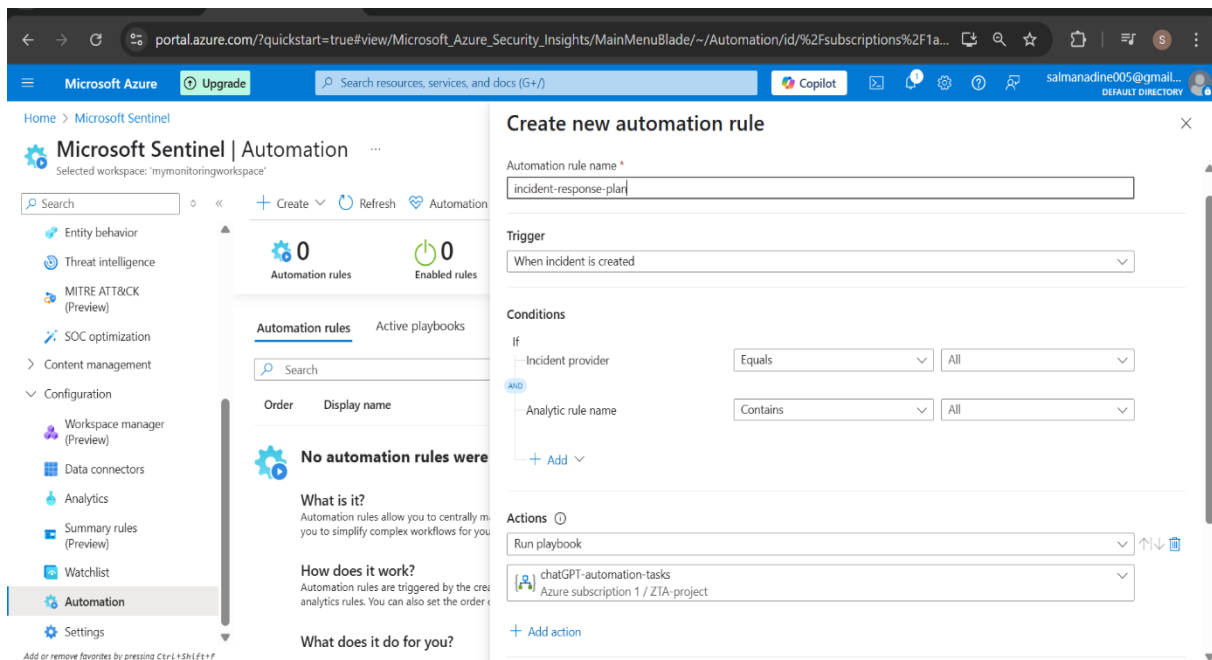


Figure 30: Création d'une règle d'automatisation

Le workflow Logic App s'active automatiquement lors de la création d'un incident. Ce processus intègre un appel à GPT afin d'analyser le contenu de l'incident et de proposer les meilleures étapes de remédiation.

Chaque étape suggérée est ensuite enregistrée sous forme de tâches.

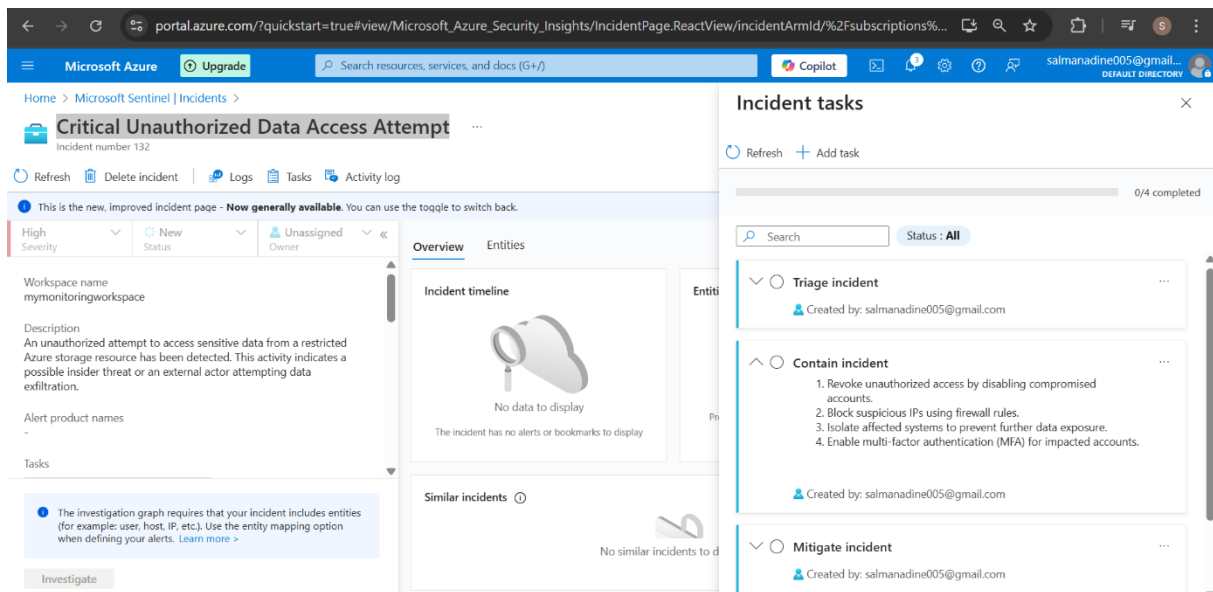


Figure 31: Exécution de notre règle d'automatisation

Les membres de l'équipe valident les tâches au fur et à mesure. Une fois cochées, ces actions sont additionnées dans un score de progression qui évolue jusqu'à atteindre 4/4 dans notre cas, marquant la clôture complète du plan de réponse.

3. Contrôle des Identités et de l'Accès Zero Trust

3.1.Intégration Entra ID

Pour assurer une gestion sécurisée des identités et des accès dans notre environnement cloud, nous avons intégré Microsoft Entra ID comme service centralisé d'authentification et de gouvernance des accès. Cette intégration constitue un pilier essentiel de notre architecture, en cohérence avec les recommandations du modèle Zero Trust.

Nous avons commencé par créer de nouveaux utilisateurs en renseignant leurs informations principales, leur permettant ainsi d'accéder aux ressources nécessaires selon leur rôle dans l'organisation. Cette étape permet d'assurer un inventaire propre des identités, tout en posant les bases d'une gouvernance rigoureuse.

Dans un second temps, nous avons mis en œuvre une politique de contrôle d'accès basée sur les rôles, en assignant à chaque utilisateur un niveau minimal de privilèges. Les rôles tels que Global Reader ou Secure Access Administrator ont été choisis de manière ciblée, en tenant compte des responsabilités de chacun. Cette approche garantit une application stricte du principe du moindre privilège, tel que défini par le modèle Zero Trust et les cadres comme le NIST SP 800-207.

Dans le cadre de la gouvernance des identités d'entreprise, cette segmentation précise permet de limiter les risques liés aux privilèges excessifs, tout en maintenant la souplesse nécessaire

aux différents métiers. Elle facilite également la révision périodique des accès, élément clé de la conformité.

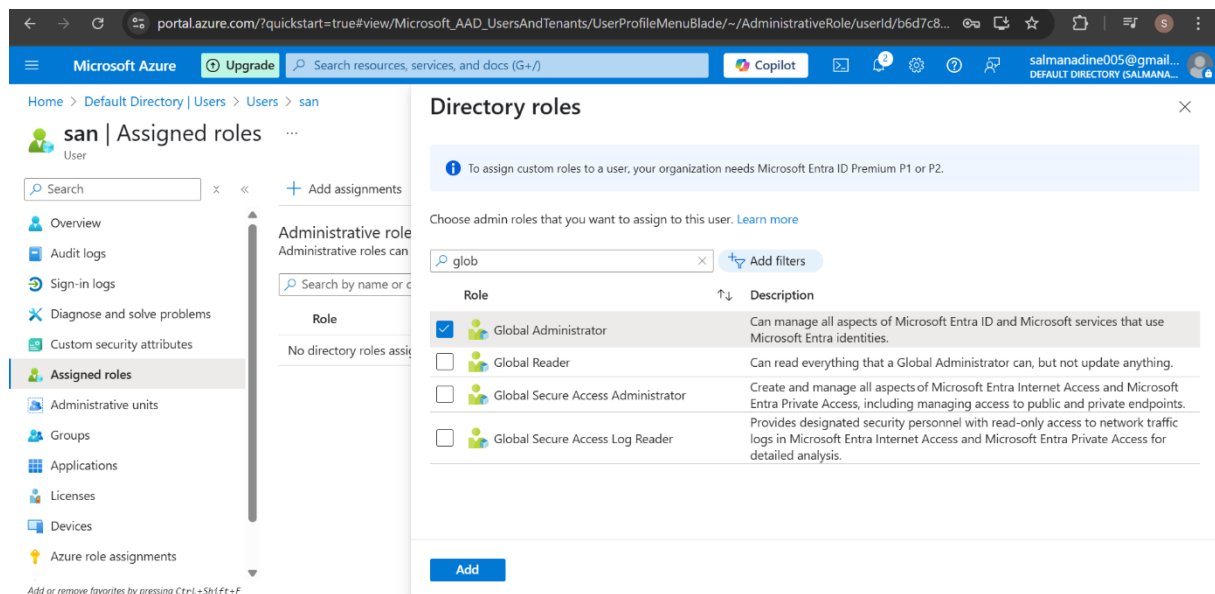


Figure 32: Mise en place de RBAC dans Entra ID

Par ailleurs, nous avons configuré les applications dans la section entreprise applications d'Entra ID. Cela inclut l'enregistrement des applications et l'attribution de rôles personnalisés à des utilisateurs spécifiques. Chaque rôle est défini dans le manifeste de l'application, avec des autorisations précises sur les fonctionnalités ou données accessibles.

L'attribution des rôles peut se faire de manière granulaire, soit directement à des utilisateurs individuels, soit à travers des groupes prédéfinis. Cette approche assure une gestion fine, évolutive et facilement contrôlable des accès aux applications internes, tout en renforçant la sécurité au sein de l'écosystème Azure.

- Configuration de l'authentification fédérée avec SAML et SSO

Dans le cadre du renforcement de notre modèle de sécurité basé sur les identités, nous avons mis en place l'intégration du protocole SAML sur notre serveur MySQL et notre application Internal-ZT-App. Cette configuration permet d'établir une fédération d'identité entre Microsoft Entra ID et les applications concernées, en centralisant l'authentification via un fournisseur d'identité de confiance.

SAML joue ici un rôle clé en tant que protocole standardisé pour l'échange d'informations d'authentification entre un fournisseur d'identité et un fournisseur de service. Il permet d'établir une session sécurisée entre l'utilisateur et l'application, sans avoir à transmettre d'identifiants à répétition.

Cette implémentation s'accompagne de l'activation du SSO sur les deux applications. Grâce à cette authentification unique, un utilisateur authentifié via Entra ID peut accéder directement à

MySQL Server ou à Internal-ZT-App sans devoir ressaisir ses identifiants à chaque interaction. Cela renforce la sécurité des connexions tout en améliorant l'expérience utilisateur.

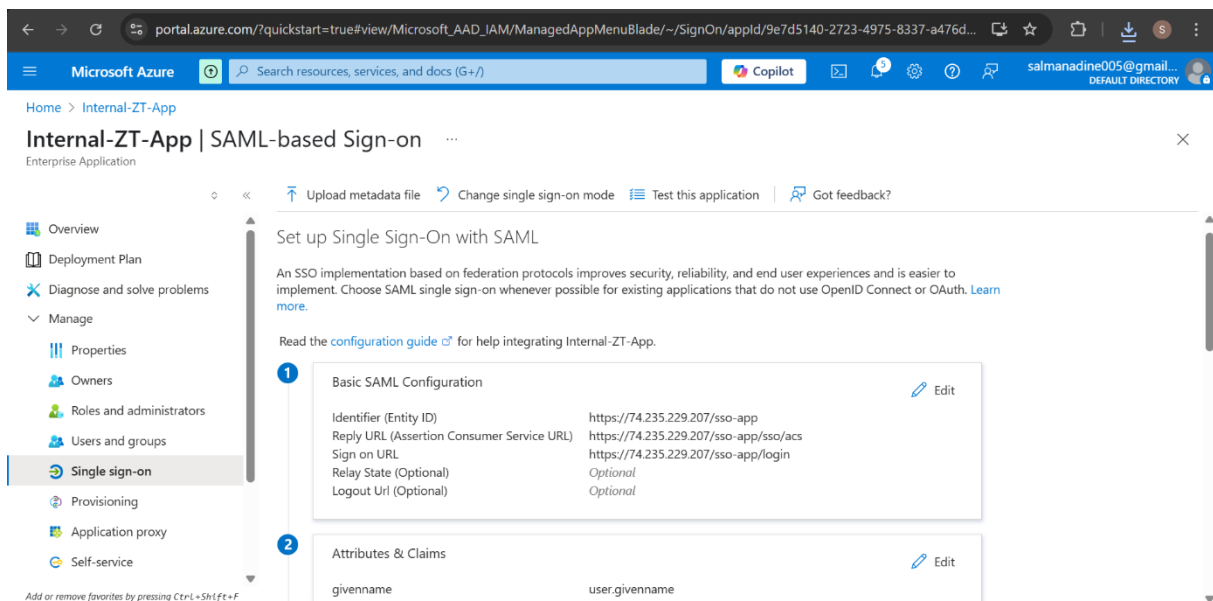


Figure 33: Configuration du SAML pour l'application Internal-ZT-App

Pour l'organisation, le SSO permet une gestion unifiée des accès, une diminution du nombre de mots de passe à gérer, et une réduction des appels au support liés aux réinitialisations. Il facilite également le suivi des connexions et des accès via les logs unifiés d'Entra ID, tout en répondant aux exigences de conformité liées à l'access management.

Une fois la configuration terminée, l'accès aux applications depuis les machines connectées se fait de manière fluide, à condition que l'utilisateur possède les autorisations nécessaires. Cette intégration renforce ainsi la cohérence du modèle Zero Trust appliqué au cycle de vie des identités, en validant systématiquement l'identité de l'utilisateur avant toute ouverture de session.

AuditLogs affiche les actions effectuées sur les ressources Azure : qui a fait quoi, quand, sur quelle ressource, et avec quel résultat. Ils servent à la traçabilité, la sécurité et la conformité.

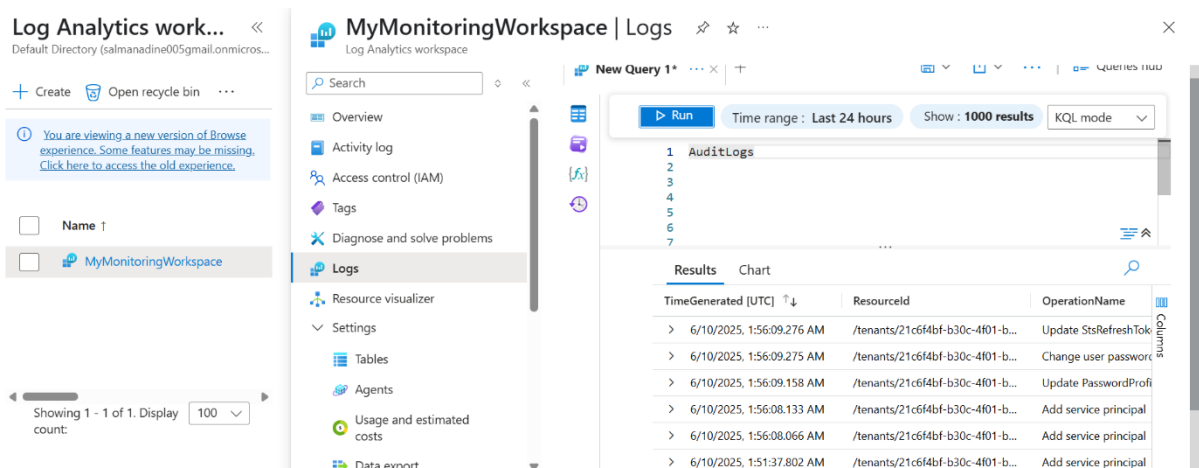


Figure 34: Affichage des actions effectuées sur les ressources Azure via les AuditLogs

3.2.Prisma Access et ZTNA

Pour renforcer l'accès sécurisé aux applications internes hébergées sur Azure, nous avons déployé une architecture s'appuyant sur Prisma Access et le modèle ZTNA. Ce déploiement s'inscrit dans une démarche Zero Trust, combinant segmentation dynamique, contrôle contextuel et simplification de l'accès applicatif.

Nous avons commencé par créer un groupe de connecteurs nommé ZTNA_ConnectorGroupSani au sein de l'interface Prisma Access. Ce groupe sert de point d'ancrage logique pour organiser les connecteurs chargés de relier les ressources internes aux utilisateurs finaux. Il regroupe les applications sensibles, comme DVWA et SQL, en les isolant du reste de l'environnement réseau.

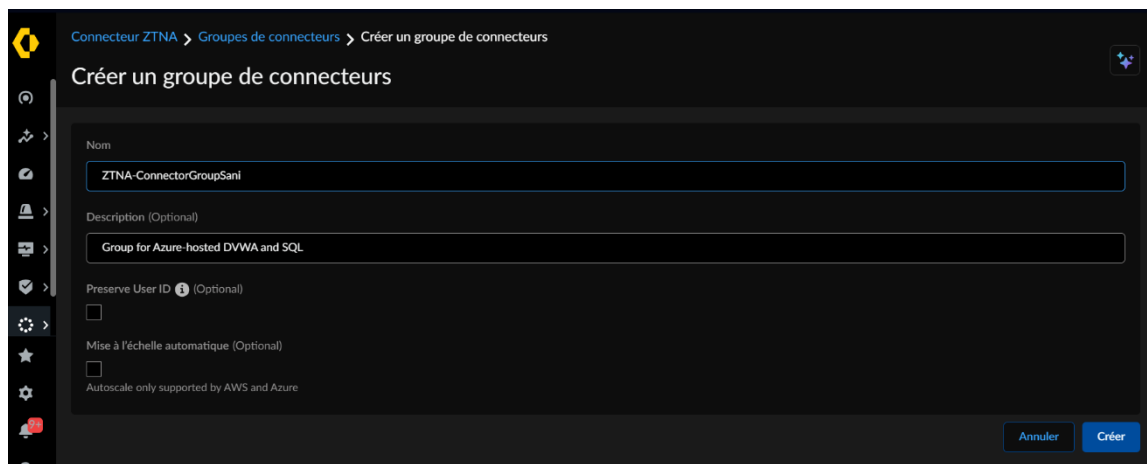


Figure 35: Création d'un groupe de connecteurs dans Prisma Access

Un connecteur nommé DVWA-Connector a ensuite été créé et rattaché à ce groupe. Son objectif est de fournir un canal d'accès sécurisé à l'application DVWA, tout en garantissant la préservation de l'identité utilisateur et la réduction de la surface d'exposition. Cette encapsulation permet de masquer l'application du réseau public, tout en permettant un accès contrôlé aux utilisateurs authentifiés.

Le connecteur a été déployé depuis Azure via un modèle Prisma Access préconfiguré. Il a été intégré à un réseau virtuel sécurisé avec un sous-réseau dédié, garantissant une isolation logique des flux et une meilleure maîtrise de la segmentation réseau. Ce déploiement répond à plusieurs exigences du modèle Zero Trust décrit dans le NIST SP 800-207 : segmentation par sous-réseaux, définition d'une périphérie logique, et gouvernance des accès par des règles RBAC.

Une fois le déploiement terminé, le connecteur a été vérifié comme actif dans l'interface Prisma Access. Ce statut confirme la liaison opérationnelle entre l'environnement cloud et Prisma, et valide que les flux d'accès aux ressources internes peuvent désormais être traités selon les politiques ZTNA définies.

Enfin, l'application privée a été configurée dans Prisma Access, avec des politiques d'accès associées. Cette configuration permet de spécifier quels utilisateurs ou groupes peuvent accéder à l'application, dans quelles conditions, et avec quelles autorisations. Grâce au connecteur ZTNA, aucune configuration réseau complexe n'est nécessaire. L'accès est acheminé de

manière transparente, de bout en bout, dans le respect des principes Zero Trust, tout en maintenant une traçabilité complète des connexions.

On remarque que notre connecteur ZTNA est actif.

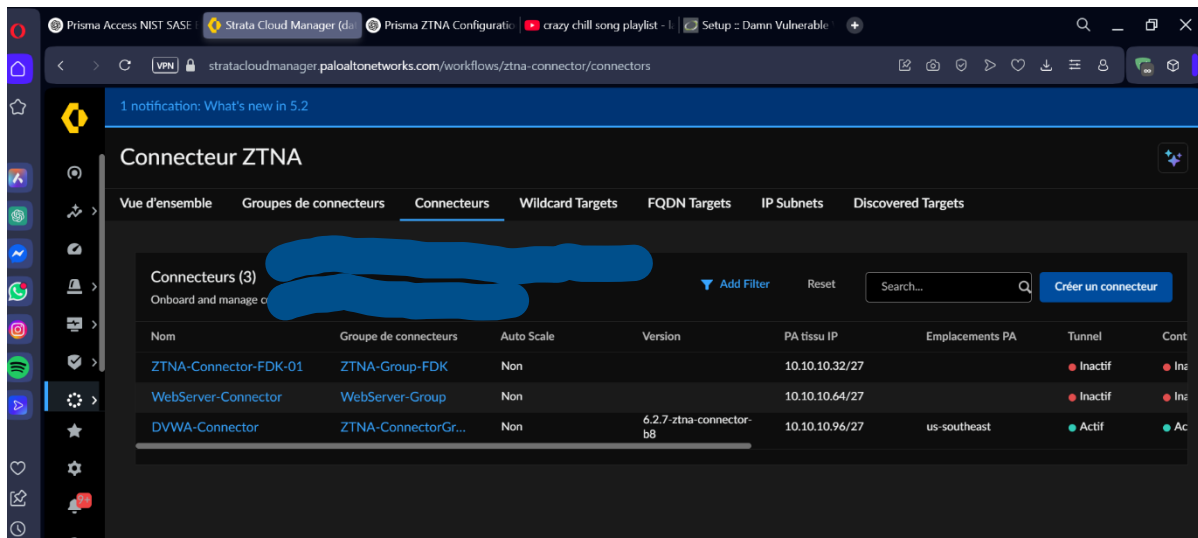


Figure 36: Vérification que le connecteur ZTNA est actif

Pour finaliser l'intégration des applications internes dans notre architecture Zero Trust, nous avons configuré l'accès à notre application privée dans Prisma Access à l'aide du modèle ZTNA. Cette approche permet un accès contrôlé, sécurisé et transparent pour les utilisateurs autorisés, sans exposition directe de l'application ni dépendance à des configurations réseau complexes. Le ZTNA Connector joue ici un rôle central en assurant la liaison entre l'infrastructure Prisma Access et l'application hébergée, tout en maintenant une isolation complète vis-à-vis du réseau public.

- Le Data Loss Prevention

Après avoir vérifié la connectivité entre l'utilisateur et l'application à travers Prisma Access, nous avons mis en place une politique de Data Loss Prevention. Cette politique DLP a été conçue pour détecter en temps réel les fuites potentielles de données sensibles, comme les adresses mail, les identifiants d'API, ou les numéros de carte bancaire. Elle repose sur l'analyse de contenu circulant dans le flux applicatif protégé, et génère des alertes dès qu'un motif sensible est identifié.

Cette configuration répond aux attentes des modèles SASE et SDP, en intégrant la surveillance des données à la couche d'accès, et en rendant cette surveillance indépendante de l'emplacement du terminal ou du réseau utilisé. Elle reflète également les exigences du pilier Data dans le cadre Zero Trust défini par le NIST SP 800-207, en assurant une visibilité complète sur l'usage des données critiques.

Nous avons testé le profil DLP à l'aide d'un fichier contenant des données simulées. L'objectif était de valider le bon fonctionnement des expressions régulières et des règles prédéfinies intégrées dans la politique. Le test a permis de confirmer la détection efficace des motifs cibles,

démontrant la capacité de la plateforme à identifier des contenus à risque et à en générer des alertes corrélables avec les autres outils de sécurité déjà en place.

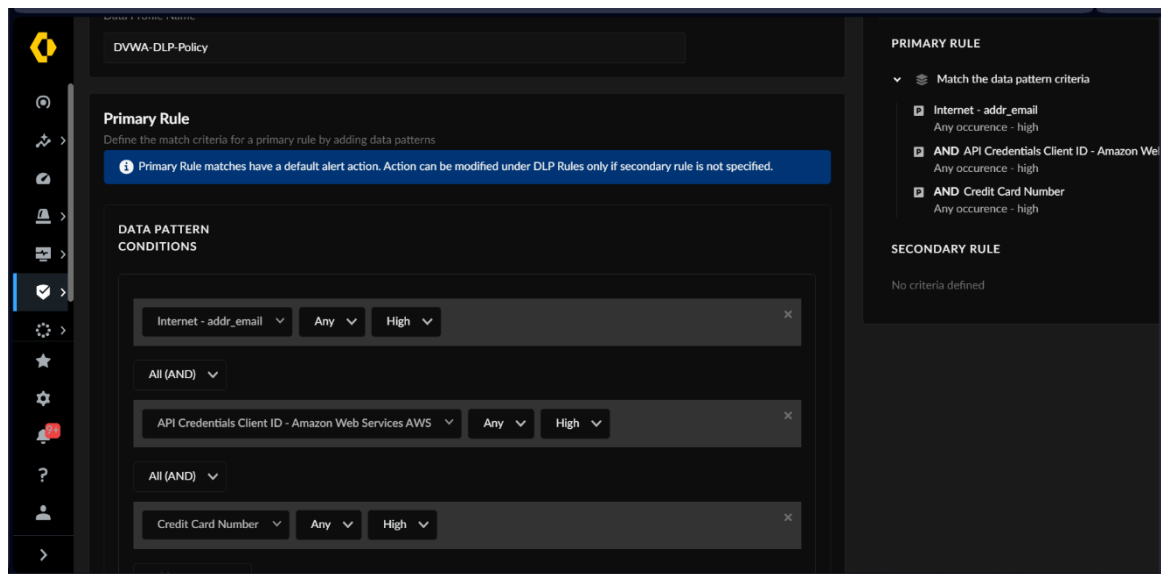


Figure 37: Configuration d'une politique de prévention des pertes de données (DLP)

On test notre profil DLP sur un fichier suspect afin de valider les correspondances avec des motifs de données sensibles définis :

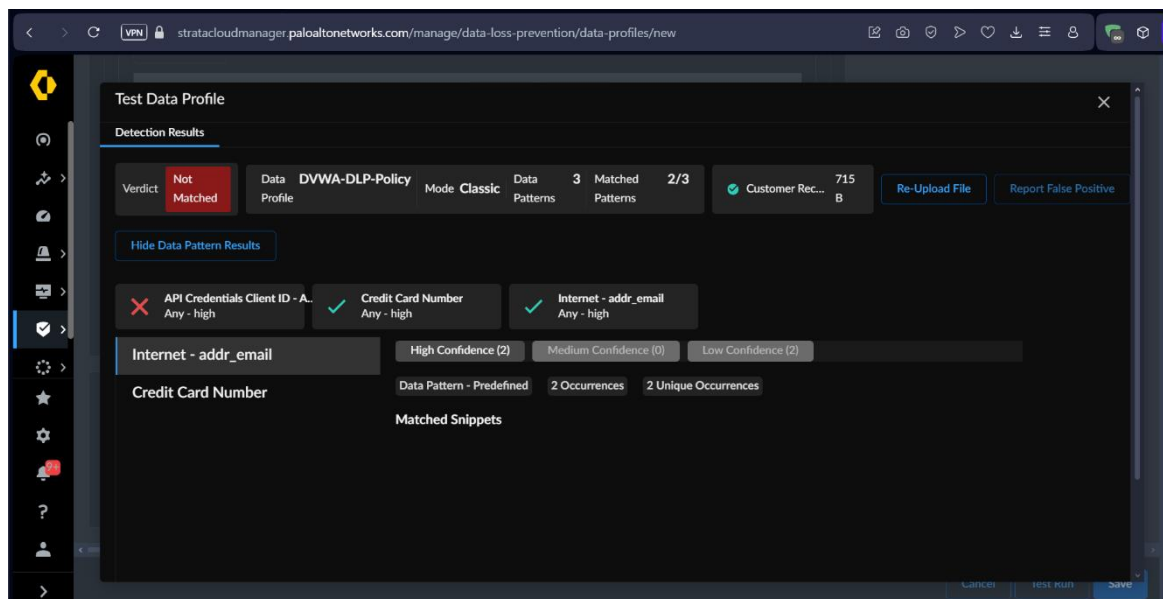


Figure 38: Test du profil DLP sur un fichier suspect

4. Tableau de Bord SOC et Analyse FinOps

Le conteneur costexport situé dans le compte de stockage *sanikoyani1* est utilisé pour centraliser l'exportation des données liées aux aspects FinOps dans Azure, comme les journaux de facturation, d'utilisation ou d'optimisation des ressources. Ces données sont exportées régulièrement via les fonctionnalités de Microsoft Cost Management, dans des formats compatibles avec les outils d'analyse comme Power BI ou les Workbooks Azure.

On configure un export automatique nommé lucuesta-ztafinpostscosts dans Azure subscription 1, afin de récupérer chaque jour les détails réels d'utilisation et de coûts dans le but d'alimenter les analyses FinOps. L'export est actif et planifié en fréquence quotidienne.

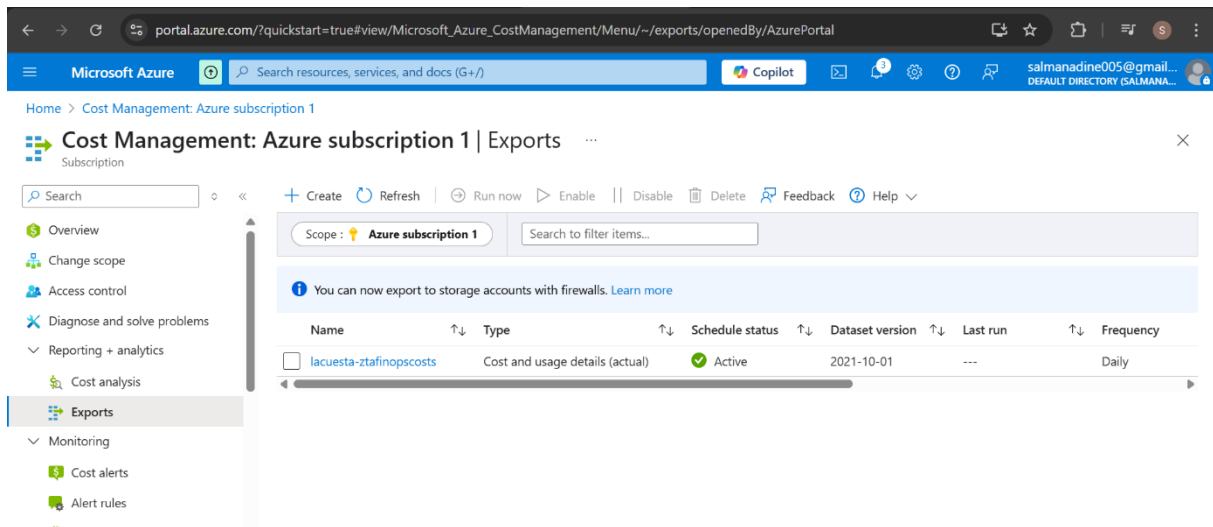


Figure 39: Exportation des données liées aux aspects FinOps

On utilise Power BI pour se connecter directement aux sources de données Azure, telles qu’Azure Cost Management, afin de visualiser, explorer et corrélérer les informations relatives à la consommation et aux coûts du cloud. Grâce au connecteur natif ou à l’application Azure Cost Management dans Power BI, on peut importer des données de facturation, d’usage, de réservations ou encore de recommandations d’optimisation. Ces données sont ensuite exploitées dans des rapports interactifs permettant d’analyser les tendances de consommation, d’identifier les ressources les plus coûteuses, de suivre les écarts budgétaires, et de prendre des décisions éclairées en matière de gouvernance FinOps.

On établit une connexion directe entre Power BI et un cluster Azure Data Explorer (Kusto), afin d’interroger les données en temps réel à l’aide du langage KQL. Cette intégration permet de créer des rapports dynamiques et interactifs dans Power BI, tout en bénéficiant de la puissance de traitement du moteur Kusto sans avoir à importer les données localement.

4.1.Surveillance SOC via Power BI

On visualise dans Power BI des indicateurs clés de la sécurité opérationnelle, comme les IP sources les plus actives, l’activité de connexion dans le temps, la répartition des alertes par gravité, et une carte mondiale des attaques en cours.

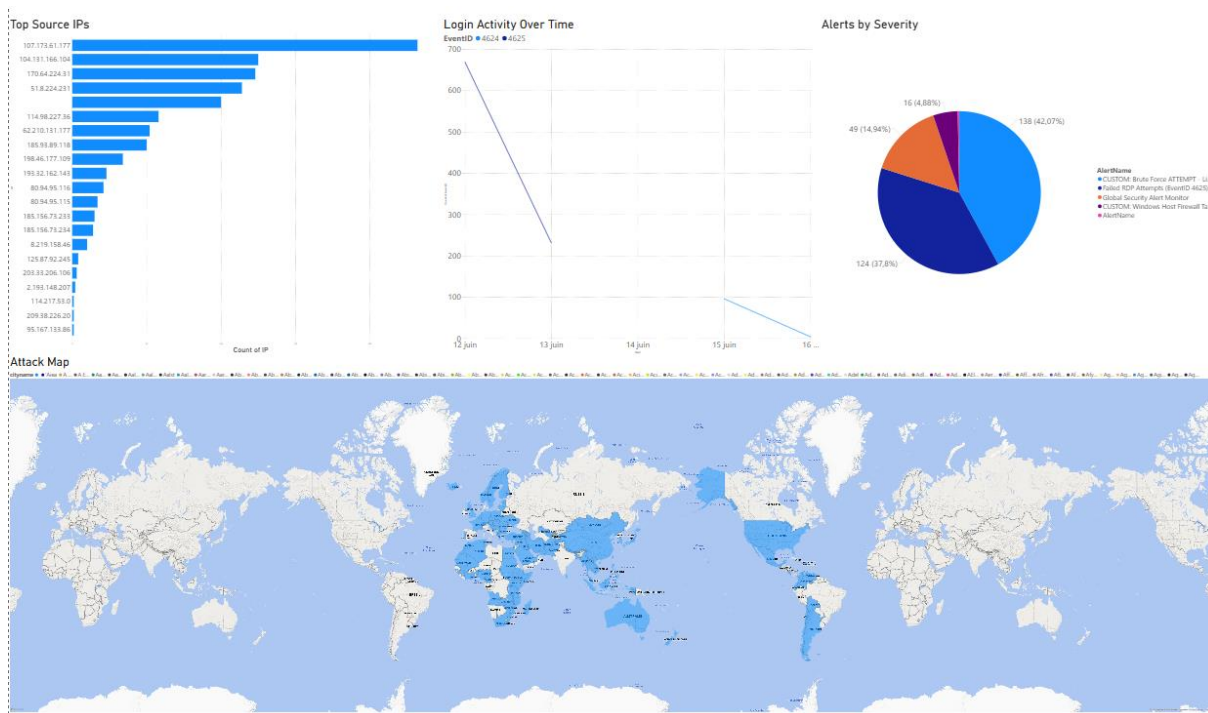


Figure 40: Surveillance SOC via Power BI

Ce tableau de bord a été conçu pour fournir au centre des opérations de sécurité (SOC) une visibilité claire et centralisée sur les activités réseau potentiellement malveillantes. Il permet notamment d'identifier rapidement les flux d'attaque suspects, en mettant en évidence les adresses IP les plus actives ou les plus fréquemment impliquées dans des tentatives d'accès non autorisées.

En parallèle, le tableau de bord offre une analyse des tendances de connexion, permettant de détecter des pics d'activité inhabituels ou des baisses soudaines, souvent révélateurs d'incidents de sécurité ou de comportements anormaux. Cette capacité à suivre l'évolution temporelle des connexions aide les analystes à anticiper ou à contextualiser les menaces.

Les incidents sont également classés et priorisés selon la gravité des alertes, ce qui permet au SOC de concentrer ses efforts sur les événements les plus critiques. Cette hiérarchisation est essentielle pour optimiser les temps de réponse et allouer les ressources de manière efficace.

Enfin, une carte interactive intégrée au tableau de bord permet de localiser géographiquement les origines des tentatives d'accès, en s'appuyant sur des données Geoip. Chaque point sur la carte est enrichi d'informations telles que l'adresse IP source, le nom du pays, voire la ville d'origine, offrant ainsi une représentation visuelle intuitive des zones les plus actives en matière de menaces.

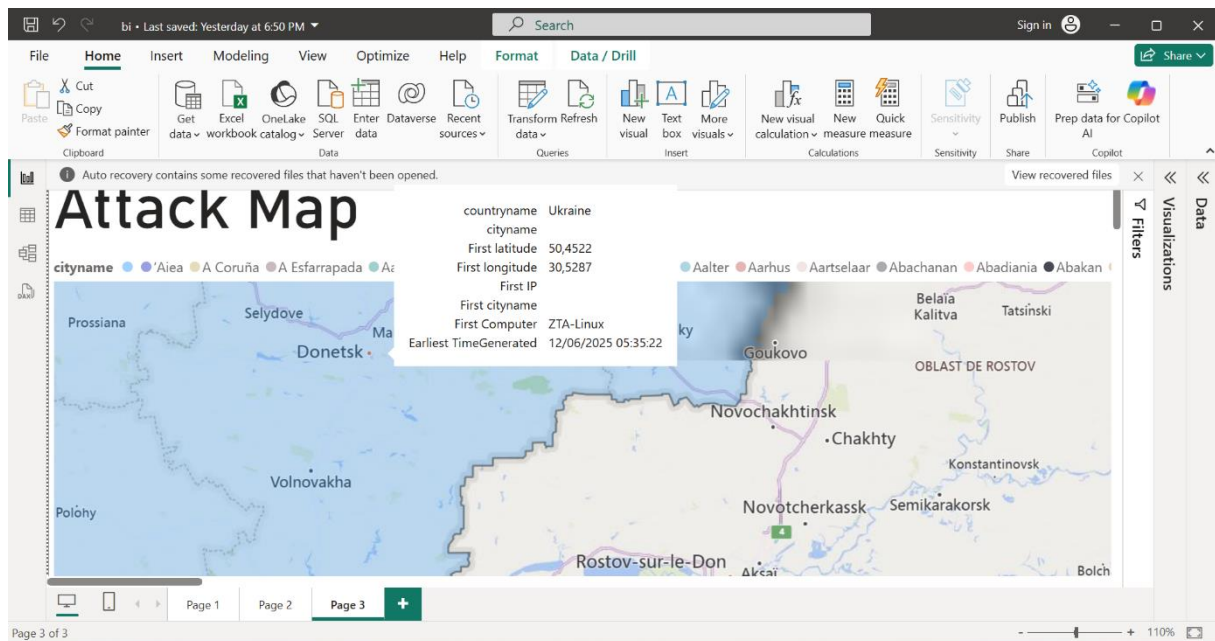


Figure 41: Attack Map

4.2. Suivi Financier (FinOps)

Ce tableau de bord Power BI a été conçu pour offrir une vue complète et dynamique de la consommation Azure et des coûts associés, en s'appuyant sur les données issues d'Azure Cost Management. Il permet non seulement de suivre les dépenses actuelles, mais aussi d'anticiper les coûts futurs grâce à des visualisations interactives et prédictives.

L'un des éléments centraux du tableau de bord est le graphique de répartition des coûts, qui présente les dépenses ventilées par service Azure, groupe de ressources et région. Ce diagramme en barres empilées ou en colonnes permet d'identifier rapidement les services les plus consommateurs (comme les machines virtuelles, le stockage ou les bases de données) et de repérer les zones géographiques où les coûts sont les plus élevés.

Un graphique en courbes illustre la tendance journalière des coûts sur la période sélectionnée. Il permet de visualiser l'évolution des dépenses dans le temps, de détecter des pics inhabituels ou des baisses soudaines, et d'identifier les jours où des changements significatifs ont eu lieu.

Des diagrammes circulaires sont utilisés pour mettre en évidence les postes budgétaires dominants. Ils offrent une vue synthétique de la répartition des coûts par catégorie, ce qui facilite la compréhension globale de la structure des dépenses et permet de cibler les axes d'optimisation.

Enfin, un graphe de prévision Forecast Cost affiche une estimation consolidée des coûts futurs, basée sur les tendances historiques. Ce graphique linéaire ou en aires permet d'anticiper les dépenses à venir, d'ajuster les budgets, et de prendre des décisions proactives en matière de gouvernance financière.

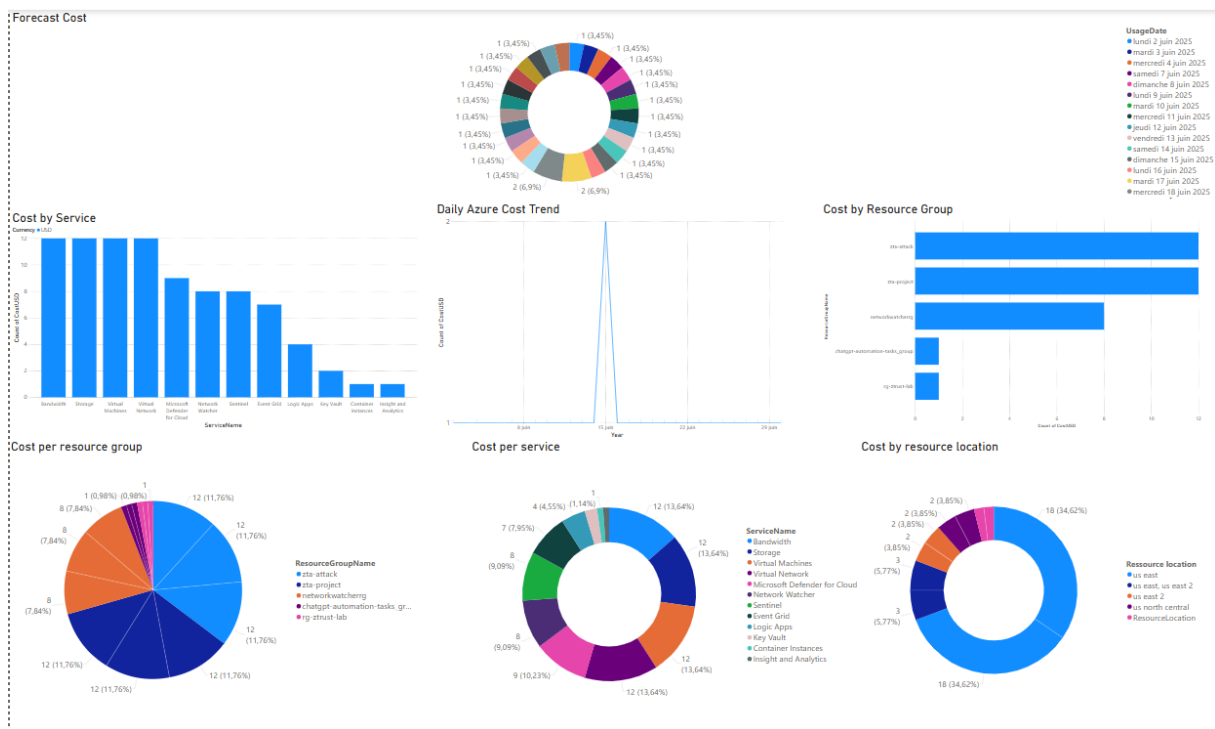


Figure 42: Suivi Financier (FinOps)

La visualisation suivante offre une lecture claire et interactive de la répartition des coûts au sein de l'infrastructure Azure mise en place dans le cadre du projet. Élaborée à partir des données collectées via Azure Cost Management, elle permet de distinguer les services les plus consommateurs de ressources budgétaires.

Les principaux contributeurs sont la bande passante, le stockage, les machines virtuelles (VM) et le réseau virtuel, chacun représentant environ 13,64 % du budget global. Cette répartition souligne le poids des ressources de base dans le fonctionnement opérationnel de l'environnement cloud.

À l'inverse, les services à moindre coût, bien qu'essentiels, tels que Insight and Analytics, Container Instances ou encore Key Vault, affichent une part relativement faible dans la consommation financière totale. Cette distribution permet non seulement de visualiser l'impact budgétaire de chaque composant, mais également d'identifier des pistes d'optimisation potentielles.

En somme, cette visualisation FinOps constitue un outil d'aide à la décision stratégique, facilitant la compréhension des dépenses, le suivi de leur évolution, ainsi que la mise en œuvre de mesures correctrices pour une gestion financière plus efficiente du cloud.

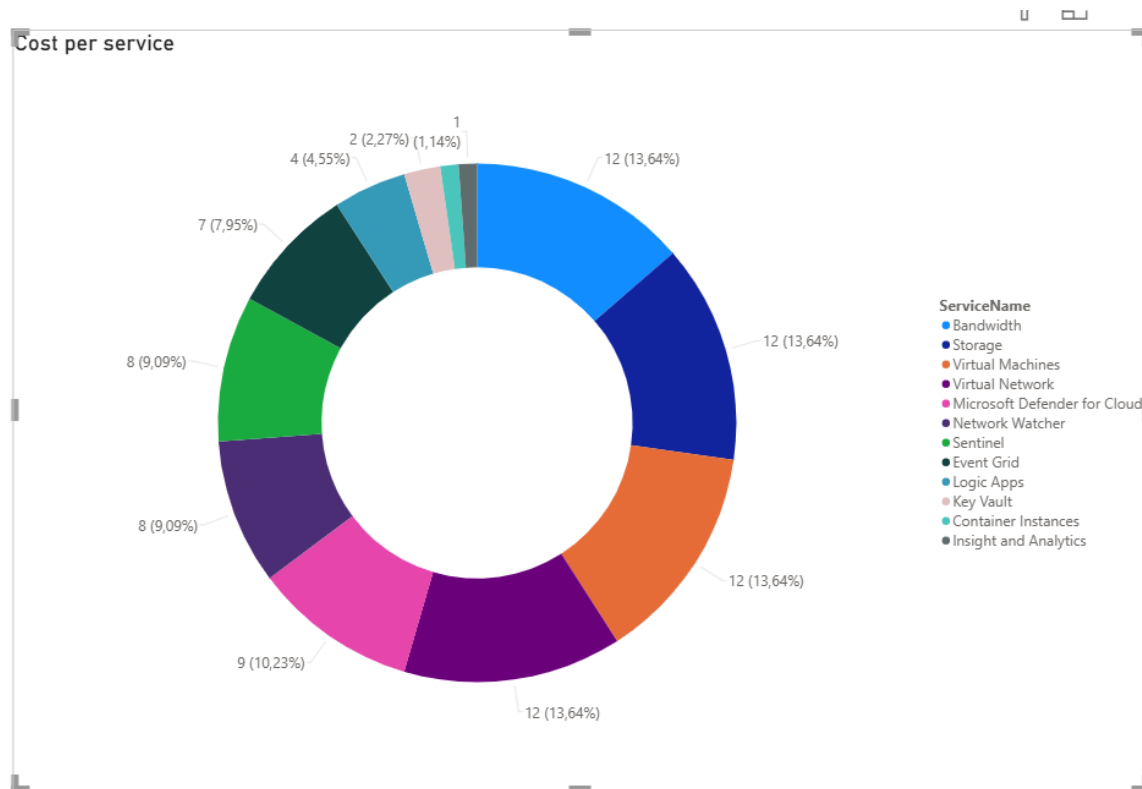


Figure 43 : Coût par service

Cette visualisation permet de comprendre comment les coûts sont répartis entre les principaux groupes de ressources au sein de l'infrastructure Azure déployée. En s'appuyant sur les données issues d'Azure Cost Management, elle constitue un outil précieux d'analyse pour mesurer l'impact financier de chaque bloc fonctionnel de la plateforme.

On observe une distribution relativement homogène des dépenses entre les groupes clés de l'infrastructure, avec zt-attack, zt-project et rg-ztrust-lab totalisant chacun 12 unités (11,76 %) du coût global. Cela suggère une répartition cohérente des charges de travail entre les différents composants critiques du projet.

Le groupe networkwatcherrg, destiné à la supervision réseau, occupe une part non négligeable avec 7,84 %, ce qui reflète l'importance accordée à la surveillance du trafic et au diagnostic réseau dans une architecture Zero Trust. En revanche, chatgpt-automation-tasks_group se distingue par une consommation budgétaire marginale (0,98 %).

Cette visualisation permet d'évaluer la consommation par domaine fonctionnel, de détecter d'éventuels déséquilibres ou surprovisionnement, et d'ajuster les ressources selon les priorités fonctionnelles et de sécurité.

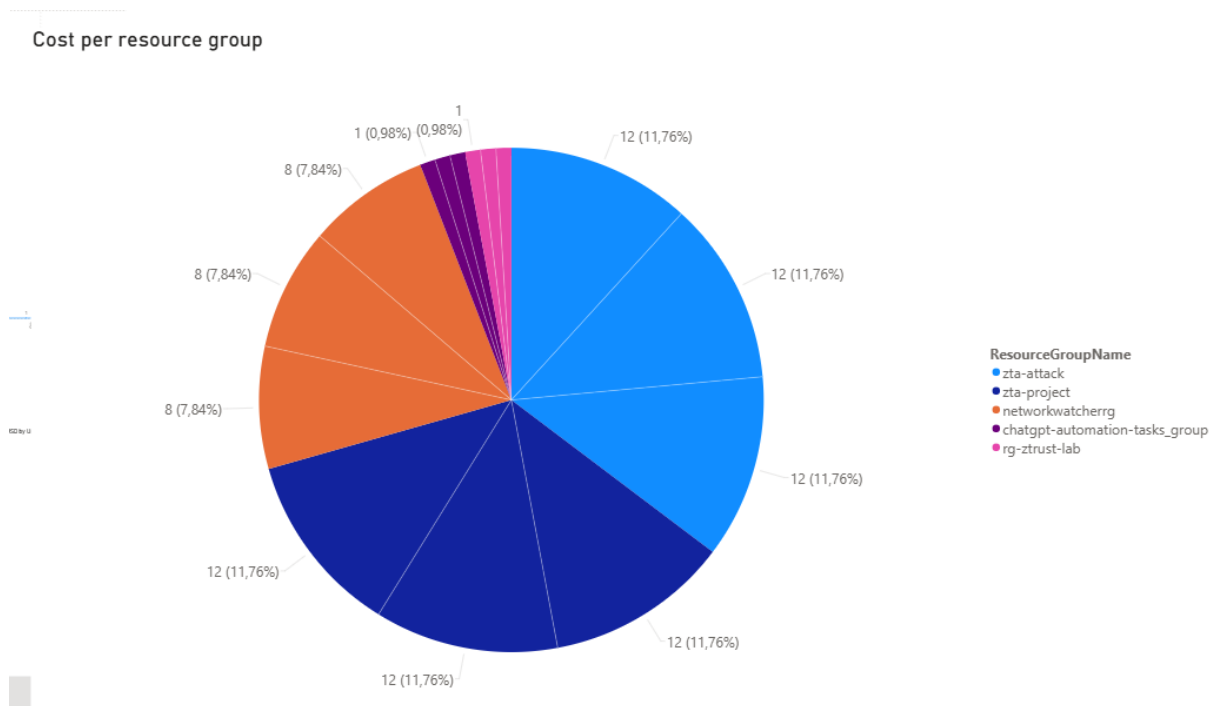


Figure 44: Coût par resource group

Cette visualisation présente la distribution des coûts en fonction des emplacements géographiques des ressources déployées dans le cloud Azure. Elle constitue un levier essentiel pour évaluer l'impact de la localisation sur les dépenses et orienter les stratégies d'optimisation régionale.

Les données révèlent une concentration significative des coûts dans la région "US East", qui cumule 34,62 % des dépenses totales (18 occurrences). Ce chiffre reflète probablement un déploiement centralisé d'une partie critique de l'infrastructure dans cette région, soit pour des raisons de disponibilité de services, de latence optimisée ou d'affinité avec certains composants de sécurité ou de supervision.

Les autres combinaisons régionales, telles que "US East 2", représentent chacune 5,77 %, ce qui indique une certaine distribution de charges entre plusieurs sous-régions.

D'autres emplacements, comme "US North Central" et "ResourceLocation", apparaissent à hauteur de 3,85 % chacun.

Cette ventilation des coûts par localisation géographique est déterminante dans une démarche FinOps, car elle permet:

- D'identifier les régions surconsommées.
- De repérer d'éventuelles opportunités de migration vers des régions plus économiques.
- D'ajuster la stratégie de déploiement pour équilibrer performance, conformité et coûts.

Cost by resource location

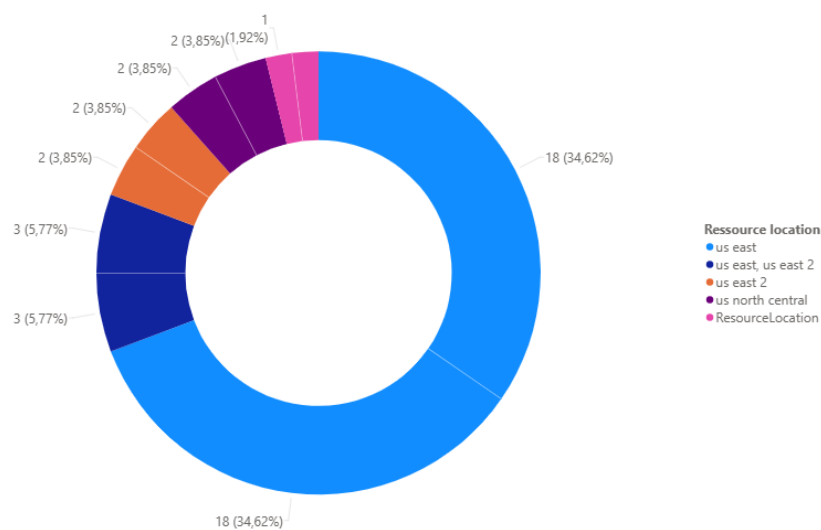


Figure 45: Coût par resource location

Cette visualisation représente la projection des coûts journaliers d'usage pour juin 2025. Elle met en évidence une distribution régulière, suggérant une consommation stable et maîtrisée sur l'ensemble de la période

Forecast Cost

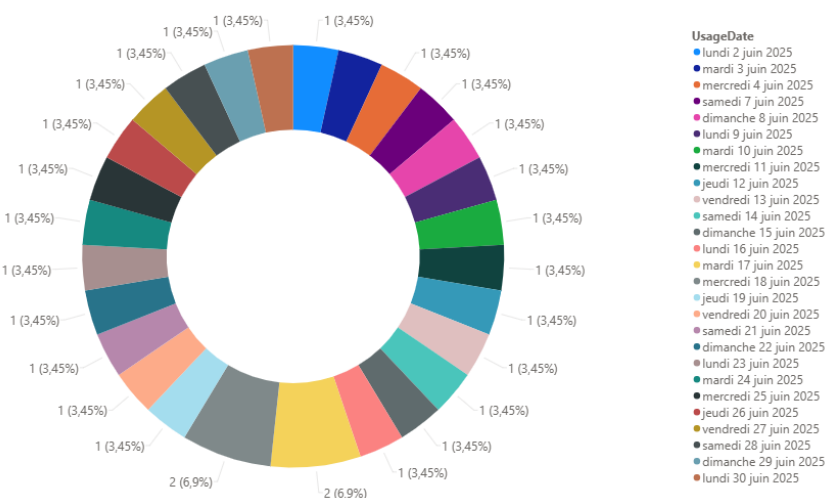


Figure 46: Forecast cost

5. Conclusion

Cette seconde phase a permis de transformer l'architecture initiale en un véritable SOC cloud intelligent. La détection des incidents via Sentinel, l'automatisation des réponses avec Logic Apps, et la visualisation des attaques et des coûts via Power BI offrent une gouvernance complète et réactive. L'intégration de Prisma Access complète la stratégie Zero Trust en assurant un contrôle granulaire des accès distants, consolidant ainsi la posture de sécurité globale du système.

Conclusion et perspectives

Ce projet de fin d'études, réalisé au sein de DATAPROTECT, m'a permis d'acquérir une expérience concrète dans le domaine de la sécurité des infrastructures cloud, en mettant en œuvre une architecture basée sur les principes du Zero Trust selon la norme NIST 800-207.

L'objectif principal était de concevoir, déployer et sécuriser une infrastructure automatisée sur Microsoft Azure, intégrant Prisma Access, Sentinel, Defender for Cloud et Entra ID, afin de garantir la détection, la prévention et la réponse aux incidents de sécurité.

Après avoir analysé les besoins et sélectionné les outils adaptés, j'ai développé un environnement complet incluant des machines virtuelles exposées à des attaques simulées, la centralisation des logs et leur visualisation via des workbooks et des tableaux de bord Power BI, ainsi que l'automatisation des alertes et rapports avec Logic Apps et OpenAI.

Cette expérience m'a permis de renforcer mes compétences techniques en sécurité cloud, automatisation et gouvernance, tout en découvrant des technologies innovantes et en appréhendant le travail en contexte professionnel.

Pour les perspectives, il serait intéressant d'approfondir la gestion des accès avec des solutions avancées comme le Conditional Access et le Privileged Identity Management, d'enrichir le SOC avec un chatbot intelligent exploitant l'historique des incidents. De plus, l'intégration d'applications métiers sécurisées dans cet environnement Zero Trust et le déploiement complet d'une solution SASE pourraient constituer des évolutions majeures.

Ce projet marque une étape importante dans mon parcours professionnel et m'encourage à poursuivre dans la voie de la sécurité cloud et de l'automatisation, avec la volonté d'approfondir mes connaissances et d'apporter des solutions innovantes. Je souhaite que ce travail soit à la hauteur des attentes de mes encadrants et des membres du jury, témoignant de mon sérieux et de mon engagement.

Bibliographie

- [1] «National Institute of Standards and Technology,» [En ligne]. Available: <https://csrc.nist.gov/pubs/sp/800/207/final>. [Accès le 22 Février 2025].
- [2] «Paloalto,» [En ligne]. Available: <https://www.paloaltonetworks.fr/cyberpedia/what-is-zero-trust-network-access-ztna>. [Accès le 24 Février 2025].
- [3] «Microsoft,» [En ligne]. Available: <https://www.microsoft.com/fr-fr/security/business/security-101/what-is-sase>. [Accès le 24 Février 2025].
- [4] «National Institute of Standards and Technology,» [En ligne]. Available: <https://pages.nist.gov/zero-trust-architecture/VolumeB/appendices/Appendix-E2B1.html>. [Accès le 25 Février 2025].
- [5] «Finops foundation,» [En ligne]. Available: <https://www.finops.org/introduction/what-is-finops/>. [Accès le 01 Mars 2025].
- [6] «Cloudflare,» [En ligne]. Available: <https://www.cloudflare.com/fr-fr/learning/cloud/what-is-hybrid-cloud/>. [Accès le 01 Mars 2025].